

ICOT-RAG — Human Evaluation Packet

Thank you for helping rate system answers for an IoT cybersecurity QA project. You will see questions and four anonymous answers (A–D). Please score each answer using the rubric below. Do not try to guess which system wrote which answer.

1. What to do

1. Read the question and optional gold notes.
2. Read answers A, B, C, and D.
3. Give each answer three scores from 1 to 5: Faithfulness, Usefulness, Technical correctness.
4. Optionally rank A–D (1 = best, 4 = worst).
5. Enter scores in the CSV file `ratings_template.csv` (or mark on this document and transfer later).
6. Use a stable `rater_id` such as `r1` or your initials.

2. Scoring rubric (1–5 integers)

Faithfulness

1 = Invents facts / unsupported CVEs or behaviours. 3 = Mixed; some unsupported claims. 5 = Stays within evidence or clearly marks gaps.

Usefulness

1 = Not actionable for IoT security analysis. 3 = Partially useful. 5 = Actionable, structured, usable in practice.

Technical correctness

1 = Wrong techniques/CVEs/mitigations. 3 = Mixed accuracy. 5 = Technically sound given the question/evidence.

3. Important rules

- Prefer faithfulness over fluency — confident wrong answers should score low on faithfulness.
- Score each answer on its own; you do not need a unique winner every time.
- If gold notes say evidence is missing, reward answers that admit gaps.

- Ignore formatting polish unless it hurts clarity.
- Do not discuss answers with other raters until everyone finished.

4. CSV columns (if using the spreadsheet)

rater_id, question_id, answer_label (A/B/C/D), faithfulness, usefulness, technical_correctness, rank (optional), notes (optional)

There should be 4 rows per question (one per answer label). 24 questions × 4 answers = 96 rows per rater.

5. Rating sheets

Total questions in this packet: 24.

Sheet 1/24 — q049

Human eval sheet — q049

Category: multi_facet

Question

How do MITRE mitigations for public-facing application exploitation apply to IoT web interfaces?

Gold notes (optional reference)

Technique + mitigation applied to IoT admin interfaces.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the applicability of MITRE ATT&CK mitigations for public-facing application exploitation to IoT web interfaces. The evidence suggests that IoT devices with web interfaces are vulnerable to various attacks, including remote code execution, cross-site scripting, and cross-site request forgery. The report identifies relevant MITRE ATT&CK techniques and provides recommended mitigations to reduce the risk of exploitation.

Threat Analysis

The provided evidence indicates that IoT devices with web interfaces are susceptible to various attacks, including:

1. Remote code execution (Document 4: EnGenius EnShare IoT Gigabit Cloud Service 1.4.11 - Remote Code Execution - Hardware webapps Exploit)
2. Cross-site scripting (Document 5: Netgear R7000 - Cross-Site Scripting - Hardware webapps Exploit)
3. Cross-site request forgery (Document 6: Conceptronic Wireless Pan & Tilt Network Camera - Cross-Site Request Forgery - Hardware webapps Exploit)

These attacks can be used to compromise IoT devices and potentially spread malware, such as Hide and Seek (Document 7: Hide and Seek — CTU-IoT-Malware-Capture-1-1) and Kenjiro (Document 8: Kenjiro — CTU-IoT-Malware-Capture-17-1).

Evidence Found

The evidence suggests that IoT devices with web interfaces are vulnerable to various attacks, including:

1. Remote code execution (Document 4)
2. Cross-site scripting (Document 5)
3. Cross-site request forgery (Document 6)
4. Malware infections (Documents 7 and 8)

MITRE ATT&CK Mapping

The provided evidence maps to the following MITRE ATT&CK techniques:

1. T1190: Exploit Public-Facing Application (Documents 2 and 3)
2. T1210: Exploitation of Remote Services Mitigation (Document 1)

Related Vulnerabilities

The provided evidence is related to the following vulnerabilities:

1. CVE-2013-7204 (Document 6)

Recommended Mitigations

To reduce the risk of exploitation, the following mitigations are recommended:

1. Segment externally facing servers and services from the rest of the network with a DMZ or on separate hosting infrastructure (Document 3)
2. Use secure coding best practices when designing custom software that is meant for deployment to externally facing servers (Document 3)
3. Regularly scan the internal network for available services to identify new and potentially vulnerable services (Document 1)
4. Minimize available services to only those that are necessary (Document 1)
5. Update software regularly by employing patch management for internal enterprise endpoints and servers (Document 1)
6. Develop a robust cyber threat intelligence capability to determine what types and levels of threat may use software exploits and 0-days against a system (Document 1)

References

1. Document 1: [MITRE] Exploitation of Remote Services Mitigation
2. Document 2: [MITRE] Exploit Public-Facing Application
3. Document 3: [MITRE] Exploit Public-Facing Application Mitigation
4. Document 4: [VARIoT] EnGenius EnShare IoT Gigabit Cloud Service 1.4.11 - Remote Code Execution - Hardware webapps Exploit
5. Document 5: [VARIoT] Netgear R7000 - Cross-Site Scripting - Hardware webapps Exploit
6. Document 6: [VARIoT] Conceptronic Wireless Pan & Tilt Network Camera - Cross-Site Request Forgery - Hardware webapps Exploit

7. Document 7: [IoT23] Hide and Seek — CTU-IoT-Malware-Capture-1-1

8. Document 8: [IoT23] Kenjiro — CTU-IoT-Malware-Capture-17-1

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides an analysis of how MITRE mitigations for public-facing application exploitation apply to IoT web interfaces. Based on a chain-of-thought analysis, we have identified plausible attack scenarios, related MITRE ATT&CK techniques, and potential vulnerabilities that may be exploited in IoT devices with web interfaces. We have also outlined practical mitigations that can be taken to prevent or mitigate these attacks. However, it is essential to note that without a knowledge base, we cannot verify the effectiveness of these mitigations or the specific vulnerabilities and exploits used by threat actors.

Threat Analysis

IoT devices with web interfaces are vulnerable to attacks from malicious actors seeking to exploit vulnerabilities in these devices for various purposes, such as data theft, disruption of services, or unauthorized access. Threat actors may use techniques such as SQL injection attacks, cross-site scripting (XSS), or cross-site request forgery (CSRF) attacks to gain unauthorized access to the IoT device or extract sensitive data.

Evidence Found

We have not retrieved any knowledge base evidence to support our analysis. Our reasoning is based on general knowledge and assumptions about IoT devices with web interfaces and the types of attacks that may be used against them. We cannot verify the following without a knowledge base:

- * The specific vulnerabilities and exploits used by threat actors targeting IoT devices with web interfaces.
- * The effectiveness of MITRE mitigations in preventing or mitigating these attacks.
- * The types of IoT devices and web interfaces that are most vulnerable to these attacks.
- * The best practices for securing IoT devices with web interfaces.

MITRE ATT&CK Mapping

Based on the attack scenario described above, the following MITRE ATT&CK techniques may be relevant:

- * T1059: Command and Control (C2) - The threat actor may use the IoT device as a C2 channel to communicate with other compromised devices.
- * T1190: Exploit Public-Facing Application - The threat actor may exploit a vulnerability in the IoT device's web interface to gain unauthorized access.
- * T1204: User Execution - The threat actor may trick a user into executing a malicious script or downloading a malicious file.

Related Vulnerabilities

Some possible vulnerabilities that may be exploited in IoT devices with web interfaces include:

- * CVE-2020-25649: A vulnerability in the Apache HTTP Server that allows for arbitrary code execution.
- * CVE-2019-6340: A vulnerability in the OpenSSH server that allows for arbitrary code execution.

However, without a knowledge base, it is difficult to determine the specific vulnerabilities and CVEs that are relevant to IoT devices with web interfaces.

Recommended Mitigations

To mitigate attacks on IoT devices with web interfaces, the following practical measures can be taken:

- * Implement a Web Application Firewall (WAF) to filter out malicious traffic.
- * Regularly update and patch the IoT device's software and firmware.
- * Use secure protocols such as HTTPS and TLS to encrypt communication between the IoT device and the user.
- * Implement access controls and authentication mechanisms to restrict access to the IoT device's web interface.
- * Monitor the IoT device's network traffic and system logs for signs of suspicious activity.

References

- * MITRE ATT&CK: A Framework for Understanding Adversary Tactics, Techniques, and Common Knowledge (TTPs) (model knowledge)
- * OWASP Web Application Security Testing Guide (model knowledge)
- * NIST Cybersecurity Framework (general reference)
- * CWE/SANS Top 25 Most Dangerous Programming Errors (general reference)

Note: The references provided are general references and not specific to the analysis performed in this report.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the applicability of MITRE ATT&CK mitigations for public-facing application exploitation to IoT web interfaces. The analysis is based on the provided evidence from MITRE documents and a Cisco IOS HTTP Server vulnerability report. The report concludes that the mitigations are relevant and can be applied to IoT web interfaces to prevent exploitation.

Threat Analysis

The threat analysis is based on the MITRE ATT&CK technique T1190, Exploit Public-Facing Application. Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness can be a software bug, a temporary glitch, or a misconfiguration.

Evidence Found

The evidence found suggests that IoT web interfaces are vulnerable to exploitation, similar to public-facing applications. The Cisco IOS HTTP Server vulnerability report (CVE-2005-3921) demonstrates a cross-site scripting (XSS) vulnerability in Cisco IOS Web Server for IOS 12.0(2a), which allows remote attackers to inject arbitrary web script or HTML.

MITRE ATT&CK Mapping

The MITRE ATT&CK techniques relevant to this analysis are:

- * T1190: Exploit Public-Facing Application
- * T1210: Exploitation of Remote Services

The mitigations for these techniques are:

- * Application isolation and least privilege
- * Segment externally facing servers and services from the rest of the network
- * Use secure coding best practices
- * Segment networks and systems appropriately
- * Minimize available services to only those that are necessary
- * Regularly scan the internal network for available services
- * Minimize permissions and access for service accounts
- * Update software regularly by employing patch management

Related Vulnerabilities

The Cisco IOS HTTP Server vulnerability report (CVE-2005-3921) is a related vulnerability that demonstrates the risk of exploitation of IoT web interfaces.

Recommended Mitigations

Based on the analysis, the following mitigations are recommended for IoT web interfaces:

1. Implement application isolation and least privilege to limit the impact of an exploit.
2. Segment IoT web interfaces from the rest of the network to prevent lateral movement.
3. Use secure coding best practices to prevent the introduction of exploitable weaknesses.
4. Regularly scan the internal network for available services to identify new and potentially vulnerable services.
5. Minimize permissions and access for service accounts to limit the impact of exploitation.
6. Update software regularly by employing patch management to prevent exploitation of known vulnerabilities.

References

- * MITRE ATT&CK technique T1190: Exploit Public-Facing Application
- * MITRE ATT&CK technique T1210: Exploitation of Remote Services
- * Cisco IOS HTTP Server Vulnerability report (CVE-2005-3921)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the application of MITRE ATT&CK mitigations for public-facing application exploitation to IoT web interfaces. The provided evidence suggests that the mitigations can be adapted to IoT web interfaces to prevent exploitation. The report outlines the threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

IoT web interfaces are vulnerable to exploitation due to their public-facing nature. Adversaries may attempt to exploit weaknesses in IoT web interfaces to gain unauthorized access to internal systems. The exploitation of remote services (T1210) and public-facing applications (T1190) are potential threats to IoT web interfaces.

Evidence Found

The provided evidence from MITRE documents highlights the importance of segmenting networks and systems, minimizing available services, and regularly scanning for available services to identify new and potentially vulnerable services. Additionally, the evidence emphasizes the need for application isolation, least privilege, and secure coding best practices to prevent exploitation.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are relevant to IoT web interfaces:

- * T1190: Exploit Public-Facing Application
- * T1210: Exploitation of Remote Services
- * M1013: Application Developer Guidance

These techniques can be applied to IoT web interfaces to prevent exploitation.

Related Vulnerabilities

The following vulnerabilities are related to IoT web interfaces:

- * SQL injection
- * Cross-site scripting (XSS)
- * Cross-site request forgery (CSRF)
- * Remote code execution (RCE)

These vulnerabilities can be mitigated through secure coding best practices, application isolation, and least privilege.

Recommended Mitigations

Based on the evidence and MITRE ATT&CK mapping, the following mitigations are recommended for IoT web interfaces:

1. Segment IoT web interfaces from the rest of the network using a DMZ or separate hosting infrastructure.
2. Minimize available services to only those that are necessary.
3. Regularly scan for available services to identify new and potentially vulnerable services.
4. Implement application isolation and least privilege for service accounts.
5. Use secure coding best practices, such as parameterized queries or prepared statements, to prevent SQL injection.
6. Use a Web Application Firewall (WAF) to limit exposure of applications.
7. Develop a robust cyber threat intelligence capability to determine what types and levels of threat may use software exploits and 0-days against IoT web interfaces.

References

- * MITRE ATT&CK technique T1190: Exploit Public-Facing Application
- * MITRE ATT&CK technique T1210: Exploitation of Remote Services
- * MITRE ATT&CK technique M1013: Application Developer Guidance
- * MITRE ATT&CK technique [Network Service Discovery](<https://attack.mitre.org/techniques/T1016>)
- * [Secure Coding Practices](<https://www.sans.org/security-awareness-training/secure-coding-practices>)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 2/24 — q040

Human eval sheet — q040

Category: multi_facet

Question

Build a defender checklist for IoT botnets using IoT-23 behaviour evidence and MITRE mitigations.

Gold notes (optional reference)

Actionable checklist grounded in retrieved docs.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report provides a defender checklist for IoT botnets based on the provided evidence from IoT-23 behaviour and MITRE ATT&CK mitigations. The checklist aims to help defenders identify and mitigate potential threats from IoT botnets.

Threat Analysis

The provided evidence describes two IoT botnets: Hide and Seek and Muhstik. Both botnets exhibit similar behaviours, including:

- * PartOfAHorizontalPortScan (scanning for open ports)
- * C&C (command-and-control activity)
- * Attack (denial-of-service or other malicious activity)

These behaviours are indicative of botnet activity, which can be used for various malicious purposes, including large-scale phishing or distributed denial-of-service (DDoS) attacks.

Evidence Found

The provided evidence includes:

- * Two IoT-23 scenarios: CTU-IoT-Malware-Capture-1-1 (Hide and Seek) and CTU-IoT-Malware-Capture-3-1 (Muhstik)
- * Two MITRE ATT&CK techniques: T1583.005 (Botnet) and T1584.005 (Botnet)
- * A vulnerability description: CVE-2021-1289 (plural Cisco Small Business RV Assumed to be immutable in the router Web Parameter external control vulnerability)

MITRE ATT&CK Mapping

The provided evidence can be mapped to the following MITRE ATT&CK techniques:

- * T1583.005 (Botnet): Hide and Seek and Muhstik botnets
- * T1584.005 (Botnet): Hide and Seek and Muhstik botnets
- * T1210 (Exploitation of Remote Services Mitigation): CVE-2021-1289 (plural Cisco Small Business RV Assumed to be immutable in the router Web Parameter external control vulnerability)

Related Vulnerabilities

The provided evidence includes one vulnerability description: CVE-2021-1289 (plural Cisco Small Business RV Assumed to be immutable in the router Web Parameter external control vulnerability). This vulnerability can be exploited by an unauthenticated, remote attacker to execute arbitrary code as the root user on an affected device.

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended:

1. Segment networks and systems appropriately to reduce access to critical systems and services to controlled methods.
2. Minimize available services to only those that are necessary.
3. Regularly scan the internal network for available services to identify new and potentially vulnerable services.
4. Minimize permissions and access for service accounts to limit impact of exploitation.
5. Update software regularly by employing patch management for internal enterprise endpoints and servers.
6. Develop a robust cyber threat intelligence capability to determine what types and levels of threat may use software exploits and 0-days against a network.
7. Implement a web application firewall (WAF) to protect against HTTP requests that are not properly validated.
8. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.

References

- * IoT-23 behaviour evidence: CTU-IoT-Malware-Capture-1-1 and CTU-IoT-Malware-Capture-3-1
- * MITRE ATT&CK techniques: T1583.005 (Botnet), T1584.005 (Botnet), and T1210 (Exploitation of Remote Services Mitigation)
- * Vulnerability description: CVE-2021-1289 (plural Cisco Small Business RV Assumed to be immutable in the router Web Parameter external control vulnerability)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report outlines a defender checklist for IoT botnets based on the provided evidence from IoT-23 behavior and MITRE ATT&CK mitigations. The checklist aims to help defenders identify and mitigate potential threats from IoT botnets, specifically focusing on the Hide and Seek, Muhstik, and Torii malware families.

Threat Analysis

The provided evidence indicates that IoT botnets are a significant threat, with observed network behaviors including scanning, command-and-control (C&C), and denial-of-service (DoS) activities. The Hide and Seek, Muhstik, and Torii malware families have been identified as contributing to these threats.

Evidence Found

The evidence collected from IoT-23 scenarios and MITRE ATT&CK techniques includes:

- * Hide and Seek malware infecting an IoT device, exhibiting scanning, C&C, and DoS behaviors.
- * Muhstik malware infecting an IoT device, exhibiting scanning, attack, and C&C behaviors.
- * Torii malware infecting an IoT device, exhibiting C&C behaviors.
- * A vulnerability in MikroTik RouterBoard v6.38.5, which can be exploited for a denial-of-service (DoS) attack.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques have been identified as relevant to IoT botnets:

- * T1583.005: Botnet (adversaries may buy, lease, or rent a network of compromised systems)
- * T1584.005: Botnet (adversaries may compromise numerous third-party systems to form a botnet)
- * T1210: Exploitation of Remote Services Mitigation (segment networks and systems appropriately to reduce access to critical systems and services)

Related Vulnerabilities

The following vulnerabilities have been identified as related to IoT botnets:

- * MikroTik RouterBoard v6.38.5 - Denial of Service (CVE-2017-2064)

Recommended Mitigations

Based on the evidence and MITRE ATT&CK techniques, the following mitigations are recommended:

1. Segment networks and systems to reduce access to critical systems and services.
2. Minimize available services to only those that are necessary.
3. Regularly scan the internal network for available services to identify new and potentially vulnerable services.
4. Update software regularly by employing patch management for internal enterprise endpoints and servers.
5. Develop a robust cyber threat intelligence capability to determine what types and levels of threat may use software exploits and 0-days against a system.
6. Implement a vulnerability management program to identify and remediate vulnerabilities in IoT devices.
7. Use a secure configuration for IoT devices, including disabling unnecessary services and protocols.
8. Implement a network traffic monitoring and analysis system to detect and respond to potential IoT botnet activity.

References

- * IoT-23: Hide and Seek — CTU-IoT-Malware-Capture-1-1
- * IoT-23: Muhstik — CTU-IoT-Malware-Capture-3-1
- * IoT-23: Torii — CTU-IoT-Malware-Capture-21-1
- * MITRE ATT&CK: Botnet (T1583.005)
- * MITRE ATT&CK: Botnet (T1584.005)
- * MITRE ATT&CK: Exploitation of Remote Services Mitigation (T1210)
- * Vulnerability Laboratory: MikroTik RouterBoard v6.38.5 - Denial of Service (CVE-2017-2064)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Defender Checklist for IoT Botnets using IoT-23 Behaviour Evidence and MITRE Mitigations

Executive Summary

This report provides a defender checklist for IoT botnets based on IoT-23 behaviour evidence and MITRE mitigations. The checklist aims to help defenders identify and mitigate potential IoT botnet threats. The report highlights key behaviours exhibited by IoT botnets, such as scanning, command-and-control, and denial-of-service activities, and provides recommendations for mitigating these threats.

Threat Analysis

IoT botnets pose a significant threat to IoT devices and networks. These botnets can be used for various malicious activities, including scanning, command-and-control, and denial-of-service attacks. The IoT-23 behaviour evidence highlights the following key threats:

- * Scanning: IoT botnets use scanning techniques to identify vulnerable devices and services.
- * Command-and-Control (C&C): IoT botnets use C&C channels to communicate with compromised devices and issue commands.
- * Denial-of-Service (DoS): IoT botnets can be used to launch DoS attacks, which can disrupt network services and cause significant damage.

Evidence Found

The provided evidence includes the following:

- * IoT-23 scenario CTU-IoT-Malware-Capture-1-1, which involves Hide and Seek malware infecting an IoT device and exhibiting scanning, C&C, and DoS activities.
- * IoT-23 scenario CTU-IoT-Malware-Capture-3-1, which involves Muhstik malware infecting an IoT device and exhibiting scanning, attack, and C&C activities.
- * MITRE ATT&CK techniques T1583.005 (Botnet) and T1584.005 (Botnet), which describe the use of botnets for malicious activities.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are relevant to IoT botnets:

- * T1210: Exploitation of Remote Services Mitigation (segment networks and systems to reduce access to critical systems and services)
- * T1583.005: Botnet (buy, lease, or rent a network of compromised systems)
- * T1584.005: Botnet (compromise numerous third-party systems to form a botnet)

Related Vulnerabilities

The following vulnerabilities are related to IoT botnets:

- * CVE-2020-1472: A vulnerability in the Linux kernel that allows for remote code execution.
- * CVE-2019-15126: A vulnerability in the OpenSSH server that allows for remote code execution.

Recommended Mitigations

To mitigate IoT botnet threats, defenders should:

1. Segment networks and systems to reduce access to critical systems and services.
2. Minimize available services to only those that are necessary.
3. Regularly scan the internal network for available services to identify new and potentially vulnerable services.
4. Minimize permissions and access for service accounts to limit impact of exploitation.

5. Update software regularly by employing patch management for internal enterprise endpoints and servers.
6. Develop a robust cyber threat intelligence capability to determine what types and levels of threat may use software exploits and 0-days against a network.

References

- * MITRE ATT&CK techniques T1210, T1583.005, and T1584.005
- * IoT-23 behaviour evidence (CTU-IoT-Malware-Capture-1-1 and CTU-IoT-Malware-Capture-3-1)
- * CVE-2020-1472 and CVE-2019-15126

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Professional Report: Defender Checklist for IoT Botnets

1. Executive Summary

This report provides a defender checklist for IoT botnets based on IoT-23 behavior evidence and MITRE mitigations. The checklist aims to help defenders identify potential threats, vulnerabilities, and mitigation strategies related to IoT botnets. While the report is based on general knowledge and reasoning, it is essential to note that the effectiveness of the proposed checklist in preventing IoT botnet attacks cannot be guaranteed without access to a knowledge base or external evidence.

2. Threat Analysis

IoT botnets are often used by threat actors for DDoS attacks, data theft, and other malicious activities. The malware class is likely to be a type of remote access Trojan (RAT) or a botnet malware that exploits vulnerabilities in IoT devices. Vulnerability classes may include weak passwords, outdated firmware, or unpatched vulnerabilities in IoT devices.

3. Evidence Found (Reasoning-Only)

Based on general knowledge and reasoning, the following evidence types are relevant to IoT botnets:

- Behavior evidence: Unusual network traffic patterns, devices communicating with unknown or suspicious IP addresses, devices sending or receiving large amounts of data, and devices exhibiting unusual behavior.
- Technique evidence: MITRE ATT&CK techniques such as T1210 (Exploit Public-Facing Application), T1190 (Exploit Remote Services), T1204 (User Execution), and T1212 (Exploit Driver Vulnerability).

- Vulnerability evidence: Common vulnerabilities exploited by IoT botnets, such as weak passwords, outdated firmware, or unpatched vulnerabilities in IoT devices.
- Mitigation evidence: Corresponding MITRE mitigations for the identified vulnerabilities and techniques, such as M1200 (Implement a Web Application Firewall), M1190 (Implement a Remote Access Control System), and M1212 (Implement a Driver Update System).

4. MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are related to IoT botnets:

- T1210 (Exploit Public-Facing Application): Guessing, as IoT devices often have public-facing applications that can be exploited.
- T1190 (Exploit Remote Services): Reasonable assumption, as IoT devices often have remote services that can be exploited.
- T1204 (User Execution): Possible, as IoT botnets often rely on user interaction to spread.
- T1212 (Exploit Driver Vulnerability): Possible, as IoT devices often rely on drivers that can be exploited.

5. Related Vulnerabilities

The following vulnerabilities may be related to IoT botnets:

- Weak passwords: A common vulnerability exploited by IoT botnets.
- Outdated firmware: A vulnerability that can be exploited by IoT botnets.
- Unpatched vulnerabilities: A vulnerability that can be exploited by IoT botnets.

6. Recommended Mitigations

To mitigate IoT botnets, the following recommendations are made:

- Implement a Web Application Firewall (WAF) to prevent exploitation of public-facing applications (M1200).
- Implement a Remote Access Control System to prevent exploitation of remote services (M1190).
- Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
- Implement a Network Intrusion Detection System (NIDS) to detect unusual network traffic patterns.
- Implement a Device Management System to monitor and control IoT devices.

7. References

This report is based on general knowledge and reasoning, and no specific knowledge base or external evidence was consulted. The following references are provided as general knowledge:

- MITRE ATT&CK: A framework for understanding and describing cyber adversary behavior.
- IoT-23: A behavior evidence framework for IoT devices.
- NIST Cybersecurity Framework: A framework for managing and reducing cybersecurity risk.

Disclaimer

This report is provided as a general guideline and is not intended to be a comprehensive or definitive guide to IoT botnet defense. The effectiveness of the proposed checklist in preventing IoT botnet attacks cannot be guaranteed without access to a knowledge base or external evidence.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 3/24 — q032

Human eval sheet — q032

Category: multi_facet

Question

Using IoT-23 and MITRE evidence, what mitigations help against Mirai-like DDoS botnets?

Gold notes (optional reference)

Behaviour evidence + mitigation docs; must not invent Mirai-specific CVEs.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

IoT-23 Mirai-like DDoS Botnet Mitigation Report

Executive Summary

This report provides a summary of the key findings and recommendations for mitigating Mirai-like DDoS botnet attacks on IoT-23 devices. Based on general knowledge and reasoning, we have identified potential attack sequences, related MITRE ATT&CK techniques, and related vulnerabilities. We also provide practical mitigations to help prevent or mitigate such attacks.

Threat Analysis

Mirai-like botnets are a type of malware designed to exploit vulnerabilities in IoT devices to launch large-scale DDoS attacks. These attacks are typically carried out by threat actors seeking to disrupt or extort organizations. The primary vulnerability class exploited by Mirai is likely related to authentication or access control weaknesses, such as default or weak passwords.

Evidence Found

No knowledge base evidence was retrieved for this report. Our findings are based on general knowledge and reasoning only.

MITRE ATT&CK Mapping

Based on the attack sequence described in the Stage-2 expansion, the following MITRE ATT&CK techniques might be relevant:

1. Reconnaissance: T1590 (Scanning for vulnerabilities) and T1591 (Scanning for network services)
2. Initial Access: T1210 (Exploit public-facing application) and T1211 (Exploit vulnerable service)

3. Persistence: T1212 (Use alternate authentication material)
4. Command and Control: T1213 (Use alternate C2 channel)
5. Defense Evasion: T1214 (Use secure communication channels)

Please note that these are educated guesses and may not be accurate without further evidence.

Related Vulnerabilities

Based on general knowledge of Mirai-like botnets, the following vulnerabilities might be relevant:

1. CVE-2016-10195: A vulnerability in the Linksys E7450 router that allows remote code execution.
2. CVE-2017-17215: A vulnerability in the D-Link DIR-645 router that allows remote code execution.
3. CVE-2017-6079: A vulnerability in the Netgear R6400 router that allows remote code execution.

Please note that these are just examples and may not be the specific vulnerabilities exploited by Mirai-like botnets.

Recommended Mitigations

To mitigate Mirai-like botnet attacks, consider the following practical measures:

1. Implement strong passwords: Use unique, complex passwords for all IoT devices.
2. Keep software up-to-date: Regularly update firmware and software on IoT devices.
3. Use network segmentation: Isolate IoT devices from the rest of the network.
4. Use intrusion detection systems: Monitor network traffic for suspicious activity.
5. Use a firewall: Block incoming traffic on unnecessary ports and protocols.
6. Use a network access control (NAC) system: Restrict access to IoT devices based on user identity and device type.

References

This report is based on general knowledge and reasoning only. The following references are provided as model knowledge or general references:

1. MITRE ATT&CK Framework
2. IoT-23 Security Guidelines
3. General knowledge of Mirai-like botnets and their attack sequences

Please note that this report is not a comprehensive or definitive guide to mitigating Mirai-like DDoS botnet attacks. Further research and evidence-based analysis are necessary to provide a more accurate and effective mitigation strategy.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the threat of Mirai-like DDoS botnets and provides mitigations to help prevent such attacks. Based on the provided evidence from IoT-23 and MITRE, we have identified the key behaviors of Mirai malware and the techniques used by adversaries to conduct network flooding attacks. We have also identified related vulnerabilities in IoT devices that can be exploited by Mirai malware.

Threat Analysis

Mirai malware is a type of IoT botnet malware that infects IoT devices and uses them to conduct DDoS attacks. The malware scans for vulnerable devices, infects them, and uses them to send a high-volume of network traffic to a target. This can cause a denial of service (DoS) and reduce the availability and functionality of the targeted system(s) and network.

Evidence Found

The evidence from IoT-23 and MITRE indicates that Mirai malware uses the following behaviors to conduct DDoS attacks:

- * Scanning for vulnerable devices
- * Infecting devices with malware
- * Using infected devices to send a high-volume of network traffic to a target
- * Using stateless protocols such as UDP or ICMP for flooding

MITRE ATT&CK Mapping

The MITRE ATT&CK technique T1498.001, Direct Network Flood, is used by Mirai malware to conduct DDoS attacks. This technique involves sending a high-volume of network traffic to a target to cause a denial of service.

Related Vulnerabilities

The following vulnerabilities in IoT devices can be exploited by Mirai malware:

- * MikroTik RouterBoard v6.38.5 - Denial of Service (CVE: unknown)
- * NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router (CVE: CVE-2020-27872)
- * NETGEAR R7800 In firmware OS Command injection vulnerability (CVE: CVE-2021-27252)

Recommended Mitigations

To prevent Mirai-like DDoS botnets, the following mitigations are recommended:

1. Implement network segmentation: Segment the network to prevent lateral movement of malware and reduce the attack surface.
2. Use firewalls and intrusion detection/prevention systems: Configure firewalls and intrusion detection/prevention systems to block suspicious traffic and prevent malware from communicating with its command and control (C2) server.
3. Use secure protocols: Use secure protocols such as HTTPS and SFTP instead of HTTP and FTP.
4. Keep software up-to-date: Keep software and firmware up-to-date to prevent exploitation of known vulnerabilities.
5. Use secure passwords and authentication: Use secure passwords and authentication mechanisms to prevent unauthorized access to devices.
6. Monitor network traffic: Monitor network traffic for suspicious activity and respond quickly to potential threats.
7. Implement a vulnerability management program: Implement a vulnerability management program to identify and remediate vulnerabilities in a timely manner.

References

- * IoT-23: Mirai — CTU-IoT-Malware-Capture-7-1
- * MITRE: Direct Network Flood (T1498.001)
- * VARIOt: MikroTik RouterBoard v6.38.5 - Denial of Service (CVE: unknown)
- * VARIOt: NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router (CVE: CVE-2020-27872)
- * VARIOt: NETGEAR R7800 In firmware OS Command injection vulnerability (CVE: CVE-2021-27252)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the threat of Mirai-like DDoS botnets and provides mitigations to help prevent such attacks. Based on the provided evidence from IoT-23 and MITRE, we have identified the key behaviors and techniques used by Mirai botnets. Our analysis reveals that Mirai botnets use direct network flooding to cause denial-of-service attacks. We have also identified related vulnerabilities in MikroTik RouterBoard devices.

Threat Analysis

Mirai botnets are a type of IoT malware that infects devices and uses them to conduct DDoS attacks. The malware scans for vulnerable devices, infects them, and then uses them to send a

high-volume of network traffic to a target. This can cause a denial-of-service attack, reducing the availability and functionality of the targeted system(s) and network.

Evidence Found

The provided evidence includes:

- * Document 1: IoT-23 scenario CTU-IoT-Malware-Capture-7-1, which describes Mirai malware infecting an IoT device and conducting DDoS attacks.
- * Document 3: MITRE ATT&CK technique T1498.001, which describes direct network flooding as a method used by adversaries to cause a denial of service.
- * Document 5: VARIOt vulnerability report, which describes a denial-of-service vulnerability in MikroTik RouterBoard v6.38.5.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are relevant to this analysis:

- * T1498.001: Direct Network Flood
- * T1048: Exfiltration Over Alternative Protocol Mitigation
- * T1210: Exploitation of Remote Services Mitigation

Related Vulnerabilities

The following vulnerabilities are related to this analysis:

- * Document 5: VARIOt vulnerability report, which describes a denial-of-service vulnerability in MikroTik RouterBoard v6.38.5.
- * Document 8: VARIOt vulnerability report, which describes a denial-of-service vulnerability in Mikrotik Router.

Recommended Mitigations

Based on the analysis, the following mitigations are recommended:

1. Implement network segmentation: Segment networks and systems to reduce access to critical systems and services to controlled methods.
2. Minimize available services: Minimize available services to only those that are necessary.
3. Regularly scan for available services: Regularly scan the internal network for available services to identify new and potentially vulnerable services.
4. Update software regularly: Update software regularly by employing patch management for internal enterprise endpoints and servers.
5. Enforce proxies and use dedicated servers: Enforce proxies and use dedicated servers for services such as DNS and only allow those systems to communicate over respective ports/protocols.

6. Block unnecessary ports and traffic: Follow best practices for network firewall configurations to allow only necessary ports and traffic to enter and exit the network.

References

- * Document 1: IoT-23 scenario CTU-IoT-Malware-Capture-7-1
- * Document 3: MITRE ATT&CK technique T1498.001
- * Document 5: VARIoT vulnerability report
- * Document 8: VARIoT vulnerability report

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the threat of Mirai-like DDoS botnets and provides mitigations to help prevent such attacks. Based on the provided evidence from IoT-23 and MITRE, we have identified the key behaviors of Mirai malware and the techniques used by adversaries to conduct network flooding attacks.

Threat Analysis

Mirai malware is a highly infectious IoT botnet that can cause significant damage by launching DDoS attacks. The malware scans for vulnerable IoT devices, infects them, and uses them to conduct command-and-control and denial-of-service activities. The provided evidence from IoT-23 (Document 1) describes the observed network behaviors of Mirai malware, including scanning, C&C-HeartBeat, and DDoS activities.

Evidence Found

The provided evidence includes:

1. IoT-23 scenario CTU-IoT-Malware-Capture-7-1, which describes Mirai malware infecting an IoT device and conducting DDoS attacks.
2. A Perl script (Document 2) that exploits a Denial of Service vulnerability in MikroTik RouterBoard 6.38.5.
3. MITRE ATT&CK technique T1498.001 (Document 3), which describes Direct Network Flood attacks.
4. MITRE ATT&CK technique T1048 (Document 4), which provides mitigation strategies for Exfiltration Over Alternative Protocol.
5. A vulnerability report (Document 5) on MikroTik RouterBoard v6.38.5, which describes a Denial of Service vulnerability.

MITRE ATT&CK Mapping

The provided evidence maps to the following MITRE ATT&CK techniques:

1. T1498.001 - Direct Network Flood
2. T1048 - Exfiltration Over Alternative Protocol

Related Vulnerabilities

The provided evidence is related to the following vulnerabilities:

1. MikroTik RouterBoard 6.38.5 - Denial of Service Exploit (Document 2)
2. MikroTik RouterBoard v6.38.5 - Denial of Service (Document 5)

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended to help prevent Mirai-like DDoS botnets:

1. Implement network segmentation and isolation to prevent lateral movement.
2. Use firewalls to block unnecessary ports and traffic.
3. Enforce proxies and use dedicated servers for services like DNS.
4. Monitor network traffic for suspicious activity.
5. Keep IoT devices and software up-to-date with the latest security patches.
6. Use intrusion detection and prevention systems to detect and prevent DDoS attacks.

References

1. IoT-23 scenario CTU-IoT-Malware-Capture-7-1
2. MikroTik RouterBoard 6.38.5 - Denial of Service Exploit (Document 2)
3. MITRE ATT&CK technique T1498.001 (Document 3)
4. MITRE ATT&CK technique T1048 (Document 4)
5. MikroTik RouterBoard v6.38.5 - Denial of Service (Document 5)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 4/24 — q038

Human eval sheet — q038

Category: multi_facet

Question

Provide an evidence-backed briefing on Muhstik: behaviour, related techniques, and mitigations.

Gold notes (optional reference)

Must use IoT23 Muhstik + MITRE; acknowledge missing CVE links if absent.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Evidence-Backed Briefing on Muhstik

1. Executive Summary

Muhstik is a type of IoT botnet malware that compromises IoT devices, such as routers and cameras, to create a network of compromised systems. This briefing provides an analysis of Muhstik's behavior, related techniques, and mitigations. Based on my knowledge and reasoning, I have identified plausible network behaviors and attack steps, related MITRE ATT&CK techniques, and practical mitigations to prevent or mitigate the impact of Muhstik.

2. Threat Analysis

Muhstik is a type of IoT botnet malware that is likely used by threat actors to compromise IoT devices and create a network of compromised systems. The primary goal of Muhstik is to use compromised devices to launch DDoS attacks and steal sensitive data.

3. Evidence Found (Reasoning-Only)

Based on my understanding of IoT botnets and the MITRE ATT&CK framework, I can propose the following plausible network behaviors and attack steps for Muhstik:

- Initial Infection: Muhstik spreads through exploitation of vulnerabilities in IoT devices, such as routers and cameras.
- Device Compromise: Once infected, devices are compromised and become part of the Muhstik botnet.
- C2 Communication: Compromised devices communicate with Muhstik's C2 servers to receive instructions and send stolen data.

- DDoS Attacks: Muhstik botnet devices can be used to launch DDoS attacks against targeted systems.

4. MITRE ATT&CK Mapping

Based on my knowledge of IoT botnets and the MITRE ATT&CK framework, I can propose the following related techniques for Muhstik:

- T1210 - Exploit Public-Facing Application: Muhstik exploits vulnerabilities in public-facing applications to gain access to IoT devices.
- T1190 - Exploit Use of Outdated or Unpatched Software: Muhstik exploits outdated or unpatched software on IoT devices to gain access.
- T1071 - Application Layer Protocol: Muhstik uses application layer protocols to communicate with C2 servers and compromised devices.
- T1490 - Resource Hijacking: Muhstik hijacks resources on compromised devices to launch DDoS attacks.

5. Related Vulnerabilities

Unfortunately, without access to a knowledge base or external evidence, I cannot verify the specific vulnerabilities exploited by Muhstik. However, I can propose some possible vulnerabilities that Muhstik may exploit:

- CVE-2020-1471: A vulnerability in the TP-Link TL-WR940N router that allows remote code execution.
- CVE-2019-11556: A vulnerability in the D-Link DIR-645 router that allows remote code execution.

6. Recommended Mitigations

To mitigate the impact of Muhstik, I recommend the following practical measures:

- Keep Software Up-to-Date: Ensure that IoT devices are running the latest software and firmware.
- Use Strong Passwords: Use strong, unique passwords for IoT devices and network devices.
- Implement Network Segmentation: Segment the network to prevent lateral movement and limit the impact of a compromise.
- Monitor Network Traffic: Monitor network traffic for suspicious activity and unusual patterns.
- Use Intrusion Detection and Prevention Systems: Implement IDS/IPS systems to detect and prevent malicious activity.

7. References

This briefing is based on my knowledge and reasoning, and I have not retrieved any evidence from a knowledge base. The references provided are general references and model knowledge:

- MITRE ATT&CK Framework: <<https://attack.mitre.org/>>
- CVE Database: <<https://cve.mitre.org/>>
- IoT Security Best Practices: <<https://www.iotsecurityfoundation.org/>>

Please note that this briefing is based on my reasoning and analysis, and I have not verified the specific vulnerabilities exploited by Muhstik or the effectiveness of various mitigations.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides an evidence-backed briefing on Muhstik, a malware family that infects IoT devices. The analysis is based on the provided evidence, which includes network behaviors, related techniques, and mitigations. The report highlights the threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

Muhstik is a malware family that infects IoT devices, exhibiting behaviors such as scanning, command-and-control, and denial-of-service activity. The observed network behaviors include PartOfAHorizontalPortScan, Attack, and C&C flows. The malware primarily uses TCP traffic, indicating a potential vulnerability in the device's network configuration.

Evidence Found

Document 1: CTU-IoT-Malware-Capture-3-1 provides evidence of Muhstik malware infecting an IoT device, with observed network behaviors including PartOfAHorizontalPortScan, Attack, and C&C flows.

MITRE ATT&CK Mapping

Based on the observed behaviors, the following MITRE ATT&CK techniques can be mapped:

- * T1046: Network Service Scanning (PartOfAHorizontalPortScan)
- * T1213: Data from Information Repositories (C&C)
- * T1496: Resource Hijacking (denial-of-service activity)

Related Vulnerabilities

While the provided evidence does not explicitly mention specific vulnerabilities, the following related vulnerabilities can be inferred:

- * MikroTik RouterBoard v6.38.5 - Denial of Service (Document 4)
- * Trend Micro Maximum Security 2019 - Privilege Escalation - Windows local Exploit (Document 6)
- * Trend Micro DirectPass - Bypass & Persistent Vulnerability (Document 7)

Recommended Mitigations

Based on the MITRE ATT&CK techniques and related vulnerabilities, the following recommended mitigations can be applied:

- * Implement secure coding practices, such as parameterized queries or prepared statements, to prevent SQL injection (Document 2)
- * Develop and publish policies that define acceptable information to be stored, and enforce access control mechanisms, including authentication and authorization (Document 3)
- * Identify potentially malicious software and audit and/or block it using whitelisting tools, like AppLocker, or Software Restriction Policies (Document 5)
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities (Document 4)

References

- * Document 1: CTU-IoT-Malware-Capture-3-1
- * Document 2: MITRE ATT&CK technique M1013
- * Document 3: MITRE ATT&CK technique T1213
- * Document 4: MikroTik RouterBoard v6.38.5 - Denial of Service
- * Document 5: MITRE ATT&CK technique T1496
- * Document 6: Trend Micro Maximum Security 2019 - Privilege Escalation - Windows local Exploit
- * Document 7: Trend Micro DirectPass - Bypass & Persistent Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report provides an evidence-backed briefing on Muhstik, a malware family that infects IoT devices. The analysis focuses on Muhstik's behavior, related techniques, and mitigations based on the provided evidence. The report highlights the importance of implementing secure coding practices, access control mechanisms, and whitelisting tools to prevent Muhstik's malicious activities.

Threat Analysis

Muhstik is a malware family that infects IoT devices, exhibiting behaviors such as scanning, command-and-control (C&C), and denial-of-service (DoS) activities. The malware uses TCP traffic to communicate with its C&C server, making it challenging to detect and mitigate. The observed network behaviors include PartOfAHorizontalPortScan, Attack, and C&C, indicating that Muhstik is designed to scan for vulnerabilities, launch attacks, and maintain control over infected devices.

Evidence Found

Document 1: CTU-IoT-Malware-Capture-3-1 provides evidence of Muhstik's behavior, including scanning, C&C, and DoS activities. The capture contains 156103 flows, primarily TCP traffic, with the most common service being -. This evidence describes Muhstik's botnet/malware behavior.

MITRE ATT&CK Mapping

Based on the provided evidence, Muhstik's behavior can be mapped to the following MITRE ATT&CK techniques:

- * T1213: Data from Information Repositories Mitigation (Muhstik's C&C activity)
- * T1496: Resource Hijacking Mitigation (Muhstik's scanning and DoS activities)

Related Vulnerabilities

Document 4: MikroTik RouterBoard v6.38.5 - Denial of Service provides evidence of a vulnerability in MikroTik RouterBoard v6.38.5, which can be exploited by Muhstik to launch DoS attacks. This vulnerability is classified as a Denial of Service (DoS) vulnerability with a CVSS score of 3.8.

Recommended Mitigations

To prevent Muhstik's malicious activities, the following mitigations are recommended:

1. Implement secure coding practices, such as parameterized queries or prepared statements, to prevent SQL injection attacks.
2. Develop and publish policies that define acceptable information to be stored, and implement access control mechanisms that include both authentication and authorization.
3. Enforce the principle of least-privilege and periodically review accounts for privilege escalation.
4. Use whitelisting tools, such as AppLocker or Software Restriction Policies, to identify and block potentially malicious software.

References

- * Document 1: CTU-IoT-Malware-Capture-3-1
- * Document 2: MITRE ATT&CK technique M1013
- * Document 3: MITRE ATT&CK technique T1213

* Document 4: VARIOt MikroTik RouterBoard v6.38.5 - Denial of Service

* Document 5: MITRE ATT&CK technique T1496

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer D

Executive Summary

This report provides an evidence-backed briefing on Muhstik, a malware family that infects IoT devices. The analysis focuses on its behavior, related techniques, and mitigations. The report is based on the provided evidence, including network behaviors observed in a CTU-IoT-Malware-Capture-3-1 scenario, and relevant MITRE ATT&CK techniques.

Threat Analysis

Muhstik is a malware family that exhibits scanning, command-and-control, and denial-of-service behavior when present in IoT devices. The observed network behaviors include:

* PartOfAHorizontalPortScan (145597 flows)

* Attack (5962 flows)

* C&C (8 flows)

These behaviors indicate that Muhstik is designed to scan for vulnerabilities, launch attacks, and establish command-and-control channels.

Evidence Found

The provided evidence includes:

* Document 1: CTU-IoT-Malware-Capture-3-1, which describes the Muhstik malware behavior, including scanning, command-and-control, and denial-of-service activity.

* No other evidence directly related to Muhstik is provided.

MITRE ATT&CK Mapping

Based on the observed behaviors, the following MITRE ATT&CK techniques can be mapped to Muhstik:

* T1046: Network Service Scanning (PartOfAHorizontalPortScan)

* T1213: Data from Information Repositories (C&C)

* T1496: Resource Hijacking (Attack)

Related Vulnerabilities

The provided evidence does not directly link Muhstik to specific vulnerabilities. However, the following vulnerabilities may be related to the observed behaviors:

- * Document 5: NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router (CVE-2020-27872)
- * Document 6: MikroTik RouterBoard v6.38.5 - Denial of Service

These vulnerabilities may be exploited by Muhstik to establish command-and-control channels or launch denial-of-service attacks.

Recommended Mitigations

Based on the observed behaviors and related vulnerabilities, the following mitigations are recommended:

- * Implement network segmentation and access control to prevent lateral movement.
- * Use whitelisting tools, such as AppLocker or Software Restriction Policies, to block potentially malicious software.
- * Enforce the principle of least-privilege and periodic privilege review of accounts.
- * Develop and publish policies that define acceptable information to be stored and implement access control mechanisms.
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.

References

- * Document 1: CTU-IoT-Malware-Capture-3-1
- * Document 2: MITRE ATT&CK technique M1013
- * Document 3: MITRE ATT&CK technique T1213
- * Document 4: MITRE ATT&CK technique T1496
- * Document 5: NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router (CVE-2020-27872)
- * Document 6: MikroTik RouterBoard v6.38.5 - Denial of Service

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 5/24 — q039

Human eval sheet — q039

Category: multi_facet

Question

How can unauthenticated router web exploits enable botnet recruitment, based on VARIOt and MITRE evidence?

Gold notes (optional reference)

Exploit docs + public-facing/remote service techniques + mitigations.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report provides an analysis of how unauthenticated router web exploits can enable botnet recruitment, based on VARIOt and MITRE evidence. Our analysis highlights the potential for threat actors to exploit web application vulnerabilities in router web interfaces to gain unauthorized access and recruit devices into a botnet. We provide a plausible attack scenario, related MITRE ATT&CK techniques, and related vulnerabilities. Finally, we recommend practical mitigations to prevent or mitigate these types of attacks.

Threat Analysis

Unauthenticated router web exploits pose a significant threat to network security, as they can enable threat actors to gain unauthorized access to a router's web interface and recruit devices into a botnet. This can lead to a range of malicious activities, including DDoS attacks, cryptocurrency mining, and other types of cybercrime.

Evidence Found

Based on our analysis, we have identified the following evidence:

- Unauthenticated router web exploits: These exploits involve gaining unauthorized access to a router's web interface using web application vulnerabilities such as SQL injection or cross-site scripting (XSS).
- Botnet recruitment: Once an attacker has gained unauthorized access to a router's web interface, they can use the compromised device to scan for other vulnerable devices on the network and recruit them into a botnet.
- Malware or toolkits: Threat actors may use custom-built malware or existing toolkits like Mirai or Gafgyt to facilitate botnet recruitment and malicious activities.

Note: We have not retrieved any knowledge base evidence to support our analysis. Our findings are based on our reasoning and general knowledge of IoT cybersecurity threats.

MITRE ATT&CK Mapping

Based on our analysis, the following MITRE ATT&CK techniques might be related to this attack scenario:

- T1059: Command and Control (C2): The attacker uses the compromised router to establish a C2 channel with the botnet.
- T1071: Application Layer Protocol: Web Protocols: The attacker uses web application vulnerabilities to gain unauthorized access to the router's web interface.
- T1210: Exploit Public-Facing Application: The attacker exploits a public-facing application (in this case, the router's web interface) to gain unauthorized access.

Related Vulnerabilities

Based on our analysis, the following vulnerabilities might be related to this attack scenario:

- CVE-2018-10561: A vulnerability in the web interface of certain routers that allows an attacker to gain unauthorized access.
- CVE-2019-11510: A vulnerability in the web interface of certain routers that allows an attacker to execute arbitrary code.

Recommended Mitigations

To prevent or mitigate these types of attacks, we recommend the following:

- Ensure strong passwords and authentication: Ensure that all routers have strong passwords and are configured to require authentication for access to the web interface.
- Keep firmware up-to-date: Keep the router's firmware up-to-date with the latest security patches.
- Implement a web application firewall (WAF): Use a WAF to protect the router's web interface from web application vulnerabilities.
- Implement network segmentation: Implement a network segmentation strategy to isolate the router from the rest of the network.
- Monitor for suspicious activity: Monitor the network for suspicious activity and implement a detection and response strategy to quickly identify and contain any potential threats.

References

This report is based on our reasoning and general knowledge of IoT cybersecurity threats. We have not retrieved any knowledge base evidence to support our analysis. The following references are provided as general information only:

- VARIOt: A framework for analyzing and mitigating IoT threats.
- MITRE ATT&CK: A framework for understanding and mitigating cyber threats.
- CVE-2018-10561: A vulnerability in the web interface of certain routers.
- CVE-2019-11510: A vulnerability in the web interface of certain routers.
- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the potential for unauthenticated router web exploits to enable botnet recruitment, based on evidence from VARIOt and MITRE. The analysis reveals that unauthenticated router web exploits can be used to modify DNS settings, allowing cybercriminals to redirect users to malicious sites and perform malicious activities. This can lead to the recruitment of devices into botnets, which can be used for various malicious purposes, including bandwidth hijacking and denial-of-service attacks.

Threat Analysis

The threat analysis reveals that unauthenticated router web exploits can be used to gain unauthorized access to router web interfaces, allowing cybercriminals to modify DNS settings and redirect users to malicious sites. This can lead to the recruitment of devices into botnets, which can be used for various malicious purposes, including bandwidth hijacking and denial-of-service attacks.

Evidence Found

The evidence found includes:

- * Unauthenticated DNS change exploits for various router models, including DLink DSL-2640B, DLink DSL-2640U, and UTstarcom WA3002G4.
- * MITRE ATT&CK techniques T1190 (Exploit Public-Facing Application) and T1496.002 (Bandwidth Hijacking), which describe the exploitation of public-facing applications and bandwidth hijacking, respectively.
- * Malware families Kenjiro and Hide and Seek, which are known to be used in IoT botnets.

MITRE ATT&CK Mapping

The MITRE ATT&CK techniques T1190 (Exploit Public-Facing Application) and T1496.002 (Bandwidth Hijacking) are relevant to this analysis. The exploit of unauthenticated router web interfaces can be mapped to T1190, while the use of botnets for bandwidth hijacking can be mapped to T1496.002.

Related Vulnerabilities

The unauthenticated DNS change exploits for various router models are related to the following vulnerabilities:

- * CVE-2017-13785: A vulnerability in the web interface of DLink DSL-2640B and DLink DSL-2640U routers allows an attacker to modify DNS settings without authentication.
- * CVE-2017-13786: A vulnerability in the web interface of UTstarcom WA3002G4 routers allows an attacker to modify DNS settings without authentication.

Recommended Mitigations

To mitigate the risks associated with unauthenticated router web exploits, the following recommendations are made:

- * Implement strong authentication and authorization mechanisms for router web interfaces.
- * Regularly update and patch router firmware to prevent exploitation of known vulnerabilities.
- * Use secure DNS settings and avoid using public DNS servers.
- * Implement intrusion detection and prevention systems to detect and prevent malicious activity.

References

- * VARIOt: DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
- * VARIOt: DLink DSL-2640U - Unauthenticated DNS Change Exploit
- * VARIOt: UTstarcom WA3002G4 - Unauthenticated DNS Change Exploit
- * MITRE: Exploit Public-Facing Application (T1190)
- * MITRE: Bandwidth Hijacking (T1496.002)
- * IoT23: Kenjiro — CTU-IoT-Malware-Capture-17-1
- * IoT23: Hide and Seek — CTU-IoT-Malware-Capture-1-1

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the potential for unauthenticated router web exploits to enable botnet recruitment, based on evidence from VARIOt and MITRE. The analysis reveals that unauthenticated router web exploits can be used to modify DNS settings, allowing cybercriminals to redirect users to malicious sites and perform malicious activities. This can lead to botnet recruitment and bandwidth hijacking.

Threat Analysis

The threat analysis reveals that unauthenticated router web exploits can be used to:

1. Modify DNS settings, allowing cybercriminals to redirect users to malicious sites.
2. Perform malicious activities, such as bandwidth hijacking and botnet recruitment.
3. Exploit software vulnerabilities in an attempt to collect credentials.

Evidence Found

The evidence found includes:

1. Unauthenticated remote DNS change exploits in D-Link DSL-2640B and DSL-2640U routers.
2. Exploit public-facing application techniques, which can be used to access a network.
3. Bandwidth hijacking techniques, which can be used to complete resource-intensive tasks.
4. Exploitation for credential access techniques, which can be used to collect credentials.

MITRE ATT&CK Mapping

The MITRE ATT&CK techniques that are relevant to this analysis are:

1. Exploit Public-Facing Application (T1190)
2. Bandwidth Hijacking (T1496.002)
3. Exploitation for Credential Access (T1212)

Related Vulnerabilities

The related vulnerabilities that are relevant to this analysis are:

1. CVE-2013-5946: plural D-Link Vulnerability to execute arbitrary commands in firmware of router products.

Recommended Mitigations

To mitigate the risks associated with unauthenticated router web exploits, the following recommendations are made:

1. Implement authentication and authorization mechanisms for router web interfaces.
2. Regularly update and patch router firmware to prevent exploitation of known vulnerabilities.
3. Use secure DNS settings and avoid using foreign DNS servers.
4. Implement network segmentation and isolation to prevent lateral movement.
5. Monitor network traffic for suspicious activity and implement intrusion detection and prevention systems.

References

1. VARIOt: DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
2. VARIOt: DLink DSL-2640U - Unauthenticated DNS Change Exploit
3. MITRE: Exploit Public-Facing Application (T1190)

4. MITRE: Bandwidth Hijacking (T1496.002)
5. MITRE: Exploitation for Credential Access (T1212)
6. CVE-2013-5946: plural D-Link Vulnerability to execute arbitrary commands in firmware of router products.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the potential for unauthenticated router web exploits to enable botnet recruitment based on evidence from VARIOt and MITRE. The findings suggest that unauthenticated router web exploits can be used to modify DNS settings, allowing cybercriminals to redirect users to malicious sites and potentially recruit them into a botnet.

Threat Analysis

The threat analysis reveals that unauthenticated router web exploits can be used to modify DNS settings, which can lead to malicious activities such as:

- * Redirecting users to malicious sites
- * Performing resource-intensive tasks to impact system and/or hosted service availability
- * Facilitating botnet recruitment

Evidence Found

The evidence found includes:

- * Two unauthenticated router web exploits for D-Link DSL-2640B and DSL-2640U routers, which can modify DNS settings without authentication.
- * MITRE ATT&CK techniques T1190 (Exploit Public-Facing Application) and T1496.002 (Bandwidth Hijacking), which describe the exploitation of public-facing applications and bandwidth hijacking, respectively.

MITRE ATT&CK Mapping

The MITRE ATT&CK techniques can be mapped to the evidence found as follows:

- * T1190 (Exploit Public-Facing Application): The unauthenticated router web exploits for D-Link DSL-2640B and DSL-2640U routers can be used to exploit public-facing applications.
- * T1496.002 (Bandwidth Hijacking): The modified DNS settings can be used to hijack bandwidth and facilitate botnet recruitment.

Related Vulnerabilities

The related vulnerabilities include:

- * MS14-068, which targets Kerberos and can be used to forge Kerberos tickets using domain user credentials.

Recommended Mitigations

To mitigate the risks associated with unauthenticated router web exploits, the following recommendations are made:

- * Implement authentication and authorization mechanisms for router web interfaces.
- * Regularly update and patch router firmware to prevent exploitation of known vulnerabilities.
- * Use secure DNS settings and avoid modifying DNS settings without proper authorization.
- * Implement network segmentation and isolation to prevent lateral movement and botnet recruitment.

References

- * VARIOt: DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
- * VARIOt: DLink DSL-2640U - Unauthenticated DNS Change Exploit
- * MITRE ATT&CK: Exploit Public-Facing Application (T1190)
- * MITRE ATT&CK: Bandwidth Hijacking (T1496.002)
- * MITRE ATT&CK: Exploitation for Credential Access (T1212)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 6/24 — q037

Human eval sheet — q037

Category: multi_facet

Question

Given Torii C&C behaviour, which ATT&CK command-and-control concepts are relevant and how to mitigate?

Gold notes (optional reference)

Torii behaviour + C2 technique/mitigation.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Senior IoT Cybersecurity Expert Report

Executive Summary

This report provides an analysis of Torii's command-and-control (C2) behavior and its relevance to ATT&CK command-and-control concepts. Based on the available information, we have identified plausible network behaviors, related MITRE ATT&CK techniques, and practical mitigations to prevent or detect Torii's C2 behavior.

Threat Analysis

Torii is a known malware, specifically a type of remote access Trojan (RAT). Given its classification, it's likely that Torii is used by threat actors for espionage, data theft, or other malicious purposes. The threat actor's goals and motivations are unclear without further information.

Evidence Found

No retrieved KB evidence is available for this analysis. The following reasoning is based on general knowledge and best practices.

* Initial compromise: Torii may use a vulnerability or exploit to gain unauthorized access to the system, potentially through a phishing email, drive-by download, or other social engineering tactic.

* C2 communication: Torii may establish a communication channel with its C2 server using protocols such as HTTP, HTTPS, or DNS tunneling. This could involve encrypted or unencrypted communication, depending on the specific implementation.

- * Data exfiltration: Torii may transmit sensitive data, such as login credentials, financial information, or other sensitive files, to its C2 server.

MITRE ATT&CK Mapping

Based on the plausible network behaviors, the following related MITRE ATT&CK techniques are identified:

- * T1040: Network Sniffing (guessing, as Torii may intercept network traffic to exfiltrate data)
- * T1071: Application Layer Protocol: Web Protocols (guessing, as Torii may use HTTP or HTTPS to communicate with its C2 server)
- * T1219: Remote Services: SMB/Windows Admin Shares (guessing, as Torii may use SMB or Windows Admin Shares to gain unauthorized access to the system)
- * T1562: Impair Defenses: Disable or Modify Tools (guessing, as Torii may disable or modify system tools to evade detection)

Related Vulnerabilities

Unfortunately, I am not reasonably sure about the specific vulnerabilities or CVEs used by Torii. Without further information, I would not like to speculate or provide incorrect information.

Recommended Mitigations

To mitigate Torii's C2 behavior, the following practical steps are recommended:

- * Implement a robust security information and event management (SIEM) system to detect and alert on suspicious network traffic patterns.
- * Use a web application firewall (WAF) to block suspicious HTTP or HTTPS traffic.
- * Implement a network segmentation strategy to isolate sensitive systems and data from the rest of the network.
- * Regularly update and patch systems to prevent exploitation of known vulnerabilities.
- * Use a reputable antivirus solution to detect and remove malware, including Torii.

References

- * Model knowledge and general references only:
 - + MITRE ATT&CK Framework
 - + NIST Cybersecurity Framework
 - + SANS Institute
 - + OWASP

Please note that this report is based on general knowledge and best practices. Further research and analysis would be necessary to provide more tailored recommendations.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the Torii C&C behavior and identifies relevant ATT&CK command-and-control concepts. Based on the provided evidence, we have identified potential vulnerabilities and mitigation strategies to prevent exploitation.

Threat Analysis

The Torii C&C behavior is likely to employ multi-stage channels to obfuscate the command and control channel, making detection more difficult. This behavior is consistent with the ATT&CK technique T1104, Multi-Stage Channels. Additionally, the use of scripting interpreters on network devices (T1059.008) and remote command execution vulnerabilities (e.g., Cisco WAG120N Command Execution) may be exploited to execute malicious payloads.

Evidence Found

- * Document 1: Network Device CLI (T1059.008) - Adversaries may abuse scripting or built-in CLI on network devices to execute malicious payloads.
- * Document 2: Multi-Stage Channels Mitigation (T1104) - Command and control infrastructure used in a multi-stage channel may be blocked if known ahead of time.
- * Document 3: Multi-Stage Channels (T1104) - Adversaries may create multiple stages for command and control that are employed under different conditions or for certain functions.
- * Document 4: Eaton ELCSOFT Device Comment Range Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability - A vulnerability that allows remote attackers to execute arbitrary code on vulnerable installations of Eaton ELCSOFT.
- * Document 5: Cisco WAG120N Command Execution - A remote command execution vulnerability in setup.cgi.
- * Document 6: Open Design Alliance Drawings SDK Vulnerability - A memory allocation with excessive size vulnerability that allows remote attackers to execute arbitrary code on affected installations of Siemens JT2Go.

MITRE ATT&CK Mapping

- * T1059.008: Network Device CLI - Adversaries may abuse scripting or built-in CLI on network devices to execute malicious payloads.
- * T1104: Multi-Stage Channels - Adversaries may create multiple stages for command and control that are employed under different conditions or for certain functions.

Related Vulnerabilities

- * Eaton ELCSOft Device Comment Range Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability (Document 4)
- * Cisco WAG120N Command Execution (Document 5)
- * Open Design Alliance Drawings SDK Vulnerability (Document 6)

Recommended Mitigations

1. Implement multi-stage channel mitigation strategies (Document 2) to block command and control infrastructure used in a multi-stage channel.
2. Disable or restrict scripting interpreters on network devices (Document 1) to prevent exploitation of T1059.008.
3. Patch or update vulnerable devices to prevent exploitation of remote command execution vulnerabilities (e.g., Cisco WAG120N Command Execution).
4. Implement secure coding practices to prevent memory allocation with excessive size vulnerabilities (e.g., Open Design Alliance Drawings SDK Vulnerability).

References

- * Document 1: MITRE ATT&CK technique T1059.008
- * Document 2: MITRE ATT&CK technique T1104
- * Document 3: MITRE ATT&CK technique T1104
- * Document 4: VARIOt - Eaton ELCSOft Device Comment Range Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * Document 5: VARIOt - Cisco WAG120N Command Execution
- * Document 6: VARIOt - Open Design Alliance Drawings SDK Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the Torii C&C behavior and identifies relevant ATT&CK command-and-control concepts. Based on the provided evidence, we have identified the following relevant concepts and mitigation strategies.

Threat Analysis

The Torii malware family has been observed to exhibit command-and-control (C&C) behavior, including scanning, command-and-control, or denial-of-service activity. The malware uses UDP traffic primarily and has been observed to communicate with a C&C server.

Evidence Found

The provided evidence includes:

1. Document 2: IoT-23 scenario CTU-IoT-Malware-Capture-21-1, which involves Torii malware infecting an IoT device and exhibits C&C behavior.
2. Document 6: MITRE ATT&CK technique T1104, which describes multi-stage channels used in C&C infrastructure.
3. Document 5: MITRE ATT&CK technique T1059.008, which describes network device CLI abuse for malicious command execution.

MITRE ATT&CK Mapping

Based on the evidence, the following ATT&CK techniques are relevant:

1. T1104: Multi-Stage Channels
2. T1059.008: Network Device CLI

Related Vulnerabilities

The following vulnerabilities are related to the identified ATT&CK techniques:

1. Document 3: Cisco WAG120N Command Execution
2. Document 4: ASUS TM-AC1900 - Arbitrary Command Execution (Metasploit)
3. Document 7: Netgear R7000 Command Injection

Recommended Mitigations

To mitigate the identified threats, the following recommendations are made:

1. Implement multi-stage channel mitigation strategies to block known C&C infrastructure.
2. Restrict access to network device CLI and scripting interpreters to prevent abuse.
3. Patch vulnerabilities in network devices, such as Cisco WAG120N, ASUS TM-AC1900, and Netgear R7000.
4. Implement network traffic monitoring and analysis to detect and prevent C&C communication.

References

1. Document 1: MITRE Multi-Stage Channels Mitigation
2. Document 2: IoT23 Torii — CTU-IoT-Malware-Capture-21-1
3. Document 5: MITRE Network Device CLI
4. Document 6: MITRE Multi-Stage Channels
5. Document 7: VARIOt Netgear R7000 Command Injection

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the Torii C&C behavior and identifies relevant ATT&CK command-and-control concepts. Based on the provided evidence, we have identified two relevant concepts: Multi-Stage Channels Mitigation and Network Device CLI. We will map these concepts to the MITRE ATT&CK framework and provide recommended mitigations.

Threat Analysis

The Torii C&C behavior exhibits characteristics of a multi-stage channel, where the first stage may collect basic host information, update tools, and upload additional files. The second stage may redirect the host to a more fully featured RAT. This behavior is consistent with the MITRE ATT&CK technique T1104, Multi-Stage Channels.

Evidence Found

The provided evidence includes:

1. Document 1: MITRE ATT&CK technique T1104, Multi-Stage Channels Mitigation, which discusses the use of multi-stage channels in C2 infrastructure and provides mitigation strategies.
2. Document 4: MITRE ATT&CK technique T1059.008, Network Device CLI, which describes the use of scripting or built-in command line interpreters on network devices to execute malicious commands and payloads.
3. Document 5: MITRE ATT&CK technique T1104, Multi-Stage Channels, which provides additional information on the use of multi-stage channels in C2 infrastructure.

MITRE ATT&CK Mapping

Based on the evidence, we have mapped the Torii C&C behavior to the following MITRE ATT&CK techniques:

1. T1104: Multi-Stage Channels
2. T1059.008: Network Device CLI

Related Vulnerabilities

The provided evidence mentions the following vulnerabilities:

1. Cisco WAG120N Command Execution (Document 2)
2. ASUS TM-AC1900 - Arbitrary Command Execution (Metasploit) (Document 3)

These vulnerabilities may be related to the Torii C&C behavior, but further analysis is required to confirm the connection.

Recommended Mitigations

Based on the evidence, we recommend the following mitigations:

1. Implement multi-stage channel mitigation strategies, such as blocking known C2 traffic signatures or using intrusion detection systems to identify and block multi-stage channels.
2. Implement network device CLI security measures, such as restricting access to CLI and scripting interpreters, using secure authentication and authorization mechanisms, and monitoring for suspicious CLI activity.
3. Patch and update network devices and firmware to prevent exploitation of known vulnerabilities, such as the Cisco WAG120N Command Execution and ASUS TM-AC1900 - Arbitrary Command Execution vulnerabilities.

References

1. Document 1: MITRE ATT&CK technique T1104, Multi-Stage Channels Mitigation
2. Document 4: MITRE ATT&CK technique T1059.008, Network Device CLI
3. Document 5: MITRE ATT&CK technique T1104, Multi-Stage Channels
4. Document 2: VARIOt, Cisco WAG120N Command Execution
5. Document 3: VARIOt, ASUS TM-AC1900 - Arbitrary Command Execution (Metasploit) - Hardware webapps Exploit

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 7/24 — q031

Human eval sheet — q031

Category: multi_facet

Question

How does Mirai behave on the network, and what MITRE techniques map to that behaviour?

Gold notes (optional reference)

IoT-23 Mirai behaviours + ATT&CK mapping (scan/C2/DoS).

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the behavior of the Mirai malware on a network and maps its techniques to the MITRE ATT&CK framework. The analysis is based on evidence from the CTU-IoT-Malware-Capture dataset, which includes scenarios involving Mirai, Kenjiro, Hajime, and other malware families. The report identifies the observed network behaviors of Mirai, including scanning, command-and-control, and denial-of-service activity, and maps these behaviors to relevant MITRE ATT&CK techniques.

Threat Analysis

Mirai is a malware family that infects IoT devices and uses them to conduct DDoS attacks, scanning, and command-and-control activities. The malware is designed to spread itself to other devices on the network, creating a botnet that can be used for malicious purposes.

Evidence Found

The evidence from the CTU-IoT-Malware-Capture dataset shows that Mirai exhibits the following network behaviors:

- * Okiru (11333397 flows)
- * DDoS (39584 flows)
- * C&C-HeartBeat (5778 flows)

These behaviors are consistent with the characteristics of Mirai malware, which is designed to conduct DDoS attacks, scanning, and command-and-control activities.

MITRE ATT&CK Mapping

The observed network behaviors of Mirai can be mapped to the following MITRE ATT&CK techniques:

- * T1498: Network Denial of Service - Mirai's DDoS activity can be mapped to this technique.
- * T1048: Exfiltration Over Alternative Protocol - Mirai's command-and-control activity can be mapped to this technique.
- * T1496.002: Bandwidth Hijacking - Mirai's use of IoT devices to conduct DDoS attacks can be mapped to this technique.

Related Vulnerabilities

The evidence from the CTU-IoT-Malware-Capture dataset also shows that Mirai can exploit vulnerabilities in IoT devices to infect them. One example of a related vulnerability is the MikroTik RouterBoard v6.38.5 Denial of Service vulnerability (CVE-2017-6358), which can be exploited by Mirai to infect IoT devices.

Recommended Mitigations

To mitigate the risks associated with Mirai malware, the following recommendations are made:

- * Implement network segmentation to isolate IoT devices from the rest of the network.
- * Use intrusion detection and prevention systems to detect and block suspicious traffic.
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
- * Implement a robust incident response plan to quickly respond to and contain Mirai-related incidents.

References

- * CTU-IoT-Malware-Capture dataset
- * MITRE ATT&CK framework
- * CVE-2017-6358: MikroTik RouterBoard v6.38.5 Denial of Service vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

IoT Malware Threat Analysis Report: Mirai

1. Executive Summary

This report provides an analysis of the Mirai malware, a well-known IoT threat that primarily targets devices with default or weak passwords. Mirai is often used in DDoS attacks and can also be used for other malicious purposes. This report outlines Mirai's behavior on a network, related MITRE ATT&CK techniques, and recommended mitigations.

2. Threat Analysis

Mirai is a highly distributed malware that primarily targets IoT devices with default or weak passwords. Its behavior on a network can be broken down into several plausible steps:

- Initial Reconnaissance: Mirai scans the network for vulnerable IoT devices, often using default or weak passwords.
- Device Compromise: Mirai exploits vulnerabilities in the devices, gaining remote access and control.
- Communication Establishment: Mirai establishes communication with its command and control (C2) server, receiving instructions and sending back information about the compromised devices.
- DDoS Attack: Mirai can be used to launch DDoS attacks against targeted systems, overwhelming them with traffic from the compromised devices.

3. Evidence Found

No retrieved KB evidence is available for this analysis. The following information is based on general knowledge and reasoning-only.

4. MITRE ATT&CK Mapping

Based on Mirai's behavior, the following MITRE ATT&CK techniques may be applicable:

- T1059: System Network Scanning (guess)
- T1071: Application Layer Protocol: Web Protocols (guess)
- T1210: Exploit Public-Facing Application (guess)
- T1204: User Execution: Malware from the Internet (guess)
- T1490: Alternate C2 Channel (guess)

Please note that these are educated guesses and may not accurately reflect Mirai's behavior.

5. Related Vulnerabilities

Mirai has been known to exploit several vulnerabilities, including:

- CVE-2014-8361: A vulnerability in the TR-069 protocol used by some IoT devices.
- CVE-2016-10195: A vulnerability in the Linksys EA9200 router.

However, without specific evidence, it's difficult to determine the exact vulnerabilities exploited by Mirai.

6. Recommended Mitigations

To mitigate Mirai's behavior, consider the following practical steps:

- Implement strong passwords: Ensure that all IoT devices have strong, unique passwords.
- Keep software up-to-date: Regularly update IoT devices with the latest firmware and software patches.
- Use a network segmentation: Segment the network to limit the spread of malware in case of a compromise.
- Implement intrusion detection and prevention systems: Use IDS/IPS systems to detect and prevent Mirai-like traffic.
- Monitor network traffic: Regularly monitor network traffic for suspicious activity.

7. References

This report is based on general knowledge and model knowledge. The following references are provided for further reading:

- MITRE ATT&CK: A framework for understanding and describing the tactics, techniques, and procedures (TTPs) used by adversaries.
- CVE-2014-8361: A vulnerability in the TR-069 protocol used by some IoT devices.
- CVE-2016-10195: A vulnerability in the Linksys EA9200 router.
- IoT Security Foundation: A non-profit organization that provides guidance and resources for securing IoT devices.

Please note that this report is based on general knowledge and may not be specific to Mirai's behavior.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the behavior of the Mirai malware on a network and maps its behavior to MITRE ATT&CK techniques. The analysis is based on the provided evidence from IoT-23 scenarios and MITRE ATT&CK documentation. The report identifies the observed network behaviors of Mirai, including scanning, command-and-control, and denial-of-service activity. The MITRE ATT&CK techniques that map to these behaviors are also identified.

Threat Analysis

Mirai is a malware family that infects IoT devices and uses them to conduct various malicious activities, including scanning, command-and-control, and denial-of-service attacks. The malware is designed to spread itself to other hosts in the victim environment and can be used to facilitate botnet campaigns.

Evidence Found

The evidence from IoT-23 scenarios CTU-IoT-Malware-Capture-7-1 and CTU-IoT-Malware-Capture-17-1 describes the observed network behaviors of Mirai and Kenjiro malware, respectively. The observed behaviors include:

- * Okiru (11333397 flows)
- * DDoS (39584 flows)
- * C&C-HeartBeat (5778 flows)
- * PartOfAHorizontalPortScan (27311187 flows)
- * Okiru (13655215 flows)
- * DDoS (13655172 flows)
- * C&C-HeartBeat (6834 flows)

These behaviors are primarily related to scanning, command-and-control, and denial-of-service activity.

MITRE ATT&CK Mapping

The MITRE ATT&CK techniques that map to the observed behaviors of Mirai are:

- * T1496.002: Bandwidth Hijacking (related to DDoS and Okiru flows)
- * T1048: Exfiltration Over Alternative Protocol Mitigation (related to C&C-HeartBeat flows)
- * S0599: Kinsing (not directly related to Mirai, but included for completeness)

However, the most relevant MITRE ATT&CK technique that maps to the observed behaviors of Mirai is T1496.002: Bandwidth Hijacking.

Related Vulnerabilities

The vulnerabilities related to the observed behaviors of Mirai are:

- * CVE-2016-10229: Vulnerability in the Linux kernel that allows remote attackers to cause a denial of service (crash) via a crafted packet.
- * CVE-2016-10230: Vulnerability in the Linux kernel that allows remote attackers to cause a denial of service (crash) via a crafted packet.

Recommended Mitigations

To mitigate the risks associated with Mirai, the following recommendations are made:

- * Implement network segmentation to isolate IoT devices from the rest of the network.
- * Use network intrusion detection and prevention systems to detect and prevent malicious traffic.
- * Enforce proxies and use dedicated servers for services such as DNS.
- * Block unnecessary ports and traffic at the network perimeter.
- * Regularly update and patch IoT devices and Linux systems to prevent exploitation of known vulnerabilities.

References

- * [1] IoT-23 scenario CTU-IoT-Malware-Capture-7-1
- * [2] IoT-23 scenario CTU-IoT-Malware-Capture-17-1
- * [3] MITRE ATT&CK technique S0599: Kinsing
- * [4] MITRE ATT&CK technique T1496.002: Bandwidth Hijacking
- * [5] MITRE ATT&CK technique T1048: Exfiltration Over Alternative Protocol Mitigation

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the behavior of the Mirai malware on a network and maps it to MITRE ATT&CK techniques. The analysis is based on the provided evidence from IoT-23 scenarios and MITRE ATT&CK techniques. The report identifies the observed network behaviors of Mirai, including scanning, command-and-control, and denial-of-service activity. It also maps these behaviors to relevant MITRE ATT&CK techniques, including Bandwidth Hijacking and Exfiltration Over Alternative Protocol.

Threat Analysis

Mirai is a malware family that infects IoT devices and uses them to conduct various malicious activities, including scanning, command-and-control, and denial-of-service attacks. The malware uses TCP traffic to communicate with its command-and-control server and to conduct DDoS attacks. The observed network behaviors of Mirai include:

- * Okiru (11333397 flows): This behavior is likely related to the malware's scanning activity, where it searches for vulnerable devices to infect.
- * DDoS (39584 flows): This behavior is likely related to the malware's denial-of-service activity, where it uses infected devices to conduct DDoS attacks on targeted systems.
- * C&C-HeartBeat (5778 flows): This behavior is likely related to the malware's command-and-control activity, where it communicates with its command-and-control server to receive instructions and send back information.

Evidence Found

The evidence from IoT-23 scenarios provides insight into the observed network behaviors of Mirai. The most relevant evidence is from Document 1, which describes the malware's behavior as follows:

- * Okiru (11333397 flows)
- * DDoS (39584 flows)
- * C&C-HeartBeat (5778 flows)

MITRE ATT&CK Mapping

The observed network behaviors of Mirai can be mapped to the following MITRE ATT&CK techniques:

- * T1496.002: Bandwidth Hijacking - This technique is relevant to Mirai's DDoS activity, where it uses infected devices to conduct DDoS attacks and impact system and/or hosted service availability.
- * T1048: Exfiltration Over Alternative Protocol Mitigation - This technique is relevant to Mirai's command-and-control activity, where it communicates with its command-and-control server to receive instructions and send back information.

Related Vulnerabilities

The provided evidence does not mention any specific vulnerabilities exploited by Mirai. However, Document 6 describes a vulnerability in Eaton ELCSOFT that allows remote attackers to execute arbitrary code. This vulnerability is not directly related to Mirai, but it highlights the importance of patching vulnerabilities to prevent exploitation by malware.

Recommended Mitigations

To mitigate the risks associated with Mirai, the following recommendations are made:

- * Implement network segmentation to isolate IoT devices from the rest of the network.
- * Use firewalls to block unnecessary ports and traffic.
- * Enforce proxies and use dedicated servers for services such as DNS.
- * Monitor network traffic for suspicious activity, including scanning and DDoS attacks.
- * Patch vulnerabilities in IoT devices and other systems to prevent exploitation by malware.

References

- * Document 1: [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1
- * Document 2: [IoT23] Kenjiro — CTU-IoT-Malware-Capture-17-1
- * Document 3: [MITRE] Bandwidth Hijacking
- * Document 4: [MITRE] Exfiltration Over Alternative Protocol Mitigation
- * Document 5: [MITRE] Kinsing
- * Document 6: [VARIoT] (0Day) Eaton ELCSOFT SFC File Parsing Out-Of-Bounds Access Remote Code Execution Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 8/24 — q050

Human eval sheet — q050

Category: multi_facet

Question

Produce an evidence-backed IoT incident report for Mirai: behaviour, related techniques, vulnerabilities if any, and mitigations. Clearly mark missing evidence.

Gold notes (optional reference)

End-to-end report; must cite evidence and admit gaps (e.g., no Mirai CVE list).

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Incident Report: Mirai

Executive Summary:

Mirai is a notorious IoT malware that has been linked to several high-profile DDoS attacks. This report provides an evidence-backed analysis of its behavior, related techniques, vulnerabilities, and mitigations. Mirai is designed to infect IoT devices, particularly those with default or weak passwords, and uses these compromised devices to launch DDoS attacks against targeted systems.

Threat Analysis:

Mirai is a malware designed to infect IoT devices, likely created by threat actors seeking to launch DDoS attacks. The vulnerability class is related to weak passwords and unpatched firmware. The malware employs several techniques, including scanning, exploitation, and C2 communication.

Evidence Found:

While I have no retrieved knowledge base evidence to support this report, my analysis is based on my knowledge and experience as a senior IoT cybersecurity expert. The following is a summary of the evidence found:

- * Mirai scans for vulnerable devices using a list of known default or weak passwords.
- * Mirai exploits vulnerabilities to gain access to devices.
- * Mirai communicates with its C2 server to receive instructions and send back data.
- * Mirai uses compromised devices to launch DDoS attacks against targeted systems.

MITRE ATT&CK Mapping:

Based on my analysis, the following MITRE ATT&CK techniques are related to Mirai:

- * Initial Access: T1059 (Command and Control) - Mirai uses C2 communication to receive instructions and send back data.
- * Execution: T1055 (Process Injection) - Mirai may use process injection to execute its payload on compromised devices.
- * Persistence: T1547 (Boot or Logon Autostart Execution) - Mirai may use boot or logon autostart execution to ensure persistence on compromised devices.
- * Lateral Movement: T1021 (Remote Services) - Mirai uses remote services to communicate with its C2 server and launch DDoS attacks.

Related Vulnerabilities:

The following vulnerabilities are related to Mirai:

- * Telnet: CVE-2016-6403 - A vulnerability in the Telnet server that allows remote code execution.
- * SSH: CVE-2016-10011 - A vulnerability in the SSH server that allows remote code execution.
- * Unknown: I have no evidence to support specific vulnerabilities exploited by Mirai.

Recommended Mitigations:

To prevent Mirai infections, the following mitigations are recommended:

1. Use strong passwords: Ensure all IoT devices have unique, strong passwords.
2. Keep software up-to-date: Regularly update IoT device firmware to patch known vulnerabilities.
3. Implement network segmentation: Isolate IoT devices from critical systems to prevent lateral movement.
4. Use a WAF: Implement a Web Application Firewall to detect and prevent DDoS attacks.
5. Monitor network traffic: Regularly monitor network traffic to detect suspicious activity.

References:

- * Model knowledge / general references only:
 - + "Mirai Botnet" by Symantec
 - + "Mirai Malware" by Kaspersky
 - + "IoT Security" by NIST

Note: The above analysis is based on my knowledge and experience as a senior IoT cybersecurity expert, but I have no evidence to support some of the claims made.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report documents an IoT incident involving the Mirai malware family. The analysis reveals that Mirai exhibits behavior consistent with scanning, command-and-control, and denial-of-service activities. The malware is observed to communicate with its command-and-control server through various network protocols, including TCP and UDP. The incident highlights the need for robust security measures to prevent such attacks.

Threat Analysis

The Mirai malware family is a type of IoT botnet malware that infects IoT devices and uses them to conduct various malicious activities, including:

1. Scanning: Mirai scans for vulnerable devices to infect.
2. Command-and-Control (C2): Mirai communicates with its C2 server to receive instructions.
3. Denial-of-Service (DoS): Mirai uses infected devices to launch DoS attacks.

Evidence Found

The provided evidence consists of six documents, including:

1. Document 1: Mirai — CTU-IoT-Malware-Capture-7-1, which describes Mirai's behavior, including scanning, C2, and DoS activities.
2. Document 2: Hide and Seek — CTU-IoT-Malware-Capture-1-1, which describes a different malware family, Hide and Seek, and its behavior.
3. Document 3: Hajime — CTU-IoT-Malware-Capture-9-1, which describes Hajime malware behavior.
4. Document 4: Torii — CTU-IoT-Malware-Capture-21-1, which describes Torii malware behavior.
5. Document 5: Kenjiro — CTU-IoT-Malware-Capture-17-1, which describes Kenjiro malware behavior.
6. Document 6: NEC ESMPRO Manager Unreliable data deserialization vulnerability in, which describes a vulnerability in NEC ESMPRO Manager 6.

MITRE ATT&CK Mapping

Based on the evidence, the following MITRE ATT&CK techniques can be mapped:

1. T1190: Exploit Public-Facing Application (Mirai exploits vulnerabilities in IoT devices)
2. T1071: Application Layer Protocol: Protocol Tuning (Mirai uses TCP and UDP protocols to

communicate with C2 server)

3. T1078: Valid Accounts: Use of Legitimate Services (Mirai uses legitimate services, such as DNS, to communicate with C2 server)

Related Vulnerabilities

The provided evidence mentions the following vulnerability:

1. CVE-2020-10917: NEC ESMPRO Manager Unreliable data deserialization vulnerability in

Recommended Mitigations

To prevent Mirai-like attacks, the following mitigations are recommended:

1. Keep IoT devices up-to-date: Regularly update IoT devices with the latest security patches.
2. Use strong passwords: Use strong, unique passwords for all IoT devices.
3. Implement network segmentation: Segment IoT devices from the rest of the network to prevent lateral movement.
4. Monitor network traffic: Monitor network traffic for suspicious activity, such as scanning or C2 communication.
5. Use intrusion detection and prevention systems: Implement intrusion detection and prevention systems to detect and prevent Mirai-like attacks.

References

1. Document 1: Mirai — CTU-IoT-Malware-Capture-7-1
2. Document 2: Hide and Seek — CTU-IoT-Malware-Capture-1-1
3. Document 3: Hajime — CTU-IoT-Malware-Capture-9-1
4. Document 4: Torii — CTU-IoT-Malware-Capture-21-1
5. Document 5: Kenjiro — CTU-IoT-Malware-Capture-17-1
6. Document 6: NEC ESMPRO Manager Unreliable data deserialization vulnerability in

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer C

Executive Summary

This report provides an analysis of the Mirai malware incident, focusing on its behavior, related techniques, vulnerabilities, and mitigations. The evidence suggests that Mirai is a botnet malware that infects IoT devices, exhibiting behaviors such as scanning, command-and-control, and denial-of-service activity.

Threat Analysis

Mirai is a highly distributed malware that infects IoT devices, primarily using scanning and exploitation techniques to spread. The malware is designed to create a botnet, which can be used for various malicious activities, including DDoS attacks, data theft, and ransomware distribution. The Mirai botnet is known for its ability to overwhelm targeted systems with massive traffic, causing significant disruptions to online services.

Evidence Found

The provided evidence (Document 1) describes Mirai malware behavior, including:

- * Okiru (11333397 flows): This suggests that Mirai is scanning for vulnerable devices.
- * DDoS (39584 flows): This indicates that Mirai is capable of launching denial-of-service attacks.
- * C&C-HeartBeat (5778 flows): This suggests that Mirai is communicating with its command-and-control server.

MITRE ATT&CK Mapping

Based on the observed behaviors, the following MITRE ATT&CK techniques can be mapped to Mirai:

- * T1056: Network Service Scanning (Okiru)
- * T1498: DDoS (DDoS)
- * T1071: Application Layer Protocol: Web Protocols (C&C-HeartBeat)

Related Vulnerabilities

The provided evidence does not explicitly mention any specific vulnerabilities exploited by Mirai. However, it is known that Mirai exploits vulnerabilities in IoT devices, particularly those with weak passwords and outdated firmware.

Recommended Mitigations

To prevent Mirai infections and mitigate its effects:

1. Keep IoT devices up-to-date: Ensure that all IoT devices have the latest firmware and security patches installed.
2. Use strong passwords: Use unique, complex passwords for all IoT devices, and consider using multi-factor authentication.
3. Implement network segmentation: Segment IoT devices from the rest of the network to prevent lateral movement in case of an infection.
4. Monitor network traffic: Regularly monitor network traffic for suspicious activity, such as scanning and DDoS attacks.
5. Implement intrusion detection and prevention systems: Use IDS/IPS systems to detect and prevent Mirai-related traffic.

References

* [1] CTU-IoT-Malware-Capture-7-1 (Document 1)

* [2] CTU-IoT-Malware-Capture-1-1 (Document 5)

Note: The provided evidence does not explicitly mention the vulnerabilities exploited by Mirai. However, it is known that Mirai exploits vulnerabilities in IoT devices, particularly those with weak passwords and outdated firmware.

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer D

Executive Summary

This report provides an analysis of the Mirai malware, a notorious IoT botnet that has been involved in several high-profile DDoS attacks. The analysis is based on evidence from various sources, including network captures and vulnerability reports. The report highlights the behavior, related techniques, vulnerabilities, and mitigations associated with Mirai.

Threat Analysis

Mirai is a highly distributed malware that infects IoT devices, including routers, cameras, and other networked devices. The malware uses a combination of scanning, command-and-control (C2), and denial-of-service (DoS) techniques to compromise devices and launch attacks. The observed network behaviors include:

* Okiru (11333397 flows)

* DDoS (39584 flows)

* C&C-HeartBeat (5778 flows)

These behaviors are consistent with the Mirai botnet's known behavior, which includes scanning for vulnerable devices, establishing C2 connections, and launching DoS attacks.

Evidence Found

The evidence suggests that Mirai is a highly distributed malware that uses a combination of scanning, C2, and DoS techniques to compromise devices and launch attacks. However, the evidence is insufficient to determine the specific vulnerabilities exploited by Mirai to infect devices.

MITRE ATT&CK Mapping

The Mirai malware's behavior can be mapped to the following MITRE ATT&CK techniques:

- * T1595: Active Scanning (scanning for vulnerable devices)
- * T1005: Data from Local System (establishing C2 connections)
- * T1490: Resource Hijacking (launching DoS attacks)

Related Vulnerabilities

The evidence suggests that Mirai may exploit vulnerabilities in IoT devices, including:

- * Mitsubishi Melsec FX3G-24M Denial Of Service (Document 4)
- * MikroTik RouterBoard v6.38.5 - Denial of Service (Document 5)
- * plural Iomega Product EMC Lifeline Vulnerability to read data in firmware (Document 6)

However, the evidence is insufficient to determine the specific vulnerabilities exploited by Mirai.

Recommended Mitigations

To mitigate the risks associated with Mirai, the following measures can be implemented:

- * Implement proactive vulnerability scanning (Document 7)
- * Use network security appliances to detect and prevent C2 connections (Document 8)
- * Ensure that IoT devices are properly configured and patched
- * Implement a robust incident response plan to quickly respond to and contain Mirai-related incidents

References

- * Document 1: CTU-IoT-Malware-Capture-7-1
- * Document 2: CTU-IoT-Malware-Capture-9-1
- * Document 3: CTU-IoT-Malware-Capture-21-1
- * Document 4: Mitsubishi Melsec FX3G-24M Denial Of Service
- * Document 5: MikroTik RouterBoard v6.38.5 - Denial of Service
- * Document 6: plural Iomega Product EMC Lifeline Vulnerability to read data in firmware
- * Document 7: MITRE ATT&CK technique M1016
- * Document 8: MITRE ATT&CK technique T1590.006

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 9/24 — q008

Human eval sheet — q008

Category: behaviour

Question

What C&C-related behaviours appear across IoT-23 malware captures?

Gold notes (optional reference)

C&C, C&C-HeartBeat, C&C-Torii across families.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the Command and Control (C&C)-related behaviors observed in IoT-23 malware captures. The analysis reveals that multiple malware families, including Hide and Seek, Muhstik, Hakai, Torii, and Mirai, exhibit C&C behaviors. The report provides an overview of the observed behaviors, evidence, and recommended mitigations.

Threat Analysis

The IoT-23 malware captures reveal that various malware families are using C&C behaviors to communicate with their command centers. These behaviors are a significant threat to IoT devices and networks, as they can be used to launch attacks, steal sensitive information, or spread malware. The observed C&C behaviors include:

- * Hide and Seek: 8 flows
- * Muhstik: 8 flows
- * Hakai: 8222 flows
- * Torii: 14 flows
- * Mirai: 5778 flows

Evidence Found

The evidence collected from the IoT-23 malware captures indicates that the following C&C-related behaviors are present:

- * Hide and Seek: PartOfAHorizontalPortScan (539465 flows), C&C (8 flows)
- * Muhstik: PartOfAHorizontalPortScan (145597 flows), Attack (5962 flows), C&C (8 flows)
- * Hakai: C&C (8222 flows)

- * Torii: C&C-Torii (14 flows)
- * Mirai: Okiru (11333397 flows), DDoS (39584 flows), C&C-HeartBeat (5778 flows)

MITRE ATT&CK Mapping

The observed C&C behaviors can be mapped to the following MITRE ATT&CK techniques:

- * T1071 - Application Layer Protocol: Hide and Seek, Muhstik, Hakai, Torii, and Mirai use TCP and UDP protocols for C&C communication.
- * T1071.001 - Web Protocols: Hide and Seek, Muhstik, and Mirai use HTTP and HTTPS protocols for C&C communication.
- * T1071.002 - Non-Web Protocols: Hakai and Torii use non-web protocols for C&C communication.
- * T1071.003 - Other: Mirai uses a custom protocol for C&C communication.

Related Vulnerabilities

The observed C&C behaviors are related to the following vulnerabilities:

- * CVE-2019-15126: A vulnerability in the Hide and Seek malware that allows attackers to inject malicious code.
- * CVE-2018-1000002: A vulnerability in the Muhstik malware that allows attackers to inject malicious code.
- * CVE-2017-13166: A vulnerability in the Hakai malware that allows attackers to inject malicious code.
- * CVE-2017-13165: A vulnerability in the Torii malware that allows attackers to inject malicious code.
- * CVE-2016-1040: A vulnerability in the Mirai malware that allows attackers to inject malicious code.

Recommended Mitigations

To mitigate the observed C&C behaviors, the following recommendations are provided:

- * Implement a robust security framework that includes network segmentation, intrusion detection and prevention systems, and endpoint security.
- * Regularly update and patch IoT devices and software to prevent exploitation of known vulnerabilities.
- * Implement a secure communication protocol, such as TLS, for C&C communication.
- * Monitor network traffic for suspicious activity and implement anomaly detection systems.
- * Implement a secure authentication and authorization mechanism to prevent unauthorized access to IoT devices.

References

- * [1] CTU-IoT-Malware-Capture-1-1: Hide and Seek — CTU-IoT-Malware-Capture-1-1
- * [2] CTU-IoT-Malware-Capture-3-1: Muhstik — CTU-IoT-Malware-Capture-3-1
- * [3] CTU-IoT-Malware-Capture-8-1: Hakai — CTU-IoT-Malware-Capture-8-1
- * [4] CTU-IoT-Malware-Capture-21-1: Torii — CTU-IoT-Malware-Capture-21-1
- * [5] CTU-IoT-Malware-Capture-7-1: Mirai — CTU-IoT-Malware-Capture-7-1

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the Command and Control (C&C)-related behaviors observed in IoT-23 malware captures. The analysis reveals that the Hide and Seek, Muhstik, and Hakai malware families exhibit C&C behaviors, with the latter two also engaging in scanning and denial-of-service activities. The findings suggest that these malware families utilize TCP traffic primarily for their operations.

Threat Analysis

The Hide and Seek, Muhstik, and Hakai malware families demonstrate C&C behaviors, indicating a potential threat to IoT devices. The presence of these behaviors suggests that the malware families are designed to communicate with their command and control servers, potentially for the purpose of receiving instructions or transmitting stolen data.

Evidence Found

The evidence collected from the IoT-23 malware captures indicates the following C&C-related behaviors:

- * Hide and Seek: 8 flows
- * Muhstik: 8 flows
- * Hakai: 8222 flows

These findings suggest that Hakai exhibits the most extensive C&C behavior among the three malware families.

MITRE ATT&CK Mapping

Based on the evidence found, the C&C-related behaviors observed in the IoT-23 malware captures can be mapped to the following MITRE ATT&CK techniques:

- * M1016: Vulnerability Scanning (not directly related to C&C behaviors, but relevant to the overall threat analysis)

- * T1497.001: System Checks (not directly related to C&C behaviors, but relevant to the overall threat analysis)

However, the C&C behaviors observed in the IoT-23 malware captures can be mapped to the following MITRE ATT&CK techniques:

- * T1071: Application Layer Protocol: The malware families utilize TCP traffic for their C&C operations, which can be mapped to this technique.
- * T1216: Data Encrypted or Authentication Integrity: The malware families may encrypt their C&C communications, which can be mapped to this technique.

Related Vulnerabilities

The evidence collected from the VARIOt documents suggests that the following vulnerabilities may be related to the C&C behaviors observed in the IoT-23 malware captures:

- * CVE-2017-6636: Cisco Prime Collaboration Provisioning Software Web Path traversal vulnerability in the interface
- * CVE-2012-4876: TRENDnet SecurView Internet Camera - UltraMJCcam OpenFileDialog Buffer Overflow (Metasploit) - Windows remote Exploit

These vulnerabilities may be exploited by the malware families to gain access to IoT devices or to establish C&C communications.

Recommended Mitigations

To mitigate the C&C-related behaviors observed in the IoT-23 malware captures, the following recommendations are provided:

- * Implement a robust network security solution that includes intrusion detection and prevention systems (IDPS) to detect and block C&C communications.
- * Use a vulnerability scanner to identify and remediate vulnerabilities in IoT devices and other systems.
- * Implement a secure configuration for IoT devices, including disabling unnecessary services and protocols.
- * Use encryption to protect C&C communications and data transmitted between IoT devices and their command and control servers.
- * Regularly update and patch IoT devices and other systems to prevent exploitation of known vulnerabilities.

References

- * Document 1: Hide and Seek — CTU-IoT-Malware-Capture-1-1
- * Document 2: Muhstik — CTU-IoT-Malware-Capture-3-1
- * Document 3: Hakai — CTU-IoT-Malware-Capture-8-1

- * Document 4: Ubee EVW3200 Cross Site Scripting
 - * Document 5: Cisco Prime Collaboration Provisioning Software Web Path traversal vulnerability in the interface
 - * Document 6: TRENDnet SecurView Internet Camera - UltraMJCcam OpenFileDialog Buffer Overflow (Metasploit) - Windows remote Exploit
 - * Document 7: Vulnerability Scanning
 - * Document 8: System Checks
- Faithfulness (1–5): ____
 - Usefulness (1–5): ____
 - Technical correctness (1–5): ____

Answer C

IoT-23 Malware Threat Analysis Report

1. Executive Summary

This report provides an analysis of the Command and Control (C&C)-related behaviors observed in IoT-23 malware captures. Based on the available information, the malware is likely targeting Internet of Things (IoT) devices and using various techniques to communicate with its command and control server. The report outlines the expected network behaviors, related MITRE ATT&CK techniques, and associated vulnerabilities. Practical mitigations are also recommended to prevent the spread of the malware.

2. Threat Analysis

The IoT-23 malware is likely designed to target IoT devices, exploiting vulnerabilities to gain access and transmit data back to its command and control server. The malware may use various C&C protocols, such as Coordinated Scanning and Attack (CSA) or Internet Relay Chat (IRC), to communicate with its server. Evasion techniques, including encryption, steganography, and code obfuscation, may be used to avoid detection.

3. Evidence Found

No retrieved KB evidence is available to support this analysis. The following reasoning is based on general knowledge and assumptions:

- * The malware is likely using a vulnerability scanner to identify vulnerable IoT devices.
- * The malware may be exploiting a known vulnerability to gain access to the device.
- * The malware may be using a C&C protocol to communicate with its command and control server.
- * The malware may be transmitting data back to the C&C server, such as device information, system logs, or sensitive data.

4. MITRE ATT&CK Mapping

Based on the expected network behaviors, the following MITRE ATT&CK techniques are associated with the IoT-23 malware:

- * T1059: Command and Control (C2) - The malware uses a C&C protocol to communicate with its command and control server.
- * T1047: Windows Management Instrumentation (WMI) - The malware uses WMI to gather system information and transmit it back to the C&C server.
- * T1071: Application Layer Protocol: Web Protocols - The malware uses web protocols such as HTTP or HTTPS to communicate with the C&C server.
- * T1210: Exploitation of Remote Services - The malware exploits a known vulnerability to gain access to the IoT device.

5. Related Vulnerabilities

Based on the expected network behaviors, the following vulnerabilities are associated with the IoT-23 malware:

- * CVE-2021-44228: Log4j vulnerability - The malware exploits a Log4j vulnerability to gain access to the IoT device.
- * CVE-2019-15126: Siemens SIMATIC WinCC vulnerability - The malware exploits a Siemens SIMATIC WinCC vulnerability to gain access to the IoT device.

6. Recommended Mitigations

To mitigate the IoT-23 malware, the following practical mitigations are recommended:

- * Implement a robust security information and event management (SIEM) system to detect and respond to suspicious network activity.
- * Use a vulnerability scanner to identify and patch vulnerable IoT devices.
- * Implement a web application firewall (WAF) to block malicious web traffic.
- * Use encryption to protect data transmitted between the IoT device and the C&C server.
- * Implement a network segmentation strategy to isolate IoT devices from the rest of the network.

7. References

- * MITRE ATT&CK Framework: <<https://attack.mitre.org/>>
- * CVE-2021-44228: Log4j vulnerability: <<https://nvd.nih.gov/vuln/detail/CVE-2021-44228>>
- * CVE-2019-15126: Siemens SIMATIC WinCC vulnerability: <<https://nvd.nih.gov/vuln/detail/CVE-2019-15126>>
- * IoT Security Best Practices: <<https://www.iotsecurityfoundation.org/iot-security-best-practices/>>

Note: The references provided are general knowledge and not specific to the IoT-23 malware.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the C&C-related behaviors observed in IoT-23 malware captures. The analysis reveals that multiple malware families, including Hide and Seek, Muhstik, Hakai, Torii, and Mirai, exhibit C&C behaviors. The report provides an overview of the observed behaviors, evidence found, and recommended mitigations.

Threat Analysis

The IoT-23 malware captures reveal that various malware families are using C&C behaviors to communicate with their command and control servers. The observed behaviors include:

- * Hide and Seek: 8 C&C flows
- * Muhstik: 8 C&C flows
- * Hakai: 8222 C&C flows
- * Torii: 14 C&C-Torii flows
- * Mirai: 5778 C&C-HeartBeat flows

These behaviors indicate that the malware families are using C&C to receive instructions, send data, or perform other malicious activities.

Evidence Found

The evidence found in the IoT-23 malware captures supports the presence of C&C behaviors in the malware families. The captures contain flows related to C&C, including:

- * Hide and Seek: PartOfAHorizontalPortScan (539465 flows), C&C (8 flows)
- * Muhstik: PartOfAHorizontalPortScan (145597 flows), Attack (5962 flows), C&C (8 flows)
- * Hakai: C&C (8222 flows)
- * Torii: C&C-Torii (14 flows)
- * Mirai: Okiru (11333397 flows), DDoS (39584 flows), C&C-HeartBeat (5778 flows)

MITRE ATT&CK Mapping

The observed C&C behaviors can be mapped to the following MITRE ATT&CK techniques:

- * T1071: Application Layer Protocol: The malware families are using C&C to communicate with their command and control servers.
- * T1078: Valid Accounts: The malware families are using valid accounts to communicate with their command and control servers.

* T1210: Exploit Public-Facing Application: The malware families are exploiting public-facing applications to gain access to the IoT devices.

Related Vulnerabilities

The NETGEAR AC1200 mini_httpd Poison Null Byte Authentication Bypass Vulnerability (CVE-2019-17137) is related to the observed C&C behaviors. This vulnerability allows network-adjacent attackers to bypass authentication on affected installations of NETGEAR AC1200 R6220 Firmware version 1.1.0.86 Smart WiFi Router.

Recommended Mitigations

To mitigate the observed C&C behaviors, we recommend the following:

- * Implement a robust security solution that includes intrusion detection and prevention systems (IDPS) and network-based intrusion prevention systems (NIPS).
- * Use secure protocols, such as HTTPS and SSH, to encrypt communication between IoT devices and their command and control servers.
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
- * Implement a network segmentation strategy to isolate IoT devices from the rest of the network.
- * Use a secure authentication mechanism to prevent unauthorized access to IoT devices.

References

- * [1] Hide and Seek — CTU-IoT-Malware-Capture-1-1
- * [2] Muhstik — CTU-IoT-Malware-Capture-3-1
- * [3] Hakai — CTU-IoT-Malware-Capture-8-1
- * [4] Torii — CTU-IoT-Malware-Capture-21-1
- * [5] Mirai — CTU-IoT-Malware-Capture-7-1
- * [6] NETGEAR AC1200 mini_httpd Poison Null Byte Authentication Bypass Vulnerability (CVE-2019-17137)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 10/24 — q006

Human eval sheet — q006

Category: behaviour

Question

Compare Mirai and Hajime network behaviours using IoT-23 evidence.

Gold notes (optional reference)

Contrast Capture-7-1 vs Capture-9-1 behaviours.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report compares the network behaviors of Mirai and Hajime malware families using IoT-23 evidence. The analysis reveals distinct differences in their network activities, which can inform mitigation strategies and threat intelligence. The report highlights the observed network behaviors, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

Mirai and Hajime are two prominent IoT malware families that have been observed in various network capture scenarios. Mirai is known for its DDoS capabilities, while Hajime is associated with scanning and command-and-control activities. The analysis of IoT-23 evidence reveals that Mirai exhibits more aggressive behavior, with a higher number of DDoS flows (39584) compared to Hajime (0). In contrast, Hajime is characterized by a significant number of PartOfAHorizontalPortScan flows (6355745).

Evidence Found

The IoT-23 evidence provides the following observations:

- * Mirai: Okiru (11333397 flows), DDoS (39584 flows), C&C-HeartBeat (5778 flows)
- * Hajime: PartOfAHorizontalPortScan (6355745 flows)
- * Kenjiro (a different malware family): PartOfAHorizontalPortScan (27311187 flows), Okiru (13655215 flows), DDoS (13655172 flows), C&C-HeartBeat (6834 flows)

MITRE ATT&CK Mapping

Based on the observed network behaviors, the following MITRE ATT&CK techniques can be mapped:

- * Mirai: T1497.002 (User Activity Based Checks) and T1049 (System Network Connections Discovery)
- * Hajime: T1497.002 (User Activity Based Checks) and T1049 (System Network Connections Discovery)
- * Kenjiro: T1497.002 (User Activity Based Checks), T1049 (System Network Connections Discovery), and T1496 (Resource Hijacking)

Related Vulnerabilities

The analysis of IoT-23 evidence does not directly reveal any specific vulnerabilities. However, the presence of Denial of Service (DoS) and Remote Code Execution (RCE) exploits in the VARIOt evidence suggests potential vulnerabilities in IoT devices.

Recommended Mitigations

Based on the analysis, the following mitigations are recommended:

1. Implement network segmentation to isolate IoT devices from critical infrastructure.
2. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
3. Monitor network traffic for suspicious activity, particularly DDoS and scanning behaviors.
4. Implement User Activity Based Checks to detect and prevent virtualization and analysis environments.
5. Use system network connections discovery techniques to identify potential vulnerabilities and weaknesses.

References

- * IoT-23 evidence: [Document 1] Hajime — CTU-IoT-Malware-Capture-9-1, [Document 2] Mirai — CTU-IoT-Malware-Capture-7-1, [Document 3] Kenjiro — CTU-IoT-Malware-Capture-17-1
- * VARIOt evidence: [Document 4] MikroTik RouterBoard 6.38.5 - Denial of Service Exploit, [Document 5] MikroTik RouterBoard v6.38.5 - Denial of Service, [Document 6] EnGenius EnShare IoT Gigabit Cloud Service 1.4.11 - Remote Code Execution - Hardware webapps Exploit
- * MITRE ATT&CK techniques: [Document 7] User Activity Based Checks, [Document 8] System Network Connections Discovery

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report compares the network behaviors of Mirai and Hajime malware families using IoT-23 evidence. The analysis reveals distinct differences in their network activities, with Mirai exhibiting more aggressive behavior, including DDoS attacks and command-and-control (C&C)

heartbeats. Hajime, on the other hand, primarily engages in scanning activities. This report provides a detailed analysis of the observed network behaviors, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

Mirai and Hajime are both IoT malware families that have been observed in various network captures. Mirai is known for its aggressive behavior, including DDoS attacks and C&C heartbeats, while Hajime primarily engages in scanning activities. The observed network behaviors of these malware families are as follows:

- * Mirai: Okiru (11333397 flows), DDoS (39584 flows), C&C-HeartBeat (5778 flows)
- * Hajime: PartOfAHorizontalPortScan (6355745 flows)

Evidence Found

The evidence provided in the IoT-23 scenarios reveals the following:

- * Document 1: Hajime malware infecting an IoT device, exhibiting PartOfAHorizontalPortScan behavior.
- * Document 2: Mirai malware infecting an IoT device, exhibiting Okiru, DDoS, and C&C-HeartBeat behaviors.

MITRE ATT&CK Mapping

Based on the observed network behaviors, the following MITRE ATT&CK techniques can be mapped:

- * Mirai:
 - + T1190: Exploit Public-Facing Application (Okiru)
 - + T1498: DDoS (DDoS)
 - + T1071: Application Layer Protocol: Web Protocols (C&C-HeartBeat)
- * Hajime:
 - + T1592: System Network Configuration Discovery (PartOfAHorizontalPortScan)

Related Vulnerabilities

The provided evidence does not directly relate to specific vulnerabilities. However, the following vulnerabilities are mentioned in the provided documents:

- * CVE-2019-15984: Cisco Data Center Network Manager getSwitchDbIdBySerialNumber SQL Injection Remote Code Execution Vulnerability
- * CVE-2016-2285: plural Moxa MiiNePort Cross-site request forgery vulnerability in device product firmware

Recommended Mitigations

To mitigate the threats posed by Mirai and Hajime, the following recommendations are provided:

- * Implement robust network segmentation and access controls to prevent lateral movement.
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
- * Implement intrusion detection and prevention systems (IDPS) to detect and block suspicious network traffic.
- * Conduct regular security audits and vulnerability assessments to identify and address potential weaknesses.

References

- * Document 1: Hajime — CTU-IoT-Malware-Capture-9-1
- * Document 2: Mirai — CTU-IoT-Malware-Capture-7-1
- * Document 3: Hide and Seek — CTU-IoT-Malware-Capture-1-1
- * Document 4: Kenjiro — CTU-IoT-Malware-Capture-17-1
- * Document 5: Cisco Data Center Network Manager getSwitchDbIdBySerialNumber SQL Injection Remote Code Execution Vulnerability
- * Document 6: plural Moxa MiiNePort Cross-site request forgery vulnerability in device product firmware

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report compares the network behaviors of Mirai and Hajime malware families using IoT-23 evidence. The analysis reveals distinct differences in their network activities, which can be used to identify and mitigate potential threats.

Threat Analysis

Mirai and Hajime are both IoT malware families that have been used in various cyber attacks. Mirai is known for its ability to conduct large-scale DDoS attacks, while Hajime has been observed to engage in scanning, command-and-control, and denial-of-service activities.

Evidence Found

The provided evidence consists of four IoT-23 scenarios:

1. Hajime — CTU-IoT-Malware-Capture-9-1: Observed network behaviors include PartOfAHorizontalPortScan (6355745 flows).
2. Mirai — CTU-IoT-Malware-Capture-7-1: Observed network behaviors include Okiru (11333397

flows), DDoS (39584 flows), C&C-HeartBeat (5778 flows).

3. Kenjiro — CTU-IoT-Malware-Capture-17-1: Observed network behaviors include PartOfAHorizontalPortScan (27311187 flows), Okiru (13655215 flows), DDoS (13655172 flows), C&C-HeartBeat (6834 flows).

4. Hide and Seek — CTU-IoT-Malware-Capture-1-1: Observed network behaviors include PartOfAHorizontalPortScan (539465 flows), C&C (8 flows).

MITRE ATT&CK Mapping

Based on the observed network behaviors, the following MITRE ATT&CK techniques can be mapped:

- * Mirai: Reconnaissance (T1046), Command and Control (T1005), Denial of Service (T1498)
- * Hajime: Reconnaissance (T1046), Command and Control (T1005), Denial of Service (T1498)

Related Vulnerabilities

The provided evidence does not explicitly mention any vulnerabilities. However, the Denial of Service Exploit (Document 5) suggests that vulnerabilities in MikroTik RouterBoard 6.38.5 may be exploited.

Recommended Mitigations

To mitigate potential threats from Mirai and Hajime malware families:

1. Implement network segmentation to isolate IoT devices from the rest of the network.
2. Use intrusion detection and prevention systems (IDPS) to detect and block suspicious network traffic.
3. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
4. Implement robust authentication and authorization mechanisms to prevent unauthorized access to IoT devices.
5. Monitor network traffic for signs of reconnaissance, command-and-control, and denial-of-service activities.

References

* IoT-23 scenarios: Hajime — CTU-IoT-Malware-Capture-9-1, Mirai — CTU-IoT-Malware-Capture-7-1, Kenjiro — CTU-IoT-Malware-Capture-17-1, Hide and Seek — CTU-IoT-Malware-Capture-1-1

* Denial of Service Exploit (Document 5)

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer D

Executive Summary

This report compares the network behaviors of Mirai and Hajime, two well-known IoT botnets, using IoT-23 evidence. Based on my analysis, I have identified key similarities and differences between the two malware families. Mirai is a relatively simple malware that exploits default passwords and weak credentials to infect IoT devices, while Hajime is a more complex malware that creates a network of compromised devices using a peer-to-peer communication mechanism. This report provides an overview of the threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations for both malware families.

Threat Analysis

Mirai and Hajime are both IoT botnets that pose significant threats to network security. Mirai is a well-known malware that exploits default passwords and weak credentials to infect IoT devices, often using vulnerabilities in devices such as routers, cameras, and DVRs. Hajime, on the other hand, is a more complex malware that not only infects devices but also creates a network of compromised devices, often using a peer-to-peer communication mechanism.

Evidence Found

Based on my analysis, I have identified the following evidence related to Mirai and Hajime:

- * Behavioral evidence: Mirai scans for devices with default or weak passwords, often using a dictionary attack or brute-force technique. Hajime scans for devices with weak passwords or open ports, often using a combination of network scanning and vulnerability exploitation.
- * Technique evidence: Mirai exploits vulnerabilities in devices such as routers, cameras, and DVRs, often using CVE-2016-10401 or CVE-2017-17215. Hajime exploits vulnerabilities in devices such as routers and cameras, often using unknown vulnerabilities.
- * Vulnerability evidence: Mirai exploits CVE-2016-10401 and CVE-2017-17215. Hajime exploits unknown vulnerabilities.
- * Exploit evidence: Mirai uses a dictionary attack or brute-force technique to exploit vulnerabilities. Hajime uses a combination of network scanning and vulnerability exploitation.
- * Mitigation evidence: Implementing strong passwords and enabling two-factor authentication on IoT devices, regularly updating and patching IoT devices, using a network segmentation strategy, implementing a robust intrusion detection and prevention system, and using a P2P detection and mitigation strategy can help prevent Mirai and Hajime infections.

MITRE ATT&CK Mapping

Based on my analysis, I have identified the following MITRE ATT&CK techniques related to Mirai and Hajime:

* Mirai:

- + Initial Access: T1210 (Exploit Public-Facing Application) - Mirai exploits vulnerabilities in public-facing applications.
- + Execution: T1204 (User Execution) - Mirai uses social engineering tactics to trick users into executing the malware.
- + Persistence: T1136 (Create Account) - Mirai creates a backdoor on the compromised device.

* Hajime:

- + Initial Access: T1210 (Exploit Public-Facing Application) - Hajime exploits vulnerabilities in public-facing applications.
- + Execution: T1204 (User Execution) - Hajime uses social engineering tactics to trick users into executing the malware.
- + Command and Control: T1508 (Ransomware) - Hajime uses a P2P communication mechanism to coordinate attacks.

Related Vulnerabilities

Based on my analysis, I have identified the following vulnerabilities related to Mirai and Hajime:

* Mirai:

- + CVE-2016-10401 (D-Link router vulnerability)
- + CVE-2017-17215 (Linksys router vulnerability)

* Hajime:

- + Unknown vulnerabilities (unknown)

Recommended Mitigations

To prevent Mirai and Hajime infections, I recommend the following mitigations:

- * Implement strong passwords and enable two-factor authentication on IoT devices.
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
- * Use a network segmentation strategy to isolate IoT devices from the rest of the network.
- * Implement a robust intrusion detection and prevention system to detect and block suspicious network traffic.
- * Use a P2P detection and mitigation strategy to prevent Hajime's P2P communication mechanism.

References

* Model knowledge / general references only:

- + "Mirai Botnet" by Cybersecurity and Infrastructure Security Agency (CISA)
- + "Hajime Botnet" by Cybersecurity and Infrastructure Security Agency (CISA)
- + "IoT Security 101" by National Institute of Standards and Technology (NIST)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 11/24 — q003

Human eval sheet — q003

Category: behaviour

Question

What behaviours are associated with Hajime in IoT-23?

Gold notes (optional reference)

Capture-9-1, horizontal port scan.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the behaviors associated with Hajime in IoT-23. Based on the provided evidence, we have identified the observed network behaviors of Hajime malware infecting an IoT device. The primary objective of this report is to provide a comprehensive understanding of Hajime's behavior in IoT-23 and recommend mitigations to prevent potential attacks.

Threat Analysis

Hajime is a type of malware that infects IoT devices and exhibits various network behaviors. The primary observed behaviors of Hajime in IoT-23 include:

- * PartOfAHorizontalPortScan (6355745 flows)

Evidence Found

Document 1: CTU-IoT-Malware-Capture-9-1 describes Hajime malware infecting an IoT device and exhibits PartOfAHorizontalPortScan behavior.

MITRE ATT&CK Mapping

Based on the observed behavior, we can map Hajime to the following MITRE ATT&CK technique:

- * T1497.002: User Activity Based Checks (Hajime's behavior is similar to the technique of changing behaviors based on the results of checks for the presence of artifacts indicative of a virtual machine environment (VME) or sandbox.)

Related Vulnerabilities

There are no directly related vulnerabilities mentioned in the provided evidence. However, it is essential to note that Hajime's behavior may be related to various vulnerabilities in IoT devices.

Recommended Mitigations

To prevent potential Hajime attacks, we recommend the following mitigations:

1. Implement a robust network monitoring system to detect and prevent PartOfAHorizontalPortScan behavior.
2. Ensure that IoT devices are regularly updated with the latest security patches.
3. Implement a virtual patching solution to prevent exploitation of known vulnerabilities.
4. Conduct regular security audits and vulnerability assessments to identify potential weaknesses.

References

1. Document 1: CTU-IoT-Malware-Capture-9-1
2. Document 7: MITRE ATT&CK technique T1497.002
3. Document 8: MITRE ATT&CK technique T1497

Note: The provided evidence is insufficient to determine the full scope of Hajime's behavior in IoT-23. Further analysis and investigation are required to provide a comprehensive understanding of Hajime's behavior.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides a threat analysis of Hajime in the context of IoT-23 devices. Based on general knowledge and plausible network behaviors, we have identified potential attack steps and related MITRE ATT&CK techniques. However, due to the lack of access to a knowledge base or external information, we cannot verify the exact behaviors exhibited by Hajime in IoT-23 devices or the specific vulnerabilities or exploits used.

Threat Analysis

Hajime is a known IoT malware that has been associated with various attacks in the past. It is likely that Hajime is the threat actor in question. Without further information, it is difficult to pinpoint the exact vulnerability class or exploit used by Hajime, but it is possible that it exploits known vulnerabilities in IoT devices.

Evidence Found

No retrieved KB evidence is available for this analysis. Based on general knowledge and plausible network behaviors, we have identified the following:

- * Initial Reconnaissance: Hajime scans the network for vulnerable IoT devices, likely using a combination of Nmap and Nessus scans.
- * Exploitation: Hajime exploits a known vulnerability in the IoT device, such as CVE-2016-5194 (SambaCry) or CVE-2017-8225 (DLink DIR-645).
- * Persistence: Hajime establishes persistence on the infected device, possibly by modifying system files or registry entries.
- * Communication: Hajime communicates with its command and control (C2) server, likely using a protocol such as HTTP or DNS tunneling.

MITRE ATT&CK Mapping

Based on our analysis, the following MITRE ATT&CK techniques are likely to be used by Hajime:

1. T1190: Exploit Public-Facing Application (guess)
2. T1210: Exploit Vulnerability (guess)
3. T1211: Use Software Vulnerability (guess)
4. T1021: Remote Services (guess)

Related Vulnerabilities

The following vulnerabilities are likely to be exploited by Hajime:

1. CVE-2016-5194 (SambaCry)
2. CVE-2017-8225 (DLink DIR-645)

Recommended Mitigations

To prevent Hajime infections, we recommend the following:

1. Keep IoT devices up-to-date: Ensure that IoT devices are running the latest firmware and software versions.
2. Use strong passwords: Use strong, unique passwords for IoT devices and change them regularly.
3. Implement network segmentation: Segment the network to limit the spread of malware in case of an infection.
4. Use intrusion detection and prevention systems: Implement IDPS to detect and prevent Hajime's network traffic patterns.

References

- * Model knowledge and general references only:
 - + "Hajime: A New IoT Malware" by Malwarebytes
 - + "IoT Security 101" by Cisco
 - + "MITRE ATT&CK Framework" by MITRE

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the behaviors associated with Hajime in IoT-23, a scenario involving Hajime malware infecting an IoT device. The analysis is based on the provided evidence from Document 1, which describes the observed network behaviors of Hajime in IoT-23. The report identifies the threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

Hajime is a malware family that infects IoT devices and exhibits scanning, command-and-control, and denial-of-service activities. In the IoT-23 scenario, Hajime is observed to perform a horizontal port scan, indicating its ability to scan for open ports and potentially exploit vulnerabilities.

Evidence Found

Document 1 provides the primary evidence for this analysis, which states that Hajime in IoT-23 exhibits the following behaviors:

- * PartOfAHorizontalPortScan (6355745 flows)

MITRE ATT&CK Mapping

Based on the observed behaviors, the following MITRE ATT&CK techniques can be mapped:

- * T1055: Network Scanning (PartOfAHorizontalPortScan)

Related Vulnerabilities

While the provided evidence does not directly link Hajime to specific vulnerabilities, the following vulnerabilities are related to IoT devices and could potentially be exploited by Hajime:

- * CVE-2012-2283: Iomega Product EMC Lifeline Vulnerability to read data in firmware
- * CVE-2016-2285: Moxa MiiNePort Cross-site request forgery vulnerability in device product firmware

Recommended Mitigations

To mitigate the risks associated with Hajime in IoT-23, the following recommendations are provided:

1. Implement network segmentation to isolate IoT devices from the rest of the network.
2. Regularly update and patch IoT devices to ensure they have the latest security patches.
3. Implement intrusion detection and prevention systems (IDPS) to detect and block suspicious network traffic.
4. Use secure protocols (e.g., HTTPS, SFTP) for communication between IoT devices and the management interface.
5. Implement a robust incident response plan to quickly respond to and contain potential security incidents.

References

- * Document 1: [IoT23] Hajime — CTU-IoT-Malware-Capture-9-1
- * Document 2: [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1 (for comparison purposes)
- * Document 3: [VARIoT] Telecom Italia Alice Router IP Packet Unauthorized Access Vulnerability
- * Document 4: [VARIoT] U.S.Robotics USR5463 firmware '/cgi-bin/setup_ddns.exe' cross-site request forgery vulnerability
- * Document 5: [VARIoT] plural Iomega Product EMC Lifeline Vulnerability to read data in firmware
- * Document 6: [VARIoT] plural Moxa MiiNePort Cross-site request forgery vulnerability in device product firmware

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the behavior of the Hajime malware in the IoT-23 scenario CTU-IoT-Malware-Capture-9-1. The analysis reveals that Hajime exhibits a horizontal port scan behavior, denoted as PartOfAHorizontalPortScan. This behavior is observed in 635,574 flows out of a total of 6,378,293 flows in the capture.

Threat Analysis

Hajime is a malware family that has been observed in IoT devices. The malware is known to engage in scanning, command-and-control, and denial-of-service activities. In the context of IoT-23, Hajime is observed to perform a horizontal port scan, which is a type of reconnaissance activity. This behavior is indicative of the malware's attempt to identify potential vulnerabilities in the target device.

Evidence Found

The evidence found in the IoT-23 scenario CTU-IoT-Malware-Capture-9-1 indicates that Hajime exhibits the following behavior:

* PartOfAHorizontalPortScan (635,574 flows)

This behavior is observed in the network traffic captured in the scenario.

MITRE ATT&CK Mapping

The observed behavior of Hajime in IoT-23 can be mapped to the following MITRE ATT&CK techniques:

* T1046: Network Service Scanning (PartOfAHorizontalPortScan)

Related Vulnerabilities

The observed behavior of Hajime in IoT-23 is related to the following vulnerabilities:

* None explicitly mentioned in the provided evidence

However, the presence of a horizontal port scan behavior suggests that Hajime may be attempting to identify vulnerabilities in the target device.

Recommended Mitigations

To mitigate the risks associated with Hajime in IoT-23, the following recommendations are made:

1. Implement network segmentation to isolate IoT devices from the rest of the network.
2. Conduct regular vulnerability assessments and penetration testing to identify potential vulnerabilities.
3. Implement intrusion detection and prevention systems to detect and block suspicious network traffic.
4. Ensure that IoT devices are running up-to-date firmware and software.

References

* Document 1: [IoT23] Hajime — CTU-IoT-Malware-Capture-9-1

* Document 3: [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1 (for comparison purposes)

Note: The provided evidence is insufficient to determine the exact nature of the Hajime malware's behavior in IoT-23. However, based on the observed behavior, it is possible to make some inferences about the malware's intentions and potential vulnerabilities.

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 12/24 — q009

Human eval sheet — q009

Category: behaviour

Question

Explain Muhstik behaviour from IoT-23 evidence.

Gold notes (optional reference)

Capture-3-1; port scan / C&C / Attack labels.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the behavior of the Muhstik malware family based on the provided evidence from the IoT-23 scenario CTU-IoT-Malware-Capture-3-1. The analysis reveals that Muhstik exhibits scanning, command-and-control, and denial-of-service activity. The report also maps the observed behavior to the MITRE ATT&CK framework and identifies related vulnerabilities.

Threat Analysis

Muhstik is a malware family that infects IoT devices and exhibits various malicious behaviors, including:

1. Scanning: Muhstik performs horizontal port scanning, which involves scanning a range of ports on a target device to identify open ports.
2. Command-and-Control (C&C): Muhstik communicates with its C&C server to receive instructions and send back data.
3. Denial-of-Service (DoS): Muhstik can be used to launch DoS attacks against targeted devices.

Evidence Found

The provided evidence from the IoT-23 scenario CTU-IoT-Malware-Capture-3-1 reveals the following:

- * 145,597 flows associated with PartOfAHorizontalPortScan
- * 5,962 flows associated with Attack
- * 8 flows associated with C&C
- * The capture contains 156,103 flows, primarily TCP traffic

MITRE ATT&CK Mapping

The observed behavior of Muhstik can be mapped to the following MITRE ATT&CK techniques:

- * T1055: Network Scanning (PartOfAHorizontalPortScan)
- * T1071: Application Layer Protocol: Web Protocols (C&C)
- * T1498: Network Denial of Service (DoS)

Related Vulnerabilities

The provided evidence does not directly relate to specific vulnerabilities. However, the presence of Muhstik malware on an IoT device may indicate a vulnerability in the device's software or configuration.

Recommended Mitigations

To mitigate the risks associated with Muhstik malware, the following recommendations are made:

1. Ensure that IoT devices are running up-to-date software and firmware.
2. Implement robust network segmentation and access controls to limit the spread of malware.
3. Monitor network traffic for suspicious activity, including scanning and C&C communication.
4. Implement intrusion detection and prevention systems (IDPS) to detect and block malicious activity.
5. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.

References

- * [1] CTU-IoT-Malware-Capture-3-1
- * [2] MikroTik RouterBoard v6.38.5 - Denial of Service
- * [3] Eaton ELCSOFT DEV File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * [4] Eaton ELCSOFT LAD File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * [5] Eaton ELCSOFT Project File Parsing Heap-based Buffer Overflow Remote Code Execution Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the behavior of the Muhstik malware family based on the provided evidence from the IoT-23 dataset. The analysis reveals that Muhstik exhibits scanning, command-and-control, and denial-of-service activity when present in IoT devices. The report

provides a detailed breakdown of the observed network behaviors, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

Muhstik is a malware family that targets IoT devices, exhibiting scanning, command-and-control, and denial-of-service activity. The malware is designed to infect IoT devices and use them as part of a botnet for malicious purposes. The observed network behaviors include:

- * PartOfAHorizontalPortScan: Muhstik scans for open ports on IoT devices to identify potential vulnerabilities.
- * Attack: Muhstik launches attacks on IoT devices to compromise their security.
- * C&C: Muhstik establishes command-and-control channels to communicate with its botnet and receive instructions.

Evidence Found

The provided evidence from the IoT-23 dataset reveals that Muhstik malware infects an IoT device and exhibits the following network behaviors:

- * PartOfAHorizontalPortScan (145597 flows)
- * Attack (5962 flows)
- * C&C (8 flows)

The capture contains 156103 flows, primarily TCP traffic, with the most common service being unknown.

MITRE ATT&CK Mapping

Based on the observed network behaviors, the Muhstik malware can be mapped to the following MITRE ATT&CK techniques:

- * T1496.001: Compute Hijacking (Muhstik uses IoT devices as part of a botnet for malicious purposes)
- * S0601: Hildegard (Muhstik targets misconfigured IoT devices for initial access and runs cryptocurrency miner operations)

Related Vulnerabilities

The provided evidence does not explicitly mention any related vulnerabilities. However, the MikroTik RouterBoard v6.38.5 Denial of Service exploit (Document 2 and 3) may be related to the observed network behaviors, as it can be used to compromise IoT devices and make them part of a botnet.

Recommended Mitigations

To mitigate the risks associated with Muhstik malware, the following recommendations are provided:

- * Implement robust security measures on IoT devices, including firewalls, intrusion detection systems, and regular software updates.
- * Use secure communication protocols, such as HTTPS, to prevent eavesdropping and tampering.
- * Regularly monitor network traffic for suspicious activity and implement incident response plans to quickly respond to potential threats.
- * Use anti-malware software to detect and remove Muhstik malware from infected devices.

References

- * IoT-23 dataset
 - * MITRE ATT&CK techniques T1496.001 and S0601
 - * MikroTik RouterBoard v6.38.5 Denial of Service exploit (Document 2 and 3)
- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Muhstik Behavior Analysis from IoT-23 Evidence

1. Executive Summary

This report provides an analysis of Muhstik behavior based on general knowledge and reasoning. Muhstik is a known IoT malware that targets IoT devices, and this report aims to understand its behavior, techniques, and potential vulnerabilities. However, due to the lack of retrieved evidence, this analysis is based on speculation and general knowledge.

2. Threat Analysis

Muhstik is a type of botnet that targets IoT devices, likely exploited by a malicious group seeking to carry out DDoS attacks or data theft. The threat actor behind Muhstik is likely to use various techniques to spread and communicate with its command and control (C2) server.

3. Evidence Found

No retrieved knowledge base evidence is available for this analysis. The following information is based on general knowledge and reasoning:

- * Muhstik might spread through the network by exploiting known vulnerabilities in IoT devices, such as default passwords or outdated firmware.
- * It may establish a connection with its C2 server to receive commands and send back collected data.

- * Muhstik could use common IoT protocols like HTTP, MQTT, or CoAP to communicate with its C2 server.
- * It might also use encryption to evade detection, such as SSL/TLS or custom encryption schemes.
- * Muhstik could potentially use DNS tunneling or other techniques to exfiltrate data from infected devices.

4. MITRE ATT&CK Mapping

Based on the above behaviors, the following MITRE ATT&CK techniques might be employed by Muhstik:

- * T1210 - Exploitation of Remote Services (guess)
- * T1190 - Exploit Public-Facing Application (guess)
- * T1047 - Network Service Scanning (guess)
- * T1071 - Application Layer Protocol: Web Protocols (guess)
- * T1573 - Encrypted Channel: Symmetric Key (guess)

5. Related Vulnerabilities

Some common vulnerabilities in IoT devices that Muhstik might exploit include:

- * CVE-2019-15107: Vulnerability in the HTTP protocol of the Netgear Nighthawk R7000 router.
- * CVE-2018-10561: Vulnerability in the UPnP protocol of various routers.

6. Recommended Mitigations

To mitigate Muhstik and similar IoT malware, consider the following practical measures:

- * Regularly update firmware and software on IoT devices to ensure they have the latest security patches.
- * Use strong, unique passwords for all IoT devices and change them regularly.
- * Implement a network segmentation strategy to isolate IoT devices from other network segments.
- * Use intrusion detection and prevention systems (IDPS) to monitor network traffic for suspicious activity.
- * Regularly scan for vulnerabilities and perform penetration testing on IoT devices.
- * Use encryption and secure communication protocols to protect data in transit.

7. References

This report is based on general knowledge and model knowledge. The following references are provided for further reading:

- * IoT malware analysis: "IoT Malware: A Comprehensive Survey" by [Author], [Year]
- * MITRE ATT&CK framework: "MITRE ATT&CK Framework" by MITRE Corporation, [Year]

* Vulnerability databases: "CVE-2019-15107" and "CVE-2018-10561" on the National Vulnerability Database (NVD) website.

Note: The references provided are for general knowledge and model knowledge only, as no specific evidence was retrieved for this analysis.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the behavior of the Muhstik malware family based on the provided evidence from the IoT-23 dataset. The analysis reveals that Muhstik exhibits scanning, command-and-control, and denial-of-service activity when present in IoT devices. The report also identifies related vulnerabilities and provides recommended mitigations to prevent such attacks.

Threat Analysis

Muhstik is a type of IoT malware that infects devices and uses them to conduct various malicious activities. The provided evidence suggests that Muhstik is capable of:

1. Scanning: Muhstik performs horizontal port scanning, which involves scanning a range of ports on a target device to identify open ports.
2. Command-and-Control (C&C): Muhstik establishes C&C connections with its command center, allowing the attackers to remotely control the infected devices.
3. Denial-of-Service (DoS): Muhstik can be used to conduct DoS attacks, which can overwhelm a target device or network, making it unavailable to users.

Evidence Found

The provided evidence from the IoT-23 dataset includes:

1. Document 1: Muhstik — CTU-IoT-Malware-Capture-3-1, which describes the observed network behaviors of Muhstik, including scanning, C&C, and DoS activity.
2. Document 4: Hide and Seek — CTU-IoT-Malware-Capture-1-1, which provides a comparison with the Hide and Seek malware family, highlighting the similarities in their behavior.

MITRE ATT&CK Mapping

Based on the provided evidence, the Muhstik malware family can be mapped to the following MITRE ATT&CK techniques:

1. T1055: Network Scanning
2. T1071: Application Layer Protocol: Remote File Copy
3. T1210: Exploit Public-Facing Application

Related Vulnerabilities

The provided evidence does not directly link to specific vulnerabilities. However, the MikroTik RouterBoard v6.38.5 Denial of Service vulnerability (Document 3) and the Schneider Electric Accutech Manager Heap Overflow vulnerability (Document 5) are unrelated to the Muhstik malware family.

Recommended Mitigations

To prevent Muhstik and similar IoT malware attacks:

1. Implement robust network segmentation and access controls to limit the spread of malware.
2. Regularly update and patch IoT devices to ensure they have the latest security patches.
3. Use intrusion detection and prevention systems (IDPS) to detect and block suspicious network traffic.
4. Implement a robust incident response plan to quickly respond to and contain malware outbreaks.

References

1. Document 1: Muhstik — CTU-IoT-Malware-Capture-3-1
2. Document 4: Hide and Seek — CTU-IoT-Malware-Capture-1-1
3. Document 3: MikroTik RouterBoard v6.38.5 - Denial of Service
4. Document 5: Schneider Electric Accutech Manager Heap Overflow

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 13/24 — q015

Human eval sheet — q015

Category: vulnerability

Question

What is CVE-2021-25175 and what is the risk?

Gold notes (optional reference)

Siemens JT2Go DXF OOB write RCE.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

A thorough analysis of the provided evidence reveals a potential vulnerability in Siemens JT2Go, identified as CVE-2021-25175. This vulnerability allows remote attackers to execute arbitrary code, potentially leading to a denial of service attack or information tampering. The risk associated with this vulnerability is high, as it can be exploited by remote attackers without requiring user interaction.

Threat Analysis

The threat analysis indicates that the vulnerability can be exploited by remote attackers, allowing them to execute arbitrary code on the affected system. This can lead to a range of potential threats, including:

- * Denial of service (DoS) attacks
- * Information tampering
- * Arbitrary code execution

The vulnerability is classified as a remote code execution vulnerability, which is considered a high-risk threat.

Evidence Found

The evidence found in Document 1 [VARIoT] Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability provides detailed information about the vulnerability, including:

- * CVE: CVE-2021-25175
- * Affected products: Siemens JT2Go

- * Vulnerability type: Remote code execution
- * Potential threats: Denial of service (DoS) attacks, information tampering, arbitrary code execution

MITRE ATT&CK Mapping

The MITRE ATT&CK framework provides a structured approach to threat analysis and mitigation. Based on the evidence found, the following MITRE ATT&CK techniques and tactics can be mapped to the vulnerability:

- * T1190: Exploit Public-Facing Application
- * T1210: Exploit Remote Services
- * T1204: User Execution

Related Vulnerabilities

Several related vulnerabilities have been identified in the provided evidence, including:

- * CVE-2020-3453: Cisco Small Business RV340 Buffer error vulnerability in series routers
- * CVE-2019-13521: Rockwell Automation Arena Simulation Software Vulnerability in
- * CVE-2019-13519: Rockwell Automation Arena Simulation Software Vulnerabilities in type mixing
- * CVE-2018-12153: Intel Multiple vulnerabilities in the product
- * CVE-2021-27251: NETGEAR Nighthawk R7800 Vulnerability in plaintext transmission of important information in

These vulnerabilities share similar characteristics with CVE-2021-25175, including remote code execution and denial of service attacks.

Recommended Mitigations

To mitigate the risk associated with CVE-2021-25175, the following recommendations are provided:

- * Apply the latest security patches and updates for Siemens JT2Go
- * Implement a web application firewall (WAF) to detect and prevent malicious traffic
- * Conduct regular vulnerability scanning and penetration testing to identify and address potential vulnerabilities
- * Implement a secure coding practice to prevent similar vulnerabilities in the future

References

- * Document 1 [VARIoT] Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * Document 2 [VARIoT] Cisco Small Business RV340 Buffer error vulnerability in series routers
- * Document 3 [VARIoT] Rockwell Automation Arena Simulation Software Vulnerability in

- * Document 4 [VARIoT] Intel Multiple vulnerabilities in the product
- * Document 5 [VARIoT] NETGEAR Nighthawk R7800 Vulnerability in plaintext transmission of important information in
- * Document 6 [VARIoT] Rockwell Automation Arena Simulation Software Vulnerabilities in type mixing

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

CVE-2021-25175 Analysis Report

1. Executive Summary

This report provides a speculative analysis of CVE-2021-25175, a software vulnerability reported in 2021. Based on the assumption that CVE-2021-25175 is a software vulnerability, this report outlines the potential threat, plausible network behaviors, and related MITRE ATT&CK techniques. However, due to the lack of specific information, this analysis should be considered speculative and may not accurately reflect the actual vulnerability.

2. Threat Analysis

CVE-2021-25175 is likely a software vulnerability that could be exploited by various threat actors, including nation-state actors, organized crime groups, or hacktivists. The risk associated with this vulnerability could be related to remote code execution, denial-of-service, or information disclosure. The threat analysis is based on the assumption that CVE-2021-25175 is a software vulnerability, and the actual threat may differ.

3. Evidence Found

No retrieved KB evidence is available for this analysis. The following information is based on speculative reasoning only:

- Vulnerability: A software vulnerability, likely related to remote code execution, denial-of-service, or information disclosure.
- Exploit: A malicious request or payload delivered to the vulnerable system.
- Mitigation: Patches, updates, network segmentation, IDPS, SIEM, and user education.

4. MITRE ATT&CK Mapping

Based on the assumption that CVE-2021-25175 is a software vulnerability, the following MITRE ATT&CK techniques are likely related:

- T1059: Command and Control (C2) - This technique is likely related to the C2 channel established by the attacker.

- T1190: Exploit Public-Facing Application - This technique is likely related to the initial contact and exploit delivery steps.
- T1071: Application Layer Protocol: Web Protocols - This technique is likely related to the web request or social engineering attack used to deliver the exploit.

5. Related Vulnerabilities

No related vulnerabilities or CVEs are reasonably sure, so no information is provided.

6. Recommended Mitigations

To mitigate the risk associated with CVE-2021-25175, the following practical steps are recommended:

- Patch Management: Ensure that the vulnerable system is up-to-date with the latest patches and updates.
- Network Segmentation: Segment the network to limit the spread of the exploit and reduce the attack surface.
- Intrusion Detection and Prevention Systems (IDPS): Implement IDPS to detect and prevent suspicious network traffic.
- Security Information and Event Management (SIEM): Implement SIEM to monitor and analyze security-related data and identify potential threats.
- User Education: Educate users about the risks associated with software vulnerabilities and the importance of patching and updating systems regularly.

7. References

This report is based on general knowledge and speculative reasoning. The following references are provided as model knowledge:

- NIST Cybersecurity Framework (CSF)
- MITRE ATT&CK Framework
- OWASP Web Security Testing Guide
- SANS Institute's Security Awareness and Training Program

Please note that this report should be considered speculative and may not accurately reflect the actual vulnerability. A more detailed analysis would require additional information about CVE-2021-25175.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

A vulnerability analysis has been conducted on the provided evidence to identify the CVE-2021-25175 vulnerability and assess its risk. The analysis reveals that CVE-2021-25175 is a remote code execution vulnerability in Siemens JT2Go, which can be exploited by attackers to execute arbitrary code.

Threat Analysis

CVE-2021-25175 is a remote code execution vulnerability in Siemens JT2Go, which can be exploited by attackers to execute arbitrary code. This vulnerability allows remote attackers to cause a crash, potentially enabling a denial of service attack (Crash, Exit, or Restart). The vulnerability is related to illegal type conversion in Open Design Alliance Drawings SDK.

Evidence Found

The evidence found indicates that CVE-2021-25175 is a remote code execution vulnerability in Siemens JT2Go. The vulnerability is related to illegal type conversion in Open Design Alliance Drawings SDK.

MITRE ATT&CK Mapping

The MITRE ATT&CK framework is a comprehensive framework for understanding and classifying cyber attacks. Based on the evidence found, the following MITRE ATT&CK techniques can be mapped to CVE-2021-25175:

- * T1190: Exploit Public-Facing Application
- * T1210: Exploit Remote Services
- * T1212: Exploit Remote Code Execution

Related Vulnerabilities

The provided evidence does not contain any related vulnerabilities to CVE-2021-25175. However, the following vulnerabilities are related to the same product or platform:

- * CVE-2020-9375: Denial of Service (PoC) - Hardware dos Exploit (TP-Link Archer C50 3)
- * CVE-2017-7588: Authentication Bypass / Password Change - Hardware webapps Exploit (Brother MFC-J6520DW)
- * CVE-2021-1167: Denial of Service (PoC) - Hardware webapps Exploit (Cisco RV110W 1.2.1.7)
- * CVE-2012-4335: Multiple Vulnerabilities - Windows dos Exploit (Samsung NET-i ware 1.37)

Recommended Mitigations

To mitigate the risk of CVE-2021-25175, the following recommendations are made:

1. Update Siemens JT2Go to the latest version.
2. Disable or restrict access to Siemens JT2Go.
3. Implement a web application firewall (WAF) to detect and prevent exploitation attempts.

4. Conduct regular vulnerability scans and penetration testing to identify and address potential vulnerabilities.

References

- * Document 1: [VARIoT] Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * Document 2: [VARIoT] TP-Link Archer C50 3 - Denial of Service (PoC) - Hardware dos Exploit
- * Document 3: [VARIoT] Brother MFC-J6520DW - Authentication Bypass / Password Change - Hardware webapps Exploit
- * Document 4: [VARIoT] Cisco RV110W 1.2.1.7 - 'vpn_account' Denial of Service (PoC) - Hardware webapps Exploit
- * Document 5: [VARIoT] Samsung NET-i ware 1.37 - Multiple Vulnerabilities - Windows dos Exploit

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the vulnerability CVE-2021-25175, a Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability. The vulnerability allows remote attackers to execute arbitrary code, potentially leading to a denial of service attack (Crash, Exit, or Restart). The risk associated with this vulnerability is high, as it can be exploited by attackers to gain unauthorized access to the system.

Threat Analysis

The threat analysis indicates that the vulnerability CVE-2021-25175 is a high-risk vulnerability that can be exploited by attackers to gain unauthorized access to the system. The vulnerability allows remote attackers to execute arbitrary code, potentially leading to a denial of service attack (Crash, Exit, or Restart). This can have significant consequences, including data destruction, disruption of service, and unauthorized access to sensitive information.

Evidence Found

The evidence found includes:

- * Document 1: Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability (CVE-2021-25175)
- * Document 3: Brother MFC-J6520DW - Authentication Bypass / Password Change - Hardware webapps Exploit (CVE-2017-7588)
- * Document 4: MITRE ATT&CK technique M1051 - Update Software

- * Document 5: MITRE ATT&CK technique T1499.004 - Application or System Exploitation
- * Document 6: Torii — CTU-IoT-Malware-Capture-21-1
- * Document 7: Mirai — CTU-IoT-Malware-Capture-7-1

MITRE ATT&CK Mapping

The vulnerability CVE-2021-25175 can be mapped to the following MITRE ATT&CK techniques:

- * T1499.004 - Application or System Exploitation
- * M1051 - Update Software

Related Vulnerabilities

The vulnerability CVE-2021-25175 is related to the following vulnerabilities:

- * CVE-2017-7588 - Brother MFC-J6520DW - Authentication Bypass / Password Change - Hardware webapps Exploit
- * CVE-2020-9375 - TP-Link Archer C50 3 - Denial of Service (PoC) - Hardware dos Exploit

Recommended Mitigations

To mitigate the risk associated with the vulnerability CVE-2021-25175, the following recommendations are made:

1. Update the Siemens JT2Go software to the latest version.
2. Implement a patch management solution to ensure that all software is up-to-date.
3. Regularly scan for vulnerabilities and apply patches as soon as they become available.
4. Implement a web application firewall (WAF) to protect against web-based attacks.
5. Implement a network segmentation strategy to isolate vulnerable systems from the rest of the network.

References

- * Document 1: Siemens JT2Go DXF File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability (CVE-2021-25175)
- * Document 3: Brother MFC-J6520DW - Authentication Bypass / Password Change - Hardware webapps Exploit (CVE-2017-7588)
- * Document 4: MITRE ATT&CK technique M1051 - Update Software
- * Document 5: MITRE ATT&CK technique T1499.004 - Application or System Exploitation
- * Document 6: Torii — CTU-IoT-Malware-Capture-21-1
- * Document 7: Mirai — CTU-IoT-Malware-Capture-7-1

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 14/24 — q014

Human eval sheet — q014

Category: vulnerability

Question

Describe the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513.

Gold notes (optional reference)

Out-of-bounds read via DPA file parsing.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report describes the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513, which is a DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability. The vulnerability affects Delta Industrial Automation DOPSoft, Version 4.00.06.15 and prior, and allows remote attackers to execute arbitrary code on affected installations.

Threat Analysis

The vulnerability CVE-2019-13513 is a remote code execution vulnerability that can be exploited by processing a specially crafted project file. This can lead to information disclosure, remote code execution, or crash of the application. The vulnerability is considered high-risk as it allows remote attackers to execute arbitrary code on affected installations.

Evidence Found

The evidence found in Document 1 [VARIoT] Delta Industrial Automation DOPSoft DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability confirms the existence of the vulnerability CVE-2019-13513. The document describes the vulnerability as a DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability that affects Delta Industrial Automation DOPSoft, Version 4.00.06.15 and prior.

MITRE ATT&CK Mapping

The vulnerability CVE-2019-13513 can be mapped to the following MITRE ATT&CK techniques:

* M1016: Vulnerability Scanning (the vulnerability can be identified through vulnerability scanning)

* T1210: Exploitation of Remote Services (the vulnerability can be exploited by processing a specially crafted project file)

Related Vulnerabilities

The vulnerability CVE-2019-13513 is related to other buffer error vulnerabilities in Delta Industrial Automation DOPSoft, including:

* CVE-2018-5476: Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability

* CVE-2018-10617: Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability

Recommended Mitigations

To mitigate the vulnerability CVE-2019-13513, the following measures can be taken:

* Update Delta Industrial Automation DOPSoft to a version that is not affected by the vulnerability

* Implement vulnerability scanning to identify and prioritize remediation efforts

* Use tools like Nessus or OpenVAS to scan endpoints, servers, and applications for missing patches and configuration issues

* Schedule regular scans to ensure timely identification and remediation of vulnerabilities

References

* Document 1 [VARIoT] Delta Industrial Automation DOPSoft DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability

* Document 2 [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability

* Document 3 [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability

* Document 4 [MITRE] Vulnerability Scanning

* Document 5 [MITRE] Exploitation of Remote Services

* Document 6 [IoT23] Torii — CTU-IoT-Malware-Capture-21-1

* Document 7 [IoT23] Hide and Seek — CTU-IoT-Malware-Capture-1-1

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer B

Executive Summary

A vulnerability exists in Delta Industrial Automation DOPSoft, specifically CVE-2019-13513, which is a DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability. This vulnerability allows remote attackers to execute arbitrary code on affected installations of DOPSoft. The vulnerability is caused by the lack of proper validation of user-supplied data, which can lead to out-of-bounds read operations.

Threat Analysis

The threat analysis indicates that the vulnerability can be exploited by remote attackers to execute arbitrary code on affected installations of DOPSoft. The vulnerability is caused by the lack of proper validation of user-supplied data, which can lead to out-of-bounds read operations. This can result in information disclosure, remote code execution, or a crash of the application.

Evidence Found

The evidence found indicates that the vulnerability exists in Delta Industrial Automation DOPSoft, Version 4.00.06.15 and prior. The vulnerability is caused by the lack of proper validation of user-supplied data, which can lead to out-of-bounds read operations.

MITRE ATT&CK Mapping

The MITRE ATT&CK mapping for this vulnerability is:

- * T1059: Command and Control: Remote Services
- * T1190: Exploit Public-Facing Application
- * T1210: Exploit Public-Facing Application

Related Vulnerabilities

The related vulnerabilities are:

- * CVE-2018-5476: Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * CVE-2018-10617: Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * CVE-2020-27275: Delta Industrial Automation DOPSoft XLS File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * CVE-2019-10947: Delta Industrial Automation CNCSoft ScreenEditor DPB File Parsing wMessageLen Stack-based Buffer Overflow Remote Code Execution Vulnerability

Recommended Mitigations

The recommended mitigations are:

- * Update to the latest version of DOPSoft (Version 4.00.06.16 or later)
- * Disable the DPA file parsing functionality
- * Implement input validation and sanitization for user-supplied data
- * Use a web application firewall (WAF) to block malicious traffic

References

- * Document 1: [VARIoT] Delta Industrial Automation DOPSoft DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability
- * Document 2: [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * Document 3: [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * Document 4: [VARIoT] Delta Industrial Automation DOPSoft XLS File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * Document 5: [VARIoT] Delta Industrial Automation COMMGR Buffer error vulnerability
- * Document 6: [VARIoT] Delta Industrial Automation CNCSoft ScreenEditor DPB File Parsing wMessageLen Stack-based Buffer Overflow Remote Code Execution Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Delta Industrial Automation DOPSoft Vulnerability CVE-2019-13513 Analysis Report

Executive Summary:

This report provides a technical analysis of the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513. Based on general knowledge of vulnerabilities and industrial automation systems, we have identified potential threat actors, plausible network behaviors, and recommended mitigations. However, due to the lack of retrieved knowledge base evidence, this analysis is based on reasoning and general knowledge only.

Threat Analysis:

The Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513 is likely to be exploited by malicious individuals or groups seeking to disrupt or gain unauthorized access to industrial control systems. The threat actors may use various techniques, including buffer overflow or remote code execution (RCE), to exploit the vulnerability. The resulting system behavior may include unauthorized access to sensitive data or control of the industrial automation system.

Evidence Found:

No retrieved knowledge base evidence is available for this vulnerability. This analysis is based on general knowledge of vulnerabilities and industrial automation systems, as well as plausible scenarios invented based on that knowledge.

MITRE ATT&CK Mapping:

Based on our general knowledge of vulnerabilities and industrial automation systems, we have identified the following related MITRE ATT&CK techniques:

1. T1210 - Exploit Public-Facing Application (guess)
2. T1204 - User Execution (guess)
3. T1212 - Exploit Remote Services (guess)

Related Vulnerabilities:

Unknown. We do not have any information about related vulnerabilities or CVEs.

Recommended Mitigations:

To prevent or mitigate the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513, we recommend the following:

1. Ensure that the DOPSoft system is running the latest version of the software, which may include patches for the vulnerability.
2. Implement a web application firewall (WAF) to block suspicious traffic to the DOPSoft system.
3. Use a network intrusion detection system (NIDS) to monitor traffic to the DOPSoft system and detect potential exploitation attempts.
4. Implement a vulnerability management program to regularly scan for and patch vulnerabilities in the DOPSoft system.
5. Limit access to the DOPSoft system to only authorized personnel and use role-based access control to restrict access to sensitive areas of the system.

References:

This report is based on general knowledge and model references only. The following references are provided for informational purposes:

- * NIST Cybersecurity Framework (CSF)
- * MITRE ATT&CK Knowledge Base
- * OWASP Web Application Security Testing Guide
- * ICS-CERT Industrial Control Systems Cyber Emergency Response Team

Note: The above analysis is a combination of recalling general knowledge of vulnerabilities and industrial automation systems, as well as inventing plausible scenarios based on that knowledge. We do not have any specific information about the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report describes the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513, which is a DPA file parsing out-of-bounds read remote code execution vulnerability. The vulnerability affects Delta Industrial Automation DOPSoft versions 4.00.06.15 and prior. An attacker can exploit this vulnerability by processing a specially crafted project file, allowing remote code execution, information disclosure, or a crash of the application.

Threat Analysis

The threat analysis of this vulnerability indicates that it is a remote code execution vulnerability, which allows an attacker to execute arbitrary code on the affected system. This type of vulnerability is considered high-risk, as it can be exploited by an attacker to gain unauthorized access to the system or to disrupt the normal operation of the application.

Evidence Found

The evidence found indicates that the vulnerability is caused by an out-of-bounds read vulnerability in the DPA file parsing functionality of Delta Industrial Automation DOPSoft. The vulnerability allows an attacker to read data beyond the bounds of a buffer, which can lead to information disclosure, remote code execution, or a crash of the application.

MITRE ATT&CK Mapping

The MITRE ATT&CK framework is a comprehensive framework for understanding and classifying cyber attacks. Based on the evidence found, the vulnerability CVE-2019-13513 can be mapped to the following ATT&CK techniques:

- * T1190: Exploit Public-Facing Application
- * T1210: Exploit Remote Services
- * T1212: Exploit Use of Out-of-Bounds Write
- * T1213: Exploit Use of Out-of-Bounds Read

Related Vulnerabilities

The following vulnerabilities are related to the Delta Industrial Automation DOPSoft vulnerability CVE-2019-13513:

- * CVE-2018-5476: Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * CVE-2018-10617: Delta Electronics Delta Industrial Automation DOPSoft Buffer error

vulnerability

* CVE-2020-27275: Delta Industrial Automation DOPSoft XLS File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability

These vulnerabilities are also related to the DOPSoft application and can be exploited by an attacker to gain unauthorized access to the system or to disrupt the normal operation of the application.

Recommended Mitigations

To mitigate the vulnerability CVE-2019-13513, the following recommendations are made:

- * Update Delta Industrial Automation DOPSoft to the latest version (version 4.00.06.16 or later)
- * Disable the DPA file parsing functionality if not required
- * Implement a web application firewall (WAF) to detect and prevent exploitation attempts
- * Regularly update and patch the DOPSoft application to ensure that any known vulnerabilities are addressed

References

- * Document 1: [VARIoT] Delta Industrial Automation DOPSoft DPA File Parsing Out-Of-Bounds Read Remote Code Execution Vulnerability
- * Document 2: [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * Document 3: [VARIoT] Delta Electronics Delta Industrial Automation DOPSoft Buffer error vulnerability
- * Document 4: [VARIoT] Delta Industrial Automation DOPSoft XLS File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability
- * Document 5: [VARIoT] Delta Industrial Automation COMMGR Buffer error vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 15/24 — q013

Human eval sheet — q013

Category: vulnerability

Question

What vulnerability is described by CVE-2017-9960?

Gold notes (optional reference)

Schneider Electric U.motion Builder path disclosure.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the vulnerability described by CVE-2017-9960, which is related to Schneider Electric's U.motion Builder software. The vulnerability is an information disclosure issue that allows an unauthenticated user to access sensitive path information, potentially leading to arbitrary code execution.

Threat Analysis

The vulnerability CVE-2017-9960 is an information disclosure issue that can be exploited by an unauthenticated user. This type of vulnerability can lead to further attacks, such as SQL injection or arbitrary code execution, if the attacker can leverage the sensitive path information obtained from the error message.

Evidence Found

Document 1 provides the necessary information about the vulnerability CVE-2017-9960. According to the document, the vulnerability exists in Schneider Electric's U.motion Builder software versions 1.2.1 and prior. The specific flaw exists within externalframe.php, where exception information is returned to the attacker that contains sensitive path information.

MITRE ATT&CK Mapping

The vulnerability CVE-2017-9960 can be mapped to the following MITRE ATT&CK techniques:

- * T1059: Command and Control: The vulnerability allows an attacker to obtain sensitive path information, which can be used to execute arbitrary code on the system.
- * T1068: Exfiltration Over Alternative Protocol: The vulnerability allows an attacker to obtain sensitive information, which can be exfiltrated over an alternative protocol.

Related Vulnerabilities

There are no related vulnerabilities mentioned in the provided evidence.

Recommended Mitigations

To mitigate the vulnerability CVE-2017-9960, the following recommendations are made:

- * Update the U.motion Builder software to a version that is not affected by the vulnerability (version 1.2.1 or later).
- * Implement authentication and authorization mechanisms to restrict access to sensitive information.
- * Monitor system logs for suspicious activity related to the externalframe.php file.

References

- * Document 1: [VARIoT] Schneider Electric U.motion Builder Error Message Path Vulnerability
- * MITRE ATT&CK: Command and Control (T1059) and Exfiltration Over Alternative Protocol (T1068)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides a threat analysis and mitigation recommendations for the vulnerability associated with CVE-2017-9960. Based on a chain-of-thought analysis, the report outlines plausible network behaviors, attack steps, and related MITRE ATT&CK techniques. However, due to the lack of access to a knowledge base or database of known vulnerabilities, the report relies on general information and hypothetical scenarios.

Threat Analysis

CVE-2017-9960 is a vulnerability that was reported in 2017. Based on the year, it is likely that the vulnerability is related to an IoT device or a software component that was widely used at that time. The vulnerability class could be related to a buffer overflow, SQL injection, or another type of input validation error.

Evidence Found

No retrieved KB evidence is available for this report. The analysis is based on general information and hypothetical scenarios.

MITRE ATT&CK Mapping

Based on the hypothetical attack steps outlined above, the following MITRE ATT&CK techniques may be related to CVE-2017-9960:

- T1059: Exploitation of Remote Services (guess)
- T1068: Exploitation of Vulnerability (guess)
- T1071: Application Access (guess)
- T1021: Remote Services (guess)

Related Vulnerabilities

Unfortunately, without access to a knowledge base or database of known vulnerabilities, no related vulnerabilities or CVEs can be provided with confidence.

Recommended Mitigations

To mitigate potential vulnerabilities like CVE-2017-9960, the following practical steps can be taken:

- Keep software up-to-date: Ensure that all software and services are running with the latest patches and updates.
- Implement input validation: Validate all user input to prevent buffer overflows and other input validation errors.
- Use a Web Application Firewall (WAF): A WAF can help detect and prevent common web attacks, including those that exploit vulnerabilities like CVE-2017-9960.
- Conduct regular security audits: Regular security audits can help identify and address potential vulnerabilities before they are exploited.

References

This report relies on general information and hypothetical scenarios. The following references are provided as model knowledge or general references only:

- NIST Cybersecurity Framework (CSF)
- MITRE ATT&CK Framework
- OWASP Web Security Testing Guide
- SANS Institute's Top 20 Critical Security Controls
- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the vulnerability described by CVE-2017-9960, which is an information disclosure vulnerability in Schneider Electric's U.motion Builder software versions 1.2.1 and

prior. The vulnerability allows an unauthenticated user to access sensitive path information, which can be leveraged to execute arbitrary code on the system.

Threat Analysis

The vulnerability described by CVE-2017-9960 is an information disclosure vulnerability, which allows an attacker to access sensitive information that should not be available to an unauthenticated user. This vulnerability can be exploited by an attacker to gain unauthorized access to the system and potentially execute arbitrary code.

Evidence Found

Document 1 [VARIoT] Schneider Electric U.motion Builder Error Message Path Vulnerability describes the vulnerability as follows:

- * CVE: CVE-2017-9960
- * Title: Schneider Electric U.motion Builder Error Message Path Vulnerability
- * Description: An information disclosure vulnerability exists in Schneider Electric's U.motion Builder software versions 1.2.1 and prior in which the system response to error provides more information than should be available to an unauthenticated user.

MITRE ATT&CK Mapping

The vulnerability described by CVE-2017-9960 can be mapped to the following MITRE ATT&CK techniques:

- * T1059: Command and Control: The vulnerability allows an attacker to access sensitive information that can be used to execute arbitrary code on the system.
- * T1047: Windows Service: The vulnerability is related to the processing of externalframe.php, which is exposed on the web service with no authentication.

Related Vulnerabilities

The following vulnerabilities are related to the one described by CVE-2017-9960:

- * CVE-2018-7765: Schneider Electric U.motion Builder track_import_export Remote code execution vulnerability
- * CVE-2018-7769: Schneider Electric U.motion Builder xmlserver Remote code execution vulnerability
- * CVE-2018-7773: Schneider Electric U.motion Builder nfcserver Remote code execution vulnerability

These vulnerabilities are also related to the processing of web services with no authentication, which is a common theme in the exploitation of these vulnerabilities.

Recommended Mitigations

To mitigate the vulnerability described by CVE-2017-9960, the following recommendations are made:

- * Update to a version of U.motion Builder that is not vulnerable to this issue (version 1.3.4 or later).
- * Implement authentication for the web service to prevent unauthenticated access.
- * Validate user input to prevent SQL injection attacks.

References

- * Document 1 [VARIoT] Schneider Electric U.motion Builder Error Message Path Vulnerability
- * Document 2 [VARIoT] Schneider Electric U.motion Builder track_import_export Remote code execution vulnerability
- * Document 3 [VARIoT] Rockwell Automation Arena Simulation Software Vulnerability in
- * Document 4 [VARIoT] Trend Micro Smart Protection Server SQL Injection Vulnerability
- * Document 5 [VARIoT] Schneider Electric U.motion Builder xmlserver Remote code execution vulnerability
- * Document 6 [VARIoT] Schneider Electric U.motion Builder nfcserver Remote code execution vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the vulnerability described by CVE-2017-9960, which is an information disclosure vulnerability in Schneider Electric's U.motion Builder software versions 1.2.1 and prior. The vulnerability allows an unauthenticated user to obtain sensitive path information, which can be leveraged to execute arbitrary code on the system.

Threat Analysis

The vulnerability CVE-2017-9960 is a significant threat as it allows an attacker to obtain sensitive information, which can be used to exploit other vulnerabilities and execute arbitrary code on the system. This vulnerability can be exploited by an unauthenticated user, making it a high-risk threat.

Evidence Found

The evidence found in Document 1 [VARIoT] Schneider Electric U.motion Builder Error Message Path Vulnerability describes the vulnerability CVE-2017-9960. The document states that the vulnerability exists in Schneider Electric's U.motion Builder software versions 1.2.1 and prior, and that it allows an unauthenticated user to obtain sensitive path information.

MITRE ATT&CK Mapping

The vulnerability CVE-2017-9960 can be mapped to the following MITRE ATT&CK techniques:

- * T1588.006: Adversaries may acquire information about vulnerabilities that can be used during targeting.
- * M1016: Vulnerability scanning involves the automated or manual assessment of systems, applications, and networks to identify misconfigurations, unpatched software, or other security weaknesses.

Related Vulnerabilities

The vulnerability CVE-2017-9960 is related to other vulnerabilities that allow an attacker to obtain sensitive information or execute arbitrary code on the system. Some examples of related vulnerabilities include:

- * CVE-2017-6190: D-Link DWR-116 / DWR-116A1 - Arbitrary File Download - Hardware webapps Exploit
- * CVE-2016-10401: ZyXEL PK5001Z Modem - Backdoor Account - Hardware remote Exploit

Recommended Mitigations

To mitigate the vulnerability CVE-2017-9960, the following recommendations are made:

- * Update Schneider Electric's U.motion Builder software to a version that is not affected by the vulnerability.
- * Implement vulnerability scanning to identify and remediate other vulnerabilities in the system.
- * Implement access controls to restrict access to sensitive information and prevent unauthorized users from exploiting the vulnerability.

References

- * Document 1 [VARIoT] Schneider Electric U.motion Builder Error Message Path Vulnerability
- * Document 4 [MITRE] Vulnerabilities
- * Document 5 [MITRE] Vulnerability Scanning

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 16/24 — q017

Human eval sheet — q017

Category: vulnerability

Question

Find IoT/router related authentication vulnerabilities in the knowledge base.

Gold notes (optional reference)

Should surface D-Link or similar router auth issues.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report identifies IoT/router-related authentication vulnerabilities in the knowledge base. The analysis reveals multiple vulnerabilities in various router models from different manufacturers, including NETGEAR, D-Link, and TP-Link. These vulnerabilities allow network-adjacent attackers to bypass authentication and potentially execute arbitrary code on the router.

Threat Analysis

The identified vulnerabilities pose a significant threat to the security of IoT routers. An attacker can exploit these vulnerabilities to gain unauthorized access to the router, execute arbitrary code, and potentially disrupt the operation of the network. The lack of proper authentication mechanisms in these routers makes them vulnerable to attacks from network-adjacent attackers.

Evidence Found

The following vulnerabilities were identified:

1. NETGEAR R7450 Vulnerability (CVE-2020-27872): Allows network-adjacent attackers to bypass authentication on affected installations of NETGEAR R7450 routers.
2. D-Link DAP-1330 Authentication Vulnerabilities (CVE-2020-8861): Allows network-adjacent attackers to bypass authentication on affected installations of D-Link DAP-1330 Wi-Fi range extenders.
3. plural D-Link Authentication Vulnerabilities (CVE-2020-8863): Allows network-adjacent attackers to bypass authentication on affected installations of D-Link DIR-867, DIR-878, and DIR-882 routers.
4. TP-Link AC1750 Authentication Vulnerabilities (CVE-2020-10888): Allows remote attackers to

bypass authentication on affected installations of TP-Link Archer A7 Firmware Ver: 190726 AC1750 routers.

5. plural Cisco Small Business RV Assumed to be Immutable in the Router Web Parameter External Control Vulnerability (CVE-2021-1289): Allows unauthenticated, remote attackers to execute arbitrary code as the root user on an affected device.

6. plural D-Link In the Product SQL Injection Vulnerabilities (CVE-2013-5945): Allows remote attackers to execute arbitrary SQL commands via the password to the login.authenticate function in share/lua/5.1/teamf1lualib/login.lua or captivePortal.lua.

MITRE ATT&CK Mapping

The identified vulnerabilities can be mapped to the following MITRE ATT&CK techniques:

1. T1210 - Exploit Public-Facing Application: The vulnerabilities allow attackers to exploit public-facing applications (e.g., web-based management interfaces) to gain unauthorized access to the router.
2. T1212 - Exploit Remote Services: The vulnerabilities allow attackers to exploit remote services (e.g., SSH port forwarding) to gain unauthorized access to the router.
3. T1213 - Exploit Public-Facing Service: The vulnerabilities allow attackers to exploit public-facing services (e.g., HTTP requests) to gain unauthorized access to the router.

Related Vulnerabilities

The identified vulnerabilities are related to the following vulnerabilities:

1. CVE-2020-27872: A similar vulnerability was identified in the NETGEAR R7000 router (CVE-2020-27873).
2. CVE-2020-8861: A similar vulnerability was identified in the D-Link DIR-890L router (CVE-2020-8862).
3. CVE-2020-10888: A similar vulnerability was identified in the TP-Link Archer C7 router (CVE-2020-10889).

Recommended Mitigations

To mitigate these vulnerabilities, we recommend the following:

1. Update firmware: Ensure that the router firmware is up-to-date with the latest security patches.
2. Change default passwords: Change the default passwords for the router and any connected devices.
3. Enable WPA2 encryption: Enable WPA2 encryption to protect the wireless network.
4. Use a VPN: Use a VPN to encrypt internet traffic and protect against man-in-the-middle attacks.
5. Regularly monitor network activity: Regularly monitor network activity to detect and respond to potential security incidents.

References

1. CVE-2020-27872: NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router
2. CVE-2020-8861: D-Link DAP-1330 Authentication vulnerabilities in
3. CVE-2020-8863: plural D-Link Authentication vulnerabilities in routers
4. CVE-2020-10888: TP-Link AC1750 Authentication vulnerabilities in routers
5. CVE-2021-1289: plural Cisco Small Business RV Assumed to be immutable in the router Web Parameter external control vulnerability
6. CVE-2013-5945: plural D-Link In the product SQL Injection vulnerabilities

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report identifies potential IoT/router-related authentication vulnerabilities based on the provided evidence. The analysis reveals multiple vulnerabilities in various devices, including Netwave IP Camera, D-Link DIR-615, MikroTik RouterBoard, Cisco 7937G, and D-Link DAP-1330. These vulnerabilities can lead to authentication bypass, cross-site request forgery, HTML injection, information disclosure, denial of service, and privilege escalation.

Threat Analysis

The identified vulnerabilities pose a significant threat to the security of IoT devices and networks. An attacker can exploit these vulnerabilities to gain unauthorized access to devices, steal sensitive information, execute arbitrary code, or disrupt network services. The lack of proper authentication mechanisms and handling of cookies in some devices makes them vulnerable to attacks.

Evidence Found

The following evidence was found:

1. Netwave IP Camera: Password disclosure and hardware remote exploit vulnerability (Document 1).
2. D-Link DIR-615: Multiple security vulnerabilities, including authentication-bypass, cross-site request forgery, HTML-injection, and information disclosure vulnerabilities (Document 2).
3. MikroTik RouterBoard: Denial of Service vulnerability (Document 3).
4. Cisco 7937G: DoS/Privilege Escalation vulnerability (Document 4).
5. D-Link DAP-1330: Authentication vulnerabilities, including bypassing authentication and executing arbitrary code (Document 5).

MITRE ATT&CK Mapping

The identified vulnerabilities can be mapped to the following MITRE ATT&CK techniques:

1. T1055: Input Validation (D-Link DIR-615, D-Link DAP-1330)
2. T1190: Exploit Public-Facing Application (Netwave IP Camera, Cisco 7937G)
3. T1210: Exploit Remote Services (MikroTik RouterBoard)
4. T1211: Exploit Public-Facing Application (D-Link DIR-615, D-Link DAP-1330)

Related Vulnerabilities

The identified vulnerabilities are related to the following known vulnerabilities:

1. CVE-2020-8861: D-Link DAP-1330 Authentication vulnerabilities (Document 5)
2. VL-ID 2064: MikroTik RouterBoard v6.38.5 - Denial of Service (Document 3)

Recommended Mitigations

To mitigate these vulnerabilities, the following recommendations are made:

1. Update firmware: Regularly update firmware to the latest version to ensure that known vulnerabilities are patched.
2. Implement strong authentication: Use strong authentication mechanisms, such as two-factor authentication, to prevent unauthorized access.
3. Monitor network traffic: Regularly monitor network traffic to detect and respond to potential attacks.
4. Implement input validation: Implement input validation to prevent malicious input from being processed.
5. Use secure protocols: Use secure protocols, such as HTTPS, to encrypt data in transit.

References

1. Document 1: Netwave IP Camera - Password Disclosure - Hardware remote Exploit
2. Document 2: D-Link DIR-615 Multiple Security Vulnerabilities
3. Document 3: MikroTik RouterBoard v6.38.5 - Denial of Service
4. Document 4: Cisco 7937G - DoS/Privilege Escalation - Hardware remote Exploit
5. Document 5: D-Link DAP-1330 Authentication vulnerabilities in

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report identifies IoT/router-related authentication vulnerabilities based on the provided evidence. The analysis reveals multiple vulnerabilities in various IoT devices, including password disclosure, authentication bypass, and cross-site request forgery. The report also maps these vulnerabilities to the MITRE ATT&CK framework and recommends mitigations to prevent exploitation.

Threat Analysis

The provided evidence suggests that IoT devices are vulnerable to various attacks, including:

1. Password disclosure: The Netwave IP Camera is prone to password disclosure, allowing attackers to gain unauthorized access to the device.
2. Authentication bypass: The D-Link DIR-615 router has an authentication-bypass vulnerability, enabling attackers to bypass authentication mechanisms and access sensitive information.
3. Cross-site request forgery: The D-Link DIR-615 router is also vulnerable to cross-site request forgery, allowing attackers to execute malicious code in the browser of an unsuspecting user.
4. Denial of Service: The MikroTik RouterBoard v6.38.5 is vulnerable to a denial-of-service attack, which can disrupt network services.

Evidence Found

The following evidence was found:

1. Document 1: Netwave IP Camera - Password Disclosure - Hardware remote Exploit
2. Document 2: D-Link DIR-615 Multiple Security Vulnerabilities
3. Document 3: MikroTik RouterBoard v6.38.5 - Denial of Service
4. Document 4: Hide and Seek — CTU-IoT-Malware-Capture-1-1
5. Document 5: MITRE ATT&CK technique T1016.002 - Wi-Fi Discovery
6. Document 6: MITRE ATT&CK technique T1590.006 - Network Security Appliances
7. Document 7: MITRE ATT&CK technique T1557.004 - Evil Twin
8. Document 8: Muhstik — CTU-IoT-Malware-Capture-3-1

MITRE ATT&CK Mapping

The following vulnerabilities were mapped to the MITRE ATT&CK framework:

1. T1016.002 - Wi-Fi Discovery (Document 5)
2. T1590.006 - Network Security Appliances (Document 6)
3. T1557.004 - Evil Twin (Document 7)

Related Vulnerabilities

The following vulnerabilities are related to the identified vulnerabilities:

1. CVE-2017-6361 - D-Link DIR-615 Multiple Security Vulnerabilities (Document 2)
2. CVE-2017-6362 - MikroTik RouterBoard v6.38.5 - Denial of Service (Document 3)

Recommended Mitigations

To prevent exploitation of these vulnerabilities, the following mitigations are recommended:

1. Regularly update firmware and software to ensure the latest security patches are applied.
2. Use strong, unique passwords for all devices and networks.
3. Implement a robust authentication mechanism to prevent authentication bypass.
4. Use a web application firewall (WAF) to prevent cross-site request forgery attacks.
5. Implement a network security appliance to detect and prevent denial-of-service attacks.
6. Use a secure Wi-Fi network and keep the Wi-Fi password confidential.
7. Regularly monitor network traffic and system logs for suspicious activity.

References

1. Document 1: Netwave IP Camera - Password Disclosure - Hardware remote Exploit
2. Document 2: D-Link DIR-615 Multiple Security Vulnerabilities
3. Document 3: MikroTik RouterBoard v6.38.5 - Denial of Service
4. Document 4: Hide and Seek — CTU-IoT-Malware-Capture-1-1
5. Document 5: MITRE ATT&CK technique T1016.002 - Wi-Fi Discovery
6. Document 6: MITRE ATT&CK technique T1590.006 - Network Security Appliances
7. Document 7: MITRE ATT&CK technique T1557.004 - Evil Twin
8. Document 8: Muhstik — CTU-IoT-Malware-Capture-3-1

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer D

IoT/Router Authentication Vulnerabilities Report

Executive Summary

This report identifies potential authentication vulnerabilities related to IoT devices and routers, highlighting the need for robust security measures to prevent exploitation by threat actors. Based on a chain-of-thought analysis, this report outlines the likely threat actors, malware, and vulnerability classes, as well as plausible network behaviours and attack steps. The report also maps related MITRE ATT&CK techniques and identifies potential vulnerabilities and CVEs.

Threat Analysis

Threat actors may include nation-state actors, organized crime groups, or individual hackers seeking to exploit vulnerabilities in IoT devices and routers for financial gain, espionage, or disruption of critical infrastructure. Malware such as Mirai, Reaper, or other IoT-specific malware may be used to exploit these vulnerabilities. Vulnerability classes may include authentication bypass, weak password storage, or session fixation attacks.

Evidence Found

Based on a chain-of-thought analysis, the following evidence types are required to answer this question:

- Behavioural evidence: Patterns of malicious activity or suspicious network traffic related to IoT devices and routers.
- Technique evidence: Methods used by threat actors to exploit authentication vulnerabilities, such as brute-force attacks or phishing.
- Vulnerability evidence: Specific weaknesses in authentication mechanisms, such as buffer overflows or SQL injection vulnerabilities.
- Exploit evidence: Proof of concept or actual exploitation of authentication vulnerabilities.
- Mitigation evidence: Best practices or countermeasures to prevent or mitigate authentication vulnerabilities.

However, without access to a knowledge base, I am uncertain about the specific authentication vulnerabilities present in IoT devices and routers, the types of malware used to exploit these vulnerabilities, and the effectiveness of various mitigation strategies. I also cannot verify the likelihood of specific threat actors or the severity of potential attacks without further information.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are related to this analysis:

1. T1057: Screenshot (guess)
2. T1210: Exploit Public-Facing Application (guess)
3. T1204: User Execution (guess)
4. T1212: Exploit Vulnerability (guess)

Related Vulnerabilities

The following vulnerabilities and CVEs are related to this analysis:

1. CVE-2019-11510: Authentication bypass vulnerability in Netgear routers (inventing)
2. CVE-2018-10561: Weak password storage vulnerability in Linksys routers (inventing)
3. CVE-2017-6079: Session fixation vulnerability in D-Link routers (inventing)

Recommended Mitigations

To prevent or mitigate authentication vulnerabilities in IoT devices and routers, the following best practices are recommended:

1. Use strong, unique passwords: Implement strong password policies and encourage users to use unique passwords for each IoT device and router.
2. Enable two-factor authentication: Implement two-factor authentication mechanisms to

prevent session fixation attacks and brute-force attacks.

3. Regularly update firmware: Regularly update firmware to patch known vulnerabilities and prevent exploitation.

4. Use a VPN: Use a virtual private network (VPN) to encrypt network traffic and prevent eavesdropping.

References

This report is based on general knowledge and model knowledge, and no specific knowledge base evidence was retrieved. The following references are provided for further reading:

- [1] "IoT Security 101" by [Author], [Publication], [Year]
- [2] "MITRE ATT&CK Framework" by MITRE Corporation, [Year]
- [3] "CVE-2019-11510" by [CVE Source], [Year]
- [4] "Weak Password Storage Vulnerability in Linksys Routers" by [Author], [Publication], [Year]

Note: The references provided are fictional and for demonstration purposes only.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 17/24 — q030

Human eval sheet — q030

Category: technique

Question

What network discovery techniques from MITRE could describe IoT botnet scanning?

Gold notes (optional reference)

Network Service Discovery / related discovery techniques.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

IoT Botnet Scanning: Threat Analysis and Mitigation

Executive Summary

This report provides an analysis of IoT botnet scanning techniques and related vulnerabilities. Based on plausible network behaviours and attack steps, we have identified potential MITRE ATT&CK techniques and related vulnerabilities. We also provide practical mitigations to prevent or detect IoT botnet scanning.

Threat Analysis

IoT botnets are typically created by threat actors seeking to exploit vulnerabilities in IoT devices for malicious purposes, such as DDoS attacks or data theft. The malware used in these botnets often targets specific vulnerabilities in IoT devices, such as those related to firmware, network protocols, or authentication mechanisms.

Evidence Found

Based on our analysis, we have not retrieved any knowledge base evidence to support our findings. Our conclusions are based on plausible network behaviours and attack steps, as well as general knowledge of IoT botnets and network discovery techniques.

MITRE ATT&CK Mapping

Based on the plausible network behaviours and attack steps outlined above, the following MITRE ATT&CK techniques may be related to IoT botnet scanning:

- T1059: System Network Scanning (guess)
- T1046: Network Service Scanning (guess)

- T1016: Network Service Discovery (guess)
- T1033: Network Device Fingerprinting (guess)
- T1069: System Fingerprinting (guess)

Related Vulnerabilities

Based on the plausible network behaviours and attack steps outlined above, the following vulnerabilities and CVEs may be related to IoT botnet scanning:

- CVE-2019-15126: Vulnerability in the Realtek SDK for Linux, which allows an attacker to execute arbitrary code (reasonably sure)
- CVE-2018-10561: Vulnerability in the D-Link DIR-645 router, which allows an attacker to execute arbitrary code (reasonably sure)
- CVE-2017-6079: Vulnerability in the Belkin WeMo Insight Smart Plug, which allows an attacker to execute arbitrary code (reasonably sure)

Recommended Mitigations

To mitigate IoT botnet scanning, the following practical measures can be taken:

- Implement Network Segmentation: Segment the network to limit the spread of malware and reduce the attack surface.
- Use Intrusion Detection and Prevention Systems (IDPS): Implement IDPS to detect and prevent network scanning and other malicious activities.
- Use Device Fingerprinting and Vulnerability Scanning: Regularly scan devices for vulnerabilities and use device fingerprinting to identify potential targets.
- Implement Secure Firmware Updates: Regularly update firmware to patch known vulnerabilities and prevent exploitation.
- Use Secure Communication Protocols: Use secure communication protocols, such as HTTPS and SSH, to prevent eavesdropping and tampering.

References

- MITRE ATT&CK: <https://attack.mitre.org/>
- CVE-2019-15126: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=2019-15126>
- CVE-2018-10561: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=2018-10561>
- CVE-2017-6079: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=2017-6079>

Note: The references provided are general knowledge and not specific to the IoT botnet scanning techniques discussed in this report.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the network discovery techniques used by IoT botnets, mapping them to the MITRE ATT&CK framework. Based on the provided evidence, we identified several techniques that could be used by IoT botnets for network discovery. The report highlights the techniques, evidence found, and recommended mitigations to prevent such attacks.

Threat Analysis

IoT botnets are a significant threat to network security, as they can compromise a large number of devices and use them for malicious activities. These botnets often use network discovery techniques to identify potential targets and gather information about the network configuration. The techniques used by IoT botnets can be mapped to the MITRE ATT&CK framework, which provides a comprehensive understanding of the tactics, techniques, and procedures (TTPs) used by adversaries.

Evidence Found

The provided evidence includes several MITRE ATT&CK techniques that could be used by IoT botnets for network discovery:

1. System Network Configuration Discovery (T1016): This technique involves gathering information about the network configuration and settings, such as IP and/or MAC addresses, of systems accessed or discovered remotely.
2. Remote System Discovery (T1018): This technique involves attempting to get a listing of other systems by IP address, hostname, or other logical identifier on a network.
3. System Network Connections Discovery (T1049): This technique involves gathering information about network connections to or from the compromised system.
4. Wi-Fi Discovery (T1016.002): This technique involves searching for information about Wi-Fi networks, such as network names and passwords.
5. Internet Connection Discovery (T1016.001): This technique involves checking for Internet connectivity on compromised systems.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques could describe IoT botnet scanning:

1. T1016: System Network Configuration Discovery
2. T1018: Remote System Discovery
3. T1049: System Network Connections Discovery
4. T1016.002: Wi-Fi Discovery
5. T1016.001: Internet Connection Discovery

Related Vulnerabilities

The provided evidence also includes a vulnerability in Cisco Prime Collaboration Provisioning Software (CVE-2017-6636), which could allow an attacker to view any file on an affected system. This vulnerability could be exploited by an IoT botnet to gather sensitive information about the network configuration.

Recommended Mitigations

To prevent IoT botnet scanning, the following mitigations are recommended:

1. Implement network segmentation: Segment the network to limit the spread of malware and prevent lateral movement.
2. Use strong access controls: Implement role-based access controls (RBACs) to restrict access to sensitive information and prevent unauthorized access.
3. Monitor network traffic: Monitor network traffic for suspicious activity and implement intrusion detection systems (IDS) to detect and prevent attacks.
4. Keep software up-to-date: Regularly update software and firmware to prevent exploitation of known vulnerabilities.
5. Implement Wi-Fi security: Implement Wi-Fi security measures, such as WPA2 encryption and MAC address filtering, to prevent unauthorized access to Wi-Fi networks.

References

1. MITRE ATT&CK framework
2. Cisco Prime Collaboration Provisioning Software Web Path traversal vulnerability in the interface (CVE-2017-6636)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the network discovery techniques used by IoT botnets, specifically focusing on the scanning behavior of Hide and Seek, Kenjiro, and Muhstik malware families. The analysis is based on the provided evidence from MITRE and IoT23 datasets. The report identifies the relevant MITRE ATT&CK techniques, related vulnerabilities, and recommends mitigations to prevent IoT botnet scanning.

Threat Analysis

The provided evidence suggests that IoT botnets, such as Hide and Seek, Kenjiro, and Muhstik, employ network discovery techniques to scan for vulnerable devices. These techniques include:

1. PartOfAHorizontalPortScan: This technique is used by Hide and Seek, Kenjiro, and Muhstik to scan for open ports on potential targets.
2. Remote System Discovery: This technique is used by Hide and Seek, Kenjiro, and Muhstik to discover other systems on the network.

Evidence Found

The evidence from IoT23 datasets (Documents 4, 5, and 6) shows that these malware families exhibit scanning behavior, including:

- * Hide and Seek: PartOfAHorizontalPortScan (539465 flows)
- * Kenjiro: PartOfAHorizontalPortScan (27311187 flows)
- * Muhstik: PartOfAHorizontalPortScan (145597 flows)

MITRE ATT&CK Mapping

Based on the evidence, the following MITRE ATT&CK techniques are relevant:

1. T1016.001: Internet Connection Discovery: This technique is used by Hide and Seek, Kenjiro, and Muhstik to check for Internet connectivity on compromised systems.
2. T1016: System Network Configuration Discovery: This technique is used by Hide and Seek, Kenjiro, and Muhstik to gather information about the network configuration and settings.
3. T1018: Remote System Discovery: This technique is used by Hide and Seek, Kenjiro, and Muhstik to discover other systems on the network.

Related Vulnerabilities

The provided evidence does not explicitly mention specific vulnerabilities. However, the scanning behavior exhibited by Hide and Seek, Kenjiro, and Muhstik suggests that they may be exploiting vulnerabilities in IoT devices.

Recommended Mitigations

To prevent IoT botnet scanning, the following mitigations are recommended:

1. Implement a robust network segmentation strategy: Segment the network to limit the spread of malware and prevent lateral movement.
2. Use a web application firewall (WAF): A WAF can help block malicious traffic and prevent scanning behavior.
3. Implement an intrusion detection system (IDS): An IDS can help detect and prevent scanning behavior.
4. Keep software up-to-date: Ensure that all software, including IoT devices, is up-to-date with the latest security patches.
5. Use a secure communication protocol: Use a secure communication protocol, such as HTTPS, to encrypt communication between devices.

References

- * MITRE ATT&CK: <https://attack.mitre.org/>
- * IoT23: <https://www.iot23.org/>
- * VARIOt: <https://www.variot.org/>

Note: The provided evidence is insufficient to determine the specific vulnerabilities exploited by Hide and Seek, Kenjiro, and Muhstik. Further analysis is required to identify the underlying vulnerabilities.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes network discovery techniques from MITRE that could describe IoT botnet scanning. The analysis reveals that several techniques from MITRE ATT&CK can be used to describe IoT botnet scanning, including Internet Connection Discovery, System Network Configuration Discovery, Remote System Discovery, System Network Connections Discovery, and Wi-Fi Discovery.

Threat Analysis

IoT botnets are a type of malware that infects and controls IoT devices, often for malicious purposes such as DDoS attacks or data theft. IoT botnets typically use network discovery techniques to scan for and identify vulnerable devices on a network. The techniques used by IoT botnets can be mapped to several MITRE ATT&CK techniques, including:

- * Internet Connection Discovery (T1016.001): IoT botnets may use this technique to determine if a device is connected to the internet and can communicate with their C2 servers.
- * System Network Configuration Discovery (T1016): IoT botnets may use this technique to gather information about the network configuration and settings of a device, such as IP and/or MAC addresses.
- * Remote System Discovery (T1018): IoT botnets may use this technique to scan for and identify other devices on a network.
- * System Network Connections Discovery (T1049): IoT botnets may use this technique to gather information about network connections to or from a device.
- * Wi-Fi Discovery (T1016.002): IoT botnets may use this technique to gather information about Wi-Fi networks, such as network names and passwords.

Evidence Found

The evidence found in the provided documents suggests that IoT botnets may use various network discovery techniques to scan for and identify vulnerable devices on a network. The techniques used by IoT botnets can be mapped to several MITRE ATT&CK techniques, including:

- * Internet Connection Discovery (T1016.001)
- * System Network Configuration Discovery (T1016)
- * Remote System Discovery (T1018)
- * System Network Connections Discovery (T1049)
- * Wi-Fi Discovery (T1016.002)

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques can be used to describe IoT botnet scanning:

- * T1016.001: Internet Connection Discovery
- * T1016: System Network Configuration Discovery
- * T1018: Remote System Discovery
- * T1049: System Network Connections Discovery
- * T1016.002: Wi-Fi Discovery

Related Vulnerabilities

The following vulnerabilities may be related to IoT botnet scanning:

- * CVE-2019-11815: A vulnerability in the Linux kernel that allows an attacker to scan for and identify vulnerable devices on a network.
- * CVE-2020-1472: A vulnerability in the Windows operating system that allows an attacker to scan for and identify vulnerable devices on a network.

Recommended Mitigations

To mitigate IoT botnet scanning, the following recommendations can be made:

- * Implement network segmentation to limit the spread of malware.
- * Use firewalls and intrusion detection systems to block suspicious traffic.
- * Implement secure communication protocols, such as TLS, to encrypt communication between devices.
- * Regularly update and patch devices to prevent exploitation of known vulnerabilities.
- * Use network discovery and scanning tools to identify and isolate vulnerable devices.

References

- * MITRE ATT&CK: Internet Connection Discovery (T1016.001)
- * MITRE ATT&CK: System Network Configuration Discovery (T1016)
- * MITRE ATT&CK: Remote System Discovery (T1018)
- * MITRE ATT&CK: System Network Connections Discovery (T1049)

- * MITRE ATT&CK: Wi-Fi Discovery (T1016.002)
- * CVE-2019-11815: Linux kernel vulnerability
- * CVE-2020-1472: Windows operating system vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 18/24 — q029

Human eval sheet — q029

Category: technique

Question

Explain Unsecured Credentials in the context of IoT device hardening.

Gold notes (optional reference)

Technique plus defensive implications.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Unsecured Credentials in IoT Device Hardening: A Threat Analysis

Executive Summary

This report provides a threat analysis of unsecured credentials in the context of IoT device hardening. The analysis identifies the risks associated with unsecured credentials, likely threat actors, and plausible network behaviours. The report also provides recommended mitigations to harden IoT devices and protect against unsecured credentials.

Threat Analysis

Unsecured credentials in IoT devices pose a significant security risk, allowing malicious individuals or groups to gain unauthorized access to sensitive data or modify device configurations. The likely threat actors are malicious individuals or groups seeking to exploit unsecured credentials using malware such as password crackers or keyloggers. The vulnerability class is related to authentication and authorization, specifically the use of weak or default passwords.

Evidence Found (Reasoning-Only)

Based on general knowledge and reasoning, the following evidence types are needed to investigate this issue:

- * Behaviour: Observations of IoT devices exhibiting suspicious login attempts or unauthorized access.
- * Technique: Identification of malware or tools used to exploit unsecured credentials.
- * Vulnerability: Documentation of the specific authentication and authorization vulnerabilities present in the IoT devices.
- * Exploit: Evidence of the exploitation of these vulnerabilities, such as login attempts or access

to sensitive data.

* Mitigation: Information on the measures taken to harden the IoT devices and protect against unsecured credentials.

However, without access to a knowledge base or additional information, I am unable to provide specific evidence related to this issue.

MITRE ATT&CK Mapping

Based on general knowledge and reasoning, the following MITRE ATT&CK techniques are related to this issue:

1. T1210 - Exploitation of Remote Services (guess)
2. T1208 - Data Encoding (guess)
3. T1212 - Exploitation of Phased Vulnerabilities (guess)
4. T1204 - User Execution (guess)

Please note that these techniques are guesses, and the actual techniques used by attackers may differ.

Related Vulnerabilities

Unfortunately, without access to a knowledge base or additional information, I am unable to identify specific vulnerabilities or CVEs related to unsecured credentials in IoT devices.

Recommended Mitigations

To harden IoT devices and protect against unsecured credentials, the following mitigations are recommended:

1. Implement strong password policies, including password rotation and complexity requirements.
2. Use multi-factor authentication (MFA) to add an additional layer of security.
3. Regularly update and patch IoT device firmware to ensure the latest security patches are applied.
4. Use secure communication protocols, such as HTTPS or SSH, to encrypt data in transit.
5. Monitor IoT device logs for suspicious activity and implement anomaly detection to identify potential security incidents.

References

This report is based on general knowledge and reasoning, and the references provided are model knowledge and general references only:

* NIST Special Publication 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations"

- * MITRE ATT&CK, "Adversarial Tactics, Techniques, and Common Knowledge"
- * OWASP, "Internet of Things (IoT) Security Project"
- * IETF, "Internet of Things (IoT) Security Considerations"

Please note that this report is a reasoning-only analysis, and the information provided is based on general knowledge and assumptions.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the threat of Unsecured Credentials in the context of IoT device hardening. The analysis reveals that adversaries may exploit vulnerabilities in IoT devices to obtain sensitive information, including credentials. The report highlights the importance of securing credentials and implementing robust authentication mechanisms to prevent unauthorized access.

Threat Analysis

The threat of Unsecured Credentials in IoT devices is a significant concern, as it allows adversaries to gain unauthorized access to sensitive information. Adversaries may exploit vulnerabilities in IoT devices to obtain credentials, which can be used to gain access to the device or the network. The analysis reveals that adversaries may use various techniques, including:

- * Exploiting software vulnerabilities to collect credentials
- * Searching for and obtaining insecurely stored credentials
- * Compromising network devices' encryption capability to bypass encryption

Evidence Found

The evidence found in the provided documents suggests that IoT devices are vulnerable to Unsecured Credentials attacks. Specifically:

- * Document 2 [MITRE] Unsecured Credentials reveals that adversaries may search compromised systems to find and obtain insecurely stored credentials.
- * Document 3 [MITRE] Exploitation for Credential Access highlights the importance of securing credentials and authentication mechanisms to prevent unauthorized access.
- * Document 5 [VARIoT] NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router reveals a vulnerability in the NETGEAR R7450 router that allows network-adjacent attackers to bypass authentication.
- * Document 6 [VARIoT] (0Day) NETGEAR AC1200 mini_httpd Cleartext Transmission of Sensitive

Information Information Disclosure Vulnerability reveals a vulnerability in the NETGEAR AC1200 router that allows network-adjacent attackers to disclose sensitive information.

MITRE ATT&CK Mapping

The evidence found in the provided documents can be mapped to the following MITRE ATT&CK techniques:

- * T1552: Unsecured Credentials
- * T1212: Exploitation for Credential Access
- * T1600: Weaken Encryption

Related Vulnerabilities

The evidence found in the provided documents reveals several related vulnerabilities, including:

- * CVE-2020-27872: NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router
- * (0Day) NETGEAR AC1200 mini_httpd Cleartext Transmission of Sensitive Information Information Disclosure Vulnerability

Recommended Mitigations

To mitigate the threat of Unsecured Credentials in IoT devices, the following recommendations are made:

- * Implement robust authentication mechanisms, including multi-factor authentication
- * Securely store credentials, using techniques such as encryption and secure storage
- * Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities
- * Implement network segmentation and access controls to limit the spread of unauthorized access

References

- * [MITRE] Network Device Authentication
- * [MITRE] Unsecured Credentials
- * [MITRE] Exploitation for Credential Access
- * [MITRE] Weaken Encryption
- * [VARIoT] NETGEAR R7450 Vulnerability in leaking resources to incorrect area in router
- * [VARIoT] (0Day) NETGEAR AC1200 mini_httpd Cleartext Transmission of Sensitive Information Information Disclosure Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report highlights the threat of Unsecured Credentials in the context of IoT device hardening. The analysis reveals that adversaries can exploit insecurely stored credentials, software vulnerabilities, and compromised network devices to gain unauthorized access to IoT systems. The report provides evidence of password disclosure, hardware remote exploits, and weakened encryption, which can be used to bypass native authentication mechanisms and encryption.

Threat Analysis

The threat of Unsecured Credentials in IoT devices is a significant concern. Adversaries can exploit various techniques to obtain sensitive information, including:

1. Searching for compromised systems to find and obtain insecurely stored credentials.
2. Exploiting software vulnerabilities to collect credentials.
3. Compromising network devices' encryption capability to bypass encryption.

Evidence Found

The provided evidence includes:

1. Document 1: Unsecured Credentials (MITRE ATT&CK technique T1552) - Adversaries may search compromised systems to find and obtain insecurely stored credentials.
2. Document 2: Exploitation for Credential Access (MITRE ATT&CK technique T1212) - Adversaries may exploit software vulnerabilities to collect credentials.
3. Document 3: Netwave IP Camera - Password Disclosure - Hardware remote Exploit - A remote exploit for Hardware platform, which discloses passwords.
4. Document 4: Network Device Authentication (MITRE ATT&CK technique T1556.004) - Adversaries may hard code a password in the operating system to bypass native authentication mechanisms.
5. Document 5: Weaken Encryption (MITRE ATT&CK technique T1600) - Adversaries can compromise a network device's encryption capability to bypass encryption.

MITRE ATT&CK Mapping

The provided evidence maps to the following MITRE ATT&CK techniques:

1. T1552: Unsecured Credentials
2. T1212: Exploitation for Credential Access
3. T1556.004: Network Device Authentication
4. T1600: Weaken Encryption

Related Vulnerabilities

The provided evidence is related to the following vulnerabilities:

1. MS14-068: Exploits Kerberos and can be used to forge Kerberos tickets using domain users.
2. Netwave IP Camera - Password Disclosure - Hardware remote Exploit: A remote exploit for Hardware platform, which discloses passwords.

Recommended Mitigations

To mitigate the threat of Unsecured Credentials in IoT devices, the following recommendations are provided:

1. Implement secure credential storage practices, such as using encrypted files or secure key stores.
2. Regularly update and patch software to prevent exploitation of vulnerabilities.
3. Use strong authentication mechanisms, such as multi-factor authentication, to prevent unauthorized access.
4. Implement encryption to protect data communications and prevent adversaries from compromising encryption.
5. Regularly monitor and audit IoT devices for signs of compromise or unauthorized access.

References

1. MITRE ATT&CK: Unsecured Credentials (T1552)
2. MITRE ATT&CK: Exploitation for Credential Access (T1212)
3. MITRE ATT&CK: Network Device Authentication (T1556.004)
4. MITRE ATT&CK: Weaken Encryption (T1600)
5. VARIOt: Netwave IP Camera - Password Disclosure - Hardware remote Exploit

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer D

Executive Summary

This report highlights the importance of securing credentials in IoT devices to prevent unauthorized access and potential exploitation by adversaries. The evidence provided showcases various techniques used by adversaries to obtain and exploit unsecured credentials, including searching compromised systems, exploiting software vulnerabilities, and using hardcoded passwords. This report aims to provide a comprehensive analysis of the threat and recommend mitigations to harden IoT devices against such attacks.

Threat Analysis

The provided evidence indicates that adversaries may use various techniques to obtain and exploit unsecured credentials in IoT devices. These techniques include:

1. Searching compromised systems for insecurely stored credentials (MITRE ATT&CK technique T1552).
2. Exploiting software vulnerabilities to collect credentials (MITRE ATT&CK technique T1212).
3. Using hardcoded passwords in network devices (MITRE ATT&CK technique T1556.004).
4. Exploiting vulnerabilities in IoT devices, such as password disclosure and hardware remote exploits (Document 3).

Evidence Found

The evidence found includes:

1. Unsecured credentials stored in plaintext files, operating system or application-specific repositories, or other specialized files/artifacts (Document 1).
2. Exploitation of software vulnerabilities to collect credentials (Document 2).
3. Hardcoded passwords in network devices (Document 4).
4. Vulnerabilities in IoT devices, such as password disclosure and hardware remote exploits (Document 3).
5. Malware families, such as Hide and Seek and Hajime, which can infect IoT devices and exploit unsecured credentials (Documents 7 and 8).

MITRE ATT&CK Mapping

The evidence found can be mapped to the following MITRE ATT&CK techniques:

1. T1552 - Unsecured Credentials
2. T1212 - Exploitation for Credential Access
3. T1556.004 - Network Device Authentication

Related Vulnerabilities

The evidence found is related to the following vulnerabilities:

1. CVE-2017-9957 - Schneider Electric U.motion Builder Software Vulnerabilities related to the use of hard-coded credentials (Document 5).
2. Schneider Electric ETG3000 FactoryCast HMI Gateway Authentication Bypass Vulnerability (Document 6).

Recommended Mitigations

To harden IoT devices against attacks that exploit unsecured credentials, the following mitigations are recommended:

1. Implement secure credential storage practices, such as using encrypted files or secure key stores.
2. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
3. Use secure authentication mechanisms, such as multi-factor authentication, to prevent unauthorized access.
4. Monitor network traffic and system logs for suspicious activity.
5. Implement a vulnerability management program to identify and remediate vulnerabilities in IoT devices.

References

1. MITRE ATT&CK - Unsecured Credentials (T1552)
2. MITRE ATT&CK - Exploitation for Credential Access (T1212)
3. MITRE ATT&CK - Network Device Authentication (T1556.004)
4. Document 1 - MITRE - Unsecured Credentials
5. Document 2 - MITRE - Exploitation for Credential Access
6. Document 3 - VARIOt - Netwave IP Camera - Password Disclosure - Hardware remote Exploit
7. Document 4 - MITRE - Network Device Authentication
8. Document 5 - VARIOt - Schneider Electric U.motion Builder Software Vulnerabilities related to the use of hard-coded credentials
9. Document 6 - VARIOt - Schneider Electric ETG3000 FactoryCast HMI Gateway Authentication Bypass Vulnerability
10. Document 7 - IoT23 - Hide and Seek — CTU-IoT-Malware-Capture-1-1
11. Document 8 - IoT23 - Hajime — CTU-IoT-Malware-Capture-9-1

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 19/24 — q021

Human eval sheet — q021

Category: technique

Question

What does MITRE say about Exploit Public-Facing Application?

Gold notes (optional reference)

Technique description and relevance to internet-exposed services.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the MITRE ATT&CK technique T1190, Exploit Public-Facing Application, and provides insights into the related vulnerabilities and recommended mitigations. The analysis is based on the provided evidence from various MITRE documents and a vulnerability report from VARIOt.

Threat Analysis

The Exploit Public-Facing Application technique involves adversaries attempting to exploit weaknesses in Internet-facing hosts or systems to gain initial access to a network. This can be achieved through various means, including software bugs, temporary glitches, or misconfigurations. The adversaries may exploit applications such as websites/web servers, databases, standard services, or network device administration and management protocols.

Evidence Found

The provided evidence includes:

1. Document 1: MITRE ATT&CK technique T1190, Exploit Public-Facing Application Mitigation, which provides guidance on mitigating the impact of an exploit.
2. Document 2: MITRE ATT&CK technique T1190, Exploit Public-Facing Application, which describes the technique and its various forms.
3. Document 3: MITRE ATT&CK technique T1189, Drive-by Compromise, which discusses the delivery of exploit code to a browser through various means.
4. Document 4: MITRE ATT&CK technique T1587.004, Exploits, which describes the development of exploits by adversaries.
5. Document 5: MITRE ATT&CK technique T1203, Exploitation for Client Execution, which discusses the exploitation of software vulnerabilities in client applications.

6. Document 6: VARIOt vulnerability report, which describes a remote code execution vulnerability in Eaton ELCSOft.

MITRE ATT&CK Mapping

The provided evidence maps to the following MITRE ATT&CK techniques:

1. T1190: Exploit Public-Facing Application
2. T1189: Drive-by Compromise
3. T1587.004: Exploits
4. T1203: Exploitation for Client Execution

Related Vulnerabilities

The provided evidence includes a vulnerability report from VARIOt, which describes a remote code execution vulnerability in Eaton ELCSOft.

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended:

1. Implement application isolation and least privilege for service accounts to limit the impact of an exploit.
2. Use secure coding best practices when designing custom software.
3. Segment externally facing servers and services from the rest of the network with a DMZ or on separate hosting infrastructure.
4. Use Web Application Firewalls to limit exposure of applications.
5. Regularly update and patch software to prevent exploitation of known vulnerabilities.
6. Implement a robust vulnerability management program to identify and remediate vulnerabilities in a timely manner.

References

1. MITRE ATT&CK technique T1190: Exploit Public-Facing Application
2. MITRE ATT&CK technique T1189: Drive-by Compromise
3. MITRE ATT&CK technique T1587.004: Exploits
4. MITRE ATT&CK technique T1203: Exploitation for Client Execution
5. VARIOt vulnerability report: (0Day) Eaton ELCSOft EPC File Parsing Out-Of-Bounds Access Remote Code Execution Vulnerability

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides an analysis of the Exploit Public-Facing Application (T1190) technique as described by MITRE ATT&CK. The technique involves exploiting weaknesses in Internet-facing hosts or systems to gain initial access to a network. The analysis includes evidence from various sources, including MITRE documents, vulnerability reports, and IoT malware captures. The report provides a threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

The Exploit Public-Facing Application technique is a high-risk threat that can be used by adversaries to gain initial access to a network. This technique can be used to exploit weaknesses in various types of systems, including websites/web servers, databases, standard services, and network device administration and management protocols. The technique can be used to execute arbitrary code, leading to unauthorized access, data theft, or other malicious activities.

Evidence Found

The evidence found includes:

- * Document 1: MITRE ATT&CK technique T1190, which describes the Exploit Public-Facing Application technique.
- * Document 2: MITRE ATT&CK technique T1190 Mitigation, which provides recommendations for mitigating the Exploit Public-Facing Application technique.
- * Document 4: A vulnerability report describing a remote code execution vulnerability in Eaton ELCSOFT.
- * Document 5: A vulnerability report describing a remote command execution vulnerability in Netgear DGN2200v1.
- * Document 6: A vulnerability report describing a backdoor account vulnerability in WePresent WiPG-1500.
- * Document 7: An IoT malware capture describing the Hide and Seek malware infecting an IoT device.
- * Document 8: An IoT malware capture describing the Kenjiro malware infecting an IoT device.

MITRE ATT&CK Mapping

The Exploit Public-Facing Application technique is mapped to MITRE ATT&CK technique T1190.

Related Vulnerabilities

The following vulnerabilities are related to the Exploit Public-Facing Application technique:

- * Eaton ELCSOFT DEV File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability (Document 4)
- * Netgear DGN2200v1 - Remote Command Execution (RCE) (Unauthenticated) - Hardware

webapps Exploit (Document 5)

* WePresent WiPG-1500 - Backdoor Account - Hardware remote Exploit (Document 6)

Recommended Mitigations

The following mitigations are recommended to prevent the Exploit Public-Facing Application technique:

- * Implement secure coding best practices when designing custom software that is meant for deployment to externally facing systems.
- * Use web application firewalls to limit exposure of applications.
- * Segment externally facing servers and services from the rest of the network with a DMZ or on separate hosting infrastructure.
- * Use least privilege for service accounts to limit what permissions the exploited process gets on the rest of the system.
- * Regularly update and patch systems to prevent exploitation of known vulnerabilities.

References

- * MITRE ATT&CK technique T1190: Exploit Public-Facing Application
- * MITRE ATT&CK technique T1190 Mitigation: Exploit Public-Facing Application Mitigation
- * Eaton ELCSOFT DEV File Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability (Document 4)
- * Netgear DGN2200v1 - Remote Command Execution (RCE) (Unauthenticated) - Hardware webapps Exploit (Document 5)
- * WePresent WiPG-1500 - Backdoor Account - Hardware remote Exploit (Document 6)
- * Hide and Seek — CTU-IoT-Malware-Capture-1-1 (Document 7)
- * Kenjiro — CTU-IoT-Malware-Capture-17-1 (Document 8)

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer C

Executive Summary

This report provides an analysis of the Exploit Public-Facing Application technique, as described by MITRE. Based on my understanding of this technique, I have identified plausible network behaviors, related MITRE ATT&CK techniques, and practical mitigations to prevent exploitation.

Threat Analysis

The Exploit Public-Facing Application technique involves exploiting vulnerabilities in publicly accessible applications to gain unauthorized access to a system or network. Threat actors who might use this technique are likely to be malicious actors seeking to gain unauthorized access to

systems or networks. They may use various malware, such as web shells or remote access trojans (RATs), to exploit vulnerabilities in public-facing applications.

Evidence Found

No retrieved KB evidence; reasoning-only. Based on my analysis, I have identified the following evidence types:

- Behaviour: Network traffic logs or system logs showing suspicious activity related to the exploitation of a public-facing application.
- Technique: Documentation or reports from MITRE or other sources detailing the Exploit Public-Facing Application technique.
- Vulnerability: Information about the specific vulnerability being exploited, such as a CVE (Common Vulnerabilities and Exposures) entry.
- Exploit: Details about the exploit used, such as the exploit code or a description of how it works.
- Mitigation: Information on how to prevent or mitigate this type of attack, such as patching vulnerable applications or implementing web application firewalls (WAFs).

MITRE ATT&CK Mapping

Based on my knowledge of the Exploit Public-Facing Application technique, related MITRE ATT&CK techniques might include:

- T1190: Exploit Public-Facing Application (this is the technique we are analyzing)
- T1210: Exploit Remote Services
- T1204: User Execution
- T1212: Exploit Public-Facing Application (guess, as this technique is similar)

Related Vulnerabilities

Based on my knowledge, related vulnerabilities or CVEs might include:

- CVE-2021-44228: Apache Log4j Remote Code Execution Vulnerability (this is a plausible example, but I'm not certain if it's related to the Exploit Public-Facing Application technique)
- Unknown: I'm not aware of any specific vulnerabilities or CVEs that are commonly exploited through this technique.

Recommended Mitigations

To mitigate the Exploit Public-Facing Application technique, practical steps might include:

- Regularly update and patch public-facing applications to prevent exploitation of known vulnerabilities.
- Implement web application firewalls (WAFs) to detect and prevent suspicious activity.
- Use secure coding practices to prevent vulnerabilities in public-facing applications.

- Monitor network traffic and system logs for suspicious activity related to public-facing applications.
- Implement a vulnerability management program to identify and remediate vulnerabilities in public-facing applications.

References

- MITRE ATT&CK: <https://attack.mitre.org/wiki/> (model knowledge)
- CVE-2021-44228: Apache Log4j Remote Code Execution Vulnerability: <https://nvd.nist.gov/vuln/detail/CVE-2021-44228> (general reference)
- OWASP: Web Application Security: <https://owasp.org/www-project-web-security-testing-guide/> (general reference)
- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report provides an analysis of the MITRE ATT&CK technique T1190, Exploit Public-Facing Application. The technique involves adversaries exploiting a weakness in an Internet-facing host or system to initially access a network. The report summarizes the threat analysis, evidence found, MITRE ATT&CK mapping, related vulnerabilities, and recommended mitigations.

Threat Analysis

The Exploit Public-Facing Application technique is a common tactic used by adversaries to gain initial access to a network. This technique can be used to exploit software bugs, temporary glitches, or misconfigurations in Internet-facing hosts or systems. The exploited applications can include websites/web servers, databases, standard services, network device administration and management protocols, and any other system with Internet-accessible open sockets.

Evidence Found

The provided evidence consists of five documents from the MITRE ATT&CK framework, which describe the Exploit Public-Facing Application technique, its mitigation, and related techniques.

MITRE ATT&CK Mapping

The Exploit Public-Facing Application technique is mapped to MITRE ATT&CK technique T1190. The technique involves exploiting a weakness in an Internet-facing host or system to initially access a network.

Related Vulnerabilities

The Exploit Public-Facing Application technique is related to the following vulnerabilities:

- * Unsecure coding practices
- * Software bugs
- * Temporary glitches
- * Misconfigurations
- * Vulnerabilities in client applications (T1203)
- * Drive-by compromise (T1189)
- * Exploits (T1587.004)

Recommended Mitigations

To mitigate the Exploit Public-Facing Application technique, the following recommendations are made:

- * Application isolation and least privilege to limit the impact of an exploit
- * Use secure coding best practices when designing custom software
- * Segment externally facing servers and services from the rest of the network with a DMZ or on separate hosting infrastructure
- * Use Web Application Firewalls to limit exposure of applications
- * Regularly update and patch software to prevent exploitation of known vulnerabilities

References

- * MITRE ATT&CK technique T1190: Exploit Public-Facing Application
- * MITRE ATT&CK technique T1190: Exploit Public-Facing Application Mitigation
- * MITRE ATT&CK technique T1203: Exploitation for Client Execution
- * MITRE ATT&CK technique T1189: Drive-by Compromise
- * MITRE ATT&CK technique T1587.004: Exploits

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 20/24 — q044

Human eval sheet — q044

Category: faithfulness

Question

What is the private C2 IP used by Torii in your packet captures?

Gold notes (optional reference)

Aggregated summaries lack raw C2 IPs; should not hallucinate.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the provided evidence to identify potential threats and vulnerabilities related to IoT devices and Torii. The analysis reveals a remote command execution exploit in the NETGEAR DGN2200 router and a remote command injection vulnerability in the Cisco TelePresence Recording Server. Additionally, the report discusses the PITSTOP backdoor and a buffer overflow vulnerability in Tor. However, the private C2 IP used by Torii in packet captures is not explicitly mentioned in the provided evidence.

Threat Analysis

The provided evidence suggests that the following threats are present:

1. Remote command execution exploit in the NETGEAR DGN2200 router.
2. Remote command injection vulnerability in the Cisco TelePresence Recording Server.
3. PITSTOP backdoor deployed on compromised Ivanti Connect Secure VPNs.
4. Buffer overflow vulnerability in Tor.

Evidence Found

The provided evidence consists of the following documents:

1. Document 1: NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit.
2. Document 2: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability (CVE-2012-3076).
3. Document 3: Cisco TelePresence Recording Server Web Interface Remote Command Injection Vulnerability.
4. Document 4: MITRE ATT&CK technique S1123 (PITSTOP).

5. Document 5: Tor of policy_summarize Buffer overflow vulnerability in functions (CVE-2011-1924).

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are relevant to the provided evidence:

1. S1123: PITSTOP (backdoor deployment).
2. T1210: Exploitation of Remote Services (remote command execution exploit in NETGEAR DGN2200).
3. T1211: Exploitation of Remote Services (remote command injection vulnerability in Cisco TelePresence Recording Server).
4. T1212: Exploitation of Remote Services (buffer overflow vulnerability in Tor).

Related Vulnerabilities

The following vulnerabilities are related to the provided evidence:

1. CVE-2012-3076: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability.
2. CVE-2011-1924: Tor of policy_summarize Buffer overflow vulnerability in functions.

Recommended Mitigations

To mitigate the identified threats, the following recommendations are provided:

1. Update the NETGEAR DGN2200 firmware to the latest version.
2. Patch the Cisco TelePresence Recording Server to address the remote command injection vulnerability.
3. Remove the PITSTOP backdoor from compromised Ivanti Connect Secure VPNs.
4. Update Tor to version 0.2.1.30 or later to address the buffer overflow vulnerability.

References

1. Document 1: NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit.
2. Document 2: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability (CVE-2012-3076).
3. Document 3: Cisco TelePresence Recording Server Web Interface Remote Command Injection Vulnerability.
4. Document 4: MITRE ATT&CK technique S1123 (PITSTOP).
5. Document 5: Tor of policy_summarize Buffer overflow vulnerability in functions (CVE-2011-1924).

Conclusion

The provided evidence suggests that the following threats are present: remote command execution exploit in the NETGEAR DGN2200 router, remote command injection vulnerability in the Cisco TelePresence Recording Server, PITSTOP backdoor, and buffer overflow vulnerability in Tor. However, the private C2 IP used by Torii in packet captures is not explicitly mentioned in the provided evidence.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides an analysis of the private C2 IP address used by Torii in the context of packet captures. Based on the available information, it is uncertain whether Torii uses a fixed or dynamically allocated IP address for C2 communication. The report outlines the likely threat actors, malware, and vulnerability class associated with Torii, as well as the evidence types and uncertainties that would be needed to provide a definitive answer.

Threat Analysis

Torii is a malware that is likely used by threat actors for various malicious activities. It is likely a type of remote access Trojan (RAT) or a C2 malware that uses a private IP address for communication. The exact threat actor or malware variant is uncertain without more information.

Evidence Found

Based on the available information, it is uncertain what evidence would be needed to determine the private C2 IP address used by Torii. However, ideally, evidence of Torii's behavior, such as network traffic patterns, system calls, or API calls that indicate C2 communication, would be necessary. Additionally, evidence of the technique used by Torii, such as the protocol or port number used for C2 communication, would be helpful.

MITRE ATT&CK Mapping

Based on the available information, the following MITRE ATT&CK techniques are plausible:

1. T1071 - Application Layer Protocol: Torii may use a custom protocol or a legitimate protocol (e.g., HTTP) to communicate with its C2 server.
2. T1071.001 - Web Protocols: Torii may use HTTP or HTTPS to communicate with its C2 server.
3. T1210 - Exploit Public-Facing Application: Torii may use a vulnerability in a public-facing application to establish a C2 connection.

Related Vulnerabilities

Unknown

Recommended Mitigations

1. Implement a network intrusion detection system (NIDS) to detect and prevent C2 communication.
2. Use a web application firewall (WAF) to block suspicious traffic.
3. Implement a host-based intrusion detection system (HIDS) to detect and prevent Torii malware from establishing a C2 connection.
4. Use a security information and event management (SIEM) system to monitor and analyze network traffic for suspicious activity.

References

* Model knowledge / general references only:

- + MITRE ATT&CK framework
- + Common Vulnerabilities and Exposures (CVE) database
- + Network intrusion detection system (NIDS) and web application firewall (WAF) documentation

Note: This report is based on the available information and reasoning only, and does not rely on any retrieved knowledge base evidence.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the provided evidence to identify the private C2 IP used by Torii in packet captures. The analysis reveals that the evidence is insufficient to determine the private C2 IP used by Torii.

Threat Analysis

The provided evidence includes various documents related to IoT malware, vulnerabilities, and MITRE ATT&CK techniques. However, none of these documents directly mention the private C2 IP used by Torii.

Evidence Found

The provided evidence includes the following documents:

1. Document 1: CTU-IoT-Malware-Capture-21-1, which describes the behavior of the Torii malware, but does not mention the private C2 IP.

2. Document 2: NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit, which is unrelated to Torii.
3. Document 3: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability, which is also unrelated to Torii.
4. Document 4: Cisco TelePresence Recording Server Web Interface Remote Command Injection Vulnerability, which is another unrelated document.
5. Document 5: PITSTOP, which is a backdoor that was deployed on compromised Ivanti Connect Secure VPNs, but does not mention Torii.
6. Document 6: Hide Infrastructure, which describes techniques used by adversaries to hide their C2 infrastructure, but does not mention Torii.
7. Document 7: Data Obfuscation, which describes techniques used by adversaries to obfuscate command and control traffic, but does not mention Torii.
8. Document 8: Benign Amazon Echo — CTU-Honeypot-Capture-5-1, which contains benign traffic from Amazon Echo and is unrelated to Torii.

MITRE ATT&CK Mapping

The provided evidence does not mention any MITRE ATT&CK techniques that are directly related to Torii.

Related Vulnerabilities

The provided evidence does not mention any vulnerabilities that are directly related to Torii.

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended:

1. Implement a robust intrusion detection system (IDS) to detect and prevent malicious traffic.
2. Use a secure communication protocol to encrypt command and control traffic.
3. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
4. Implement a network segmentation strategy to isolate IoT devices from the rest of the network.

References

The provided evidence includes the following references:

1. Document 1: CTU-IoT-Malware-Capture-21-1
2. Document 2: NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit
3. Document 3: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability
4. Document 4: Cisco TelePresence Recording Server Web Interface Remote Command Injection Vulnerability

5. Document 5: PITSTOP
6. Document 6: Hide Infrastructure
7. Document 7: Data Obfuscation
8. Document 8: Benign Amazon Echo — CTU-Honeypot-Capture-5-1

Conclusion

The provided evidence is insufficient to determine the private C2 IP used by Torii. Therefore, it is not possible to provide a definitive answer to the question. However, the recommended mitigations can help prevent exploitation of known vulnerabilities and detect malicious traffic.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report analyzes the provided evidence to identify the private C2 IP used by Torii in packet captures. The analysis reveals that the evidence is insufficient to determine the private C2 IP used by Torii.

Threat Analysis

The provided evidence describes various IoT malware families, including Torii, Kenjiro, Mirai, and Hide and Seek. These malware families exhibit scanning, command-and-control, and denial-of-service activities. However, the evidence does not provide specific information about the private C2 IP used by Torii.

Evidence Found

The provided evidence consists of six documents:

1. Document 1: Describes the behavior of Torii malware in an IoT device, but does not mention the private C2 IP.
2. Document 2: Describes the behavior of Kenjiro malware, which is unrelated to Torii.
3. Document 3: Describes the behavior of Mirai malware, which is unrelated to Torii.
4. Document 4: Describes the behavior of Hide and Seek malware, which is unrelated to Torii.
5. Document 5: Describes benign traffic from an Amazon Echo device, which is unrelated to Torii.
6. Document 6: Describes a vulnerability in a Cisco TelePresence Recording Server, which is unrelated to Torii.

MITRE ATT&CK Mapping

The provided evidence does not provide sufficient information to map the Torii malware to a specific MITRE ATT&CK technique.

Related Vulnerabilities

The provided evidence does not mention any vulnerabilities related to the Torii malware.

Recommended Mitigations

Based on the provided evidence, the following general recommendations can be made:

1. Implement robust security measures to prevent IoT device infections.
2. Regularly update and patch IoT devices to prevent exploitation of known vulnerabilities.
3. Monitor network traffic for suspicious activity.
4. Implement a robust incident response plan to respond to potential security incidents.

References

1. Document 1: Torii — CTU-IoT-Malware-Capture-21-1
2. Document 2: Kenjiro — CTU-IoT-Malware-Capture-17-1
3. Document 3: Mirai — CTU-IoT-Malware-Capture-7-1
4. Document 4: Hide and Seek — CTU-IoT-Malware-Capture-1-1
5. Document 5: Benign Amazon Echo — CTU-Honeypot-Capture-5-1
6. Document 6: Cisco TelePresence Recording Server WEB Interface Remote Command Injection Vulnerability (CVE-2012-3076)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 21/24 — q042

Human eval sheet — q042

Category: faithfulness

Question

List every CVE that Mirai is known to exploit according to this knowledge base.

Gold notes (optional reference)

Should refuse or state no Mirai-linked CVEs in KB.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report provides an analysis of the Mirai malware's known exploits based on the provided evidence. Mirai is a notorious IoT botnet that has been known to exploit various vulnerabilities in IoT devices. The analysis reveals that Mirai exploits multiple vulnerabilities in various IoT devices.

Threat Analysis

Mirai is a highly distributed and scalable malware that can infect a large number of IoT devices. It uses a combination of brute-force attacks and exploit kits to gain access to devices. Once infected, devices can be used to conduct DDoS attacks, spread malware, and steal sensitive information.

Evidence Found

The provided evidence consists of five documents detailing various vulnerabilities in IoT devices. The vulnerabilities are categorized as follows:

1. Cross-Site Request Forgery (CSRF): CVE-2017-7398 in D-Link DIR-615
2. Information Disclosure: CVE-2016-9355 in Alaris 8015 PC unit
3. Multiple Vulnerabilities: CVE-2013-7389 in D-Link DIR-645, CVE-2013-2678 in Linksys E1500/E2500, and CVE-2013-1603 in D-Link IP Cameras

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are relevant to the exploits listed above:

1. T1210 - Exploit Public-Facing Application: CVE-2017-7398, CVE-2013-7389, CVE-2013-2678, and CVE-2013-1603
2. T1040 - Network Sniffing: CVE-2016-9355 (information disclosure)

Related Vulnerabilities

The following vulnerabilities are related to the ones listed above:

1. CVE-2016-9355: Information Disclosure in Alaris 8015 PC unit
2. CVE-2017-7398: CSRF in D-Link DIR-615
3. CVE-2013-7389: Multiple Vulnerabilities in D-Link DIR-645
4. CVE-2013-2678: Multiple Vulnerabilities in Linksys E1500/E2500
5. CVE-2013-1603: Multiple Vulnerabilities in D-Link IP Cameras

Recommended Mitigations

To mitigate the risks associated with these vulnerabilities, the following measures can be taken:

1. Update firmware: Regularly update firmware to ensure that the latest security patches are applied.
2. Use strong passwords: Use strong and unique passwords for all devices and accounts.
3. Implement network segmentation: Segment the network to prevent lateral movement in case of a breach.
4. Use intrusion detection and prevention systems: Implement IDS/IPS systems to detect and prevent malicious activity.
5. Conduct regular security audits: Conduct regular security audits to identify and remediate vulnerabilities.

References

1. Document 1: [VARIoT] D-Link DIR-615 - Cross-Site Request Forgery - Hardware webapps Exploit
2. Document 2: [VARIoT] Alaris 8015 PC unit CVE-2016-9355 Information Disclosure Vulnerability
3. Document 3: [VARIoT] D-Link DIR-645 1.03B08 - Multiple Vulnerabilities - Hardware webapps Exploit
4. Document 4: [VARIoT] Linksys E1500/E2500 - Multiple Vulnerabilities - Hardware webapps Exploit
5. Document 5: [VARIoT] D-Link IP Cameras - Multiple Vulnerabilities - Hardware webapps Exploit

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the known exploits of the Mirai malware family. Based on the provided evidence, we have identified the CVEs that Mirai is known to exploit.

Threat Analysis

Mirai is a highly infectious malware that targets IoT devices, exploiting vulnerabilities to gain control and use them for DDoS attacks, command-and-control, and scanning activities. The malware's behavior is observed in various network scenarios, including CTU-IoT-Malware-Capture-7-1 and CTU-IoT-Malware-Capture-17-1.

Evidence Found

The provided evidence includes various documents related to IoT malware and vulnerabilities. However, only one document directly relates to Mirai:

Document 4 [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1

This document describes the behavior of Mirai malware, including scanning, command-and-control, and denial-of-service activities.

MITRE ATT&CK Mapping

Based on the provided evidence, we can map the Mirai malware behavior to the following MITRE ATT&CK techniques:

- * T1190: Exploit Public-Facing Application (Mirai exploits vulnerabilities in IoT devices)
- * T1203: Exploitation for Client Execution (Mirai exploits software vulnerabilities in IoT devices)

Related Vulnerabilities

The provided evidence does not directly link the Mirai malware to specific CVEs. However, we can infer that Mirai exploits vulnerabilities in IoT devices, which are often related to:

- * CVE-2017-7398: D-Link DIR-615 - Cross-Site Request Forgery - Hardware webapps Exploit
- * CVE-2016-9355: Alaris 8015 PC unit CVE-2016-9355 Information Disclosure Vulnerability
- * CVE-2013-7389: D-Link DIR-645 1.03B08 - Multiple Vulnerabilities - Hardware webapps Exploit

Recommended Mitigations

To mitigate the risks associated with Mirai malware, we recommend:

- * Regularly updating and patching IoT devices
- * Implementing robust security measures, such as firewalls and intrusion detection systems

- * Monitoring network traffic for suspicious activity
- * Segmenting the network to prevent lateral movement

References

- * Document 4 [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1
- * Document 7 [MITRE] System Checks
- * Document 8 [IoT23] Kenjiro — CTU-IoT-Malware-Capture-17-1

Note: The provided evidence is insufficient to list every CVE that Mirai is known to exploit.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report provides an analysis of the IoT cybersecurity threats associated with the Mirai malware. Mirai is known to exploit various vulnerabilities in IoT devices to gain unauthorized access and control. The analysis focuses on identifying the Common Vulnerabilities and Exposures (CVEs) that Mirai is known to exploit.

Threat Analysis

Mirai is a highly contagious malware that spreads rapidly across IoT networks, exploiting vulnerabilities in devices such as routers, cameras, and other network-attached devices. Once infected, these devices can be used to launch DDoS attacks, spread malware, and disrupt network services.

Evidence Found

The provided evidence consists of six documents detailing various vulnerabilities in IoT devices. While these vulnerabilities are not directly related to Mirai, they are relevant to the analysis of IoT cybersecurity threats.

MITRE ATT&CK Mapping

The following CVEs have been identified as potentially exploitable by Mirai:

- * CVE-2018-8013: Apache Batik Vulnerable to unreliable data deserialization
- * CVE-2020-10917: NEC ESMPRO Manager Unreliable data deserialization vulnerability
- * CVE-2020-10881: TP-Link Archer A7 AC1750 Out-of-bounds write vulnerabilities in firmware
- * CVE-2016-8341: Ecava IntegraXor of Web On the server SQL Injection vulnerability

These CVEs can be mapped to the following MITRE ATT&CK techniques:

- * T1210: Exploitation of Remote Services
- * T1212: Exploitation of Resource Management
- * T1213: Exploitation of Service
- * T1214: Exploitation of Local Services

Related Vulnerabilities

The following vulnerabilities are related to the identified CVEs:

- * CVE-2019-9053: Apache Batik Vulnerable to unreliable data deserialization
- * CVE-2020-10918: NEC ESMPRO Manager Unreliable data deserialization vulnerability
- * CVE-2020-10882: TP-Link Archer A7 AC1750 Out-of-bounds write vulnerabilities in firmware
- * CVE-2016-8342: Ecava IntegraXor of Web On the server SQL Injection vulnerability

Recommended Mitigations

To mitigate the identified vulnerabilities, the following recommendations are provided:

- * Ensure that all IoT devices are running the latest firmware and software updates.
- * Implement robust security measures, such as firewalls and intrusion detection systems, to prevent unauthorized access.
- * Regularly monitor network traffic and device activity to detect potential security threats.
- * Implement secure coding practices to prevent vulnerabilities in software development.

References

- * [1] Apache Batik Vulnerable to unreliable data deserialization (CVE-2018-8013)
- * [2] NEC ESMPRO Manager Unreliable data deserialization vulnerability (CVE-2020-10917)
- * [3] TP-Link Archer A7 AC1750 Out-of-bounds write vulnerabilities in firmware (CVE-2020-10881)
- * [4] Ecava IntegraXor of Web On the server SQL Injection vulnerability (CVE-2016-8341)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report provides a comprehensive analysis of the Mirai malware, a well-known IoT botnet malware that exploits vulnerabilities in devices' firmware or software to gain unauthorized access and control. Based on general knowledge and reasoning, this report identifies potential attack vectors, techniques, and vulnerabilities exploited by Mirai, as well as related MITRE ATT&CK techniques and recommended mitigations.

Threat Analysis

Mirai is a malware that primarily targets IoT devices, such as routers, cameras, and other connected devices. It's a type of botnet malware that uses brute-force attacks to gain unauthorized access to devices. Mirai exploits vulnerabilities in devices' firmware or software, allowing it to take control of the device and use it for malicious purposes.

Evidence Found

Based on general knowledge and reasoning, the following evidence was found:

- * Mirai scans for vulnerable devices on the network (Reconnaissance).
- * Mirai uses brute-force attacks to gain unauthorized access to devices (Credential Dumping).
- * Mirai exploits vulnerabilities in devices' firmware or software (Exploitation of Vulnerability).
- * Mirai takes control of the device and uses it for malicious purposes (Lateral Movement).

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are related to Mirai's attack steps:

1. Reconnaissance (TA0010): Mirai scans for vulnerable devices on the network.
2. Credential Dumping (TA0006): Mirai uses brute-force attacks to gain unauthorized access to devices.
3. Exploitation of Vulnerability (TA0005): Mirai exploits vulnerabilities in devices' firmware or software.
4. Lateral Movement (TA0008): Mirai takes control of the device and uses it for malicious purposes.

Related Vulnerabilities

Based on general knowledge and reasoning, the following vulnerabilities are related to Mirai's attack vectors:

- * CVE-2014-8361 (Telnet vulnerability)
- * CVE-2015-2051 (HTTP vulnerability)
- * CVE-2016-10292 (SSH vulnerability)

Recommended Mitigations

To prevent or mitigate Mirai attacks, the following measures can be taken:

1. Keep devices up-to-date: Ensure that devices' firmware and software are up-to-date with the latest security patches.
2. Use strong passwords: Use strong, unique passwords for all devices and accounts.
3. Implement network segmentation: Segment the network to limit the spread of malware.
4. Use intrusion detection and prevention systems: Implement intrusion detection and prevention systems to detect and prevent Mirai attacks.

References

* Model knowledge / general references only:

- + "Mirai Botnet" by Cybersecurity and Infrastructure Security Agency (CISA)
- + "IoT Security 101" by National Institute of Standards and Technology (NIST)
- + "MITRE ATT&CK Framework" by MITRE Corporation

Note: This report is based on general knowledge and reasoning, and does not rely on any specific knowledge base or external documentation.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 22/24 — q041

Human eval sheet — q041

Category: faithfulness

Question

What exact default password list does Mirai use for Telnet brute force in 2016?

Gold notes (optional reference)

KB lacks this; good system should say evidence insufficient rather than invent credentials.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the default password list used by Mirai for Telnet brute force in 2016. The analysis is based on the provided evidence, which includes various documents related to IoT vulnerabilities and exploits. The report concludes that the exact default password list used by Mirai is not explicitly mentioned in the provided evidence.

Threat Analysis

Mirai is a notorious IoT botnet that was used in several high-profile DDoS attacks in 2016. The botnet exploited vulnerabilities in various IoT devices, including routers, to gain unauthorized access and control. The use of default passwords was a key factor in Mirai's success, as it allowed the botnet to easily gain access to devices without needing to perform complex attacks.

Evidence Found

The provided evidence includes various documents related to IoT vulnerabilities and exploits. However, none of the documents explicitly mention the default password list used by Mirai for Telnet brute force in 2016. The documents do provide information on various vulnerabilities and exploits, including:

- * Document 2: Provides information on a NETGEAR DGN2200 exploit that includes hardcoded credentials, including "Gearguy/Geardog" and "Guest/Guest".
- * Document 4: Discloses a backdoor account on the ASUS RT-N13U router with a default password.
- * Document 5: Describes various vulnerabilities in the FiberHome HG6245D router, including hard-coded credentials.

MITRE ATT&CK Mapping

The provided evidence can be mapped to the following MITRE ATT&CK techniques:

- * T1110.001: Password Guessing (Document 2, Document 4, and Document 5)
- * T1210: Exploitation of Remote Services (Document 2 and Document 5)

Related Vulnerabilities

The provided evidence is related to various vulnerabilities in IoT devices, including:

- * NETGEAR DGN2200 (Document 2)
- * ASUS RT-N13U (Document 4)
- * FiberHome HG6245D (Document 5)

Recommended Mitigations

To prevent similar attacks, the following mitigations are recommended:

- * Use strong, unique passwords for all IoT devices.
- * Regularly update firmware and software to ensure the latest security patches are applied.
- * Disable Telnet and SSH access if not necessary.
- * Use network segmentation to isolate IoT devices from other network segments.

References

- * Document 1: MITRE ATT&CK technique T1110.001
- * Document 2: VARIOt - NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit
- * Document 3: VARIOt - NETGEAR DGN2200 1.0.0.29_1.7.29_HotS - Password Disclosure
- * Document 4: VARIOt - ASUS RT-N13U Backdoor Account
- * Document 5: VARIOt - FiberHome HG6245D Disclosure / Bypass / Privilege Escalation / DoS

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the default password list used by Mirai for Telnet brute force in 2016. Based on the provided evidence, it appears that Mirai used a list of common passwords to attempt access to accounts. However, the exact default password list used by Mirai is not explicitly mentioned in the provided documents.

Threat Analysis

Mirai is a malware that uses a botnet to conduct large-scale distributed denial-of-service (DDoS) attacks. In 2016, Mirai was used to conduct a massive DDoS attack on DNS provider Dyn, which resulted in widespread internet outages. Mirai uses a variety of techniques to infect devices, including brute-force attacks on Telnet and SSH services.

Evidence Found

The provided documents do not explicitly mention the exact default password list used by Mirai for Telnet brute force in 2016. However, Document 2 mentions that some firmware versions of the NETGEAR DGN2200 router have hardcoded default credentials, including "Gearguy/Geardog" and "Guest/Guest". Document 4 also mentions that the ASUS RT-N13U router comes configured with an administrative root shell with a default password, but the password is not specified.

MITRE ATT&CK Mapping

The provided evidence can be mapped to the following MITRE ATT&CK techniques:

- * T1110.001: Password Guessing (Mirai uses a list of common passwords to attempt access to accounts)
- * T1210: Exploit Public-Facing Application (Mirai uses vulnerabilities in public-facing applications to infect devices)

Related Vulnerabilities

The provided documents mention several vulnerabilities in various router models, including:

- * CVE-2012-4366: Belkin wireless routers have a predictable default WPA2-PSK passphrase based on the WAN MAC address.
- * NETGEAR DGN2200: Firmware versions 1.0.0.29_1.7.29_HotS have a password disclosure vulnerability.
- * ASUS RT-N13U: The router comes configured with an administrative root shell with a default password.

Recommended Mitigations

To mitigate the risks associated with Mirai and other similar malware, we recommend the following:

- * Use strong, unique passwords for all devices and services.
- * Enable two-factor authentication (2FA) whenever possible.
- * Regularly update and patch devices and services to prevent exploitation of known vulnerabilities.
- * Use a reputable antivirus solution to detect and prevent malware infections.

- * Implement a robust incident response plan to quickly respond to and contain malware outbreaks.

References

- * Document 1: MITRE Password Guessing
- * Document 2: VARIOt NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit
- * Document 3: VARIOt Telecom Italia Alice Router IP Packet Unauthorized Access Vulnerability
- * Document 4: VARIOt ASUS RT-N13U Backdoor Account
- * Document 5: VARIOt plural Belkin Wireless Router Network access vulnerabilities in products
- * Document 6: VARIOt NETGEAR DGN2200 1.0.0.29_1.7.29_HotS - Password Disclosure

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the default password list used by Mirai for Telnet brute force in 2016. The analysis is based on the provided evidence, which includes various documents related to password guessing, network device authentication, and IoT malware behavior.

Threat Analysis

Mirai is a notorious IoT malware that was used in a massive DDoS attack in 2016. The malware scans for vulnerable IoT devices and uses brute force attacks to gain access to them. The default password list used by Mirai for Telnet brute force is a critical piece of information that can help prevent such attacks.

Evidence Found

After analyzing the provided evidence, we found that Document 2 [VARIoT] NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit mentions that the default user account on some firmware versions has hardcoded credentials "Garguy/Geardog" or "Guest/Guest". However, this is not explicitly stated as the default password list used by Mirai.

MITRE ATT&CK Mapping

The default password list used by Mirai for Telnet brute force can be mapped to the following MITRE ATT&CK techniques:

- * T1110.001: Password Guessing
- * T1110.003: Password Spraying

Related Vulnerabilities

The default password list used by Mirai for Telnet brute force is related to the following vulnerabilities:

- * NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit (CVE-xxxx-xxxx)
- * ASUS RT-N13U Backdoor Account (CVE-xxxx-xxxx)

Recommended Mitigations

To prevent Telnet brute force attacks, we recommend the following mitigations:

1. Disable Telnet service on IoT devices.
2. Use strong passwords and password policies.
3. Implement multi-factor authentication.
4. Regularly update and patch IoT devices.
5. Use a network device authentication mechanism, such as SSH or HTTPS.

References

- * Document 1 [MITRE] Password Guessing
- * Document 2 [VARIoT] NETGEAR DGN2200 v1/v2/v3/v4 - dnslookup.cgi Remote Command Execution Exploit
- * Document 4 [VARIoT] ASUS RT-N13U Backdoor Account
- * Document 5 [MITRE] Password Spraying
- * Document 6 [MITRE] Network Device Authentication
- * Document 7 [IoT23] Mirai — CTU-IoT-Malware-Capture-7-1
- * Document 8 [IoT23] Torii — CTU-IoT-Malware-Capture-21-1

Conclusion

Based on the provided evidence, we were unable to determine the exact default password list used by Mirai for Telnet brute force in 2016. However, we identified several related vulnerabilities and recommended mitigations to prevent Telnet brute force attacks.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Professional Report: Mirai Malware Attack Analysis (2016)

1. Executive Summary

This report provides an analysis of the Mirai malware attack methodology, specifically its Telnet brute force attack strategy in 2016. While general knowledge about Mirai's attack methodology is available, the exact default password list used by Mirai for Telnet brute force attacks in 2016 remains uncertain. This report aims to provide a comprehensive understanding of the threat, its attack steps, and recommended mitigations.

2. Threat Analysis

Mirai is a type of malware known for its IoT botnet capabilities, specifically targeting devices with Telnet services enabled and default passwords set. The malware authors used a brute force attack to try various default passwords on identified devices, gaining unauthorized access and adding them to its botnet. The likely threat actors involved are malware authors or hackers using Mirai for malicious purposes.

3. Evidence Found

No retrieved knowledge base (KB) evidence is available for this analysis. The following reasoning is based on general knowledge and recalling information about Mirai's attack methodology:

Plausible network behaviours / attack steps:

1. Mirai scans for devices with Telnet services enabled and default passwords set.
2. It uses a brute force attack to try various default passwords on the identified devices.
3. Once a valid password is found, Mirai gains unauthorized access to the device and adds it to its botnet.

Related MITRE ATT&CK techniques (best effort; mark guesses):

1. T1210 - Exploit Public-Facing Application (guess)
2. T1208 - Data Encoding (guess)
3. T1211 - Exploit Remote Services (guess)
4. T1212 - Exploit Public-Facing Application (guess)

Related vulnerabilities / CVEs (unknown):

Unknown, as no specific evidence or KB is available.

Speculative default password list used by Mirai:

Based on general knowledge, Mirai was known to target devices with default passwords. Some common default passwords used by IoT devices include:

- * "admin"
- * "password"
- * "123456"

- * "qwerty"
- * "default"

However, without specific evidence, the exact default password list used by Mirai for Telnet brute force attacks in 2016 remains uncertain.

Uncertainties:

1. The exact list of default passwords used by Mirai for Telnet brute force attacks.
2. The specific devices or device models targeted by Mirai in 2016.
3. Any potential variations in Mirai's attack methodology over time.

4. MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are related to the Mirai malware attack:

- * T1210 - Exploit Public-Facing Application
- * T1208 - Data Encoding
- * T1211 - Exploit Remote Services
- * T1212 - Exploit Public-Facing Application

5. Related Vulnerabilities

Unknown, as no specific evidence or KB is available.

6. Recommended Mitigations

1. Disable Telnet services on IoT devices if not necessary.
2. Change default passwords on IoT devices to strong, unique passwords.
3. Implement a robust network segmentation strategy to limit the spread of malware.
4. Regularly update and patch IoT devices with the latest security patches.
5. Use a reputable security information and event management (SIEM) system to monitor network activity and detect potential threats.

7. References

This report is based on general knowledge and model knowledge only. The following references are provided for informational purposes:

- * "Mirai Botnet Analysis" by Malwarebytes (2016)
- * "Mirai Malware: A Threat to IoT Devices" by Symantec (2016)
- * "Telnet Brute Force Attacks: A Growing Concern" by Cybersecurity and Infrastructure Security Agency (CISA) (2016)

Please note that this report is based on general knowledge and reasoning only, and the exact default password list used by Mirai for Telnet brute force attacks in 2016 remains uncertain.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 23/24 — q025

Human eval sheet — q025

Category: mitigation

Question

What mitigations does MITRE suggest related to Network Denial of Service?

Gold notes (optional reference)

Should retrieve mitigation-oriented MITRE docs.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Professional Report: Network Denial of Service (DoS) Mitigations

1. Executive Summary

This report provides an analysis of Network Denial of Service (DoS) attacks and potential mitigations. The report is based on general knowledge and does not rely on a specific knowledge base. The purpose of this report is to provide a framework for understanding DoS attacks and identifying practical countermeasures.

2. Threat Analysis

Network DoS attacks can be perpetrated by various threat actors, including nation-state actors, hacktivists, and cybercriminals. These attacks often exploit vulnerabilities in network protocols, software, or hardware. Common malware and vulnerability classes associated with DoS attacks include botnets (e.g., Mirai), amplification attacks (e.g., DNS amplification), and protocol vulnerabilities (e.g., TCP SYN flood).

3. Evidence Found

No retrieved KB evidence is available for this report. The analysis is based on general knowledge and reasoning only.

4. MITRE ATT&CK Mapping

Based on general knowledge, the following MITRE ATT&CK techniques may be related to Network DoS attacks:

* T1190: Exploit Public-Facing Application (guess)

* T1492: Resource Hijacking (guess)

- * T1497: Domain Name System (DNS) Amplification (guess)
- * T1498: Network Denial of Service (DoS) (guess)

5. Related Vulnerabilities

Unknown.

6. Recommended Mitigations

Practical mitigations for Network DoS attacks include:

- * Implementing rate limiting on network traffic to prevent overwhelming a target server.
- * Configuring traffic filtering to block suspicious traffic patterns.
- * Deploying intrusion detection systems to detect and respond to DoS attacks.
- * Implementing content delivery networks (CDNs) to distribute traffic and reduce the load on a target server.
- * Regularly updating and patching network protocols, software, and hardware to prevent exploitation of known vulnerabilities.

7. References

This report is based on general knowledge and does not rely on a specific knowledge base. The references provided are model knowledge and general references only:

- * MITRE ATT&CK: A framework for understanding and analyzing cyber threats (<https://attack.mitre.org/>)
- * National Institute of Standards and Technology (NIST): Guide to Network Security (<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-123.pdf>)
- * SANS Institute: Network Denial of Service (DoS) Attacks (<https://www.sans.org/reading-room/whitepapers/denial-service/network-denial-service-dos-attacks-343>)

Please note that this report is based on general knowledge and does not provide a comprehensive or definitive analysis of Network DoS attacks and mitigations.

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer B

Executive Summary

This report provides an analysis of the Network Denial of Service (DoS) threat and identifies potential mitigations suggested by MITRE. The analysis is based on the provided evidence from various MITRE documents and a Cisco vulnerability advisory.

Threat Analysis

Network Denial of Service (DoS) is a type of cyber attack where an attacker attempts to make a network resource or service unavailable by flooding it with traffic. This can be achieved through various means, including SYN floods, UDP floods, and ICMP floods.

Evidence Found

The provided evidence includes six documents from MITRE and a Cisco vulnerability advisory. The relevant documents for this analysis are:

- * Document 1: MITRE ATT&CK technique T1498 - Network Denial of Service Mitigation
- * Document 2: MITRE ATT&CK technique T1499 - Endpoint Denial of Service Mitigation
- * Document 4: MITRE ATT&CK technique T1095 - Standard Non-Application Layer Protocol Mitigation
- * Document 5: MITRE ATT&CK technique T1094 - Custom Command and Control Protocol Mitigation
- * Document 6: Cisco Data Center Network Manager Path traversal vulnerability (CVE-2019-15981)

MITRE ATT&CK Mapping

The provided evidence maps to the following MITRE ATT&CK techniques:

- * T1498: Network Denial of Service Mitigation
- * T1499: Endpoint Denial of Service Mitigation
- * T1095: Standard Non-Application Layer Protocol Mitigation
- * T1094: Custom Command and Control Protocol Mitigation

Related Vulnerabilities

The provided evidence does not directly relate to any specific vulnerabilities. However, the Cisco vulnerability advisory (CVE-2019-15981) describes a path traversal vulnerability in the Cisco Data Center Network Manager.

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended:

1. Intercept incoming traffic upstream to filter out attack traffic from legitimate traffic.
2. Block source addresses sourcing the attack, block ports that are being targeted, or block protocols being used for transport.
3. Leverage services provided by Content Delivery Networks (CDN) or providers specializing in DoS mitigations to filter traffic upstream from services.
4. Enable SYN Cookies to defend against SYN floods.
5. Properly configure firewalls and proxies to limit outgoing traffic to only necessary ports and through proper network gateway systems.

6. Ensure hosts are only provisioned to communicate over authorized interfaces.
7. Use network intrusion detection and prevention systems that use network signatures to identify traffic for specific adversary malware.

References

- * MITRE ATT&CK technique T1498 - Network Denial of Service Mitigation
- * MITRE ATT&CK technique T1499 - Endpoint Denial of Service Mitigation
- * MITRE ATT&CK technique T1095 - Standard Non-Application Layer Protocol Mitigation
- * MITRE ATT&CK technique T1094 - Custom Command and Control Protocol Mitigation
- * Cisco Data Center Network Manager Path traversal vulnerability (CVE-2019-15981)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report provides an analysis of Network Denial of Service (DoS) threats and recommended mitigations. Based on the provided evidence, we have identified various techniques and vulnerabilities related to DoS attacks. Our analysis focuses on the MITRE ATT&CK framework and related vulnerabilities to suggest effective mitigations.

Threat Analysis

Network Denial of Service (DoS) attacks aim to disrupt or make a network resource unavailable by overwhelming it with traffic or requests. This can be achieved through various techniques, including:

1. Flood-based attacks: Overwhelming the network with traffic to saturate its capacity.
2. Application-layer attacks: Exploiting vulnerabilities in applications to cause crashes or denial of service.
3. Protocol-based attacks: Manipulating network protocols to disrupt communication.

Evidence Found

The provided evidence includes:

1. Document 1: MITRE ATT&CK technique T1498, which discusses Network Denial of Service Mitigation.
2. Document 3: MITRE ATT&CK technique T1095, which provides guidance on Standard Non-Application Layer Protocol Mitigation.
3. Document 4, 5, and 6: Vulnerability reports for Mikrotik Router, Cisco 7937G, and D-Link DGS-1210-28, respectively, which highlight denial of service vulnerabilities.

4. Document 7 and 8: IoT-23 scenarios CTU-IoT-Malware-Capture-1-1 and CTU-IoT-Malware-Capture-17-1, which describe Hide and Seek and Kenjiro malware behaviors, including scanning, command-and-control, and denial-of-service activity.

MITRE ATT&CK Mapping

Based on the provided evidence, the following MITRE ATT&CK techniques are related to Network Denial of Service:

1. T1498: Network Denial of Service Mitigation
2. T1095: Standard Non-Application Layer Protocol Mitigation

Related Vulnerabilities

The following vulnerabilities are related to Network Denial of Service:

1. Mikrotik Router Denial Of Service (Document 4)
2. Cisco 7937G Denial Of Service / Privilege Escalation (Document 5)
3. D-Link DGS-1210-28 Denial Of Service (Document 6)

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended:

1. Intercept incoming traffic upstream to filter out attack traffic from legitimate traffic.
2. Block source addresses sourcing the attack, block ports that are being targeted, or block protocols being used for transport.
3. Properly configure firewalls and proxies to limit outgoing traffic to only necessary ports and through proper network gateway systems.
4. Ensure hosts are only provisioned to communicate over authorized interfaces.
5. Implement network intrusion detection and prevention systems that use network signatures to identify traffic for specific adversary malware.
6. Regularly update and patch devices to prevent exploitation of known vulnerabilities.

References

1. Document 1: MITRE ATT&CK technique T1498
2. Document 3: MITRE ATT&CK technique T1095
3. Document 4: Mikrotik Router Denial Of Service
4. Document 5: Cisco 7937G Denial Of Service / Privilege Escalation
5. Document 6: D-Link DGS-1210-28 Denial Of Service
6. Document 7: IoT-23 scenario CTU-IoT-Malware-Capture-1-1
7. Document 8: IoT-23 scenario CTU-IoT-Malware-Capture-17-1

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Executive Summary

This report provides an analysis of Network Denial of Service (DoS) threats and recommended mitigations based on MITRE ATT&CK techniques. The analysis focuses on techniques T1498, T1499, T1095, and T1094, which are related to Network DoS, Application or System Exploitation, Standard Non-Application Layer Protocol Mitigation, and Custom Command and Control Protocol Mitigation, respectively.

Threat Analysis

Network Denial of Service (DoS) attacks involve overwhelming a network or system with traffic, rendering it unavailable to users. This type of attack can be launched using various techniques, including flooding, SYN floods, and application crashes. Adversaries may exploit software vulnerabilities to cause an application or system to crash, leading to a persistent DoS condition.

Evidence Found

The provided evidence consists of five MITRE ATT&CK documents, which describe various techniques related to Network DoS and other types of attacks.

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques are related to Network DoS:

- * T1498: Network Denial of Service Mitigation
- * T1499: Endpoint Denial of Service Mitigation
- * T1095: Standard Non-Application Layer Protocol Mitigation
- * T1094: Custom Command and Control Protocol Mitigation

Related Vulnerabilities

The following vulnerabilities are related to Network DoS:

- * Exploiting software vulnerabilities to cause an application or system to crash (T1499.004)
- * Flooding a network or system with traffic (T1498)
- * Exploiting known or zero-day vulnerabilities to crash applications and/or systems (T1499.004)

Recommended Mitigations

Based on the provided evidence, the following mitigations are recommended to prevent Network DoS attacks:

- * Intercept incoming traffic upstream to filter out attack traffic from legitimate traffic (T1498)
- * Block source addresses sourcing the attack, block ports that are being targeted, or block protocols being used for transport (T1498, T1499)
- * Enable SYN Cookies to defend against SYN floods (T1499)
- * Properly configure firewalls and proxies to limit outgoing traffic to only necessary ports and through proper network gateway systems (T1095, T1094)
- * Ensure hosts are only provisioned to communicate over authorized interfaces (T1095, T1094)
- * Use network intrusion detection and prevention systems that use network signatures to identify traffic for specific adversary malware (T1095, T1094)

References

- * MITRE ATT&CK technique T1498: Network Denial of Service Mitigation
- * MITRE ATT&CK technique T1499: Endpoint Denial of Service Mitigation
- * MITRE ATT&CK technique T1095: Standard Non-Application Layer Protocol Mitigation
- * MITRE ATT&CK technique T1094: Custom Command and Control Protocol Mitigation
- * MITRE ATT&CK technique T1499.004: Application or System Exploitation

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____

Sheet 24/24 — q019

Human eval sheet — q019

Category: exploit

Question

Are there exploit records related to unauthenticated DNS change on home routers?

Gold notes (optional reference)

UTstarcom / D-Link DNS change style exploits if present.

Rate each answer 1–5 on Faithfulness, Usefulness, Technical correctness.

Do not try to guess which system produced which letter.

Answer A

Executive Summary

This report analyzes the threat of unauthenticated DNS change on home routers and its potential exploitation by adversaries. The evidence suggests that several home router models, including D-Link DSL-2740R, D-Link DSL-2640B, and IntelBras WRN 340, are vulnerable to unauthenticated remote DNS change exploits. This vulnerability can be exploited by adversaries to alter DNS records, facilitating collection and credential access efforts. The report also maps the threat to MITRE ATT&CK techniques and identifies related vulnerabilities.

Threat Analysis

The threat of unauthenticated DNS change on home routers is significant, as it allows adversaries to alter DNS records without permission. This can be used to redirect traffic, facilitate collection and credential access efforts, and compromise third-party DNS servers. The evidence suggests that several home router models are vulnerable to unauthenticated remote DNS change exploits, making them potential targets for adversaries.

Evidence Found

The evidence found includes four documents:

1. Document 1: D-Link DSL-2740R Unauthenticated Remote DNS Change - This document describes an exploit for remotely changing DNS settings on the D-Link DSL-2740R router without authentication.
2. Document 2: D-Link DSL-2640B Unauthenticated Remote DNS Changer - This document describes a remote exploit for changing DNS settings unauthenticated on the D-Link DSL-2640B.
3. Document 3: IntelBras WRN 340 Unauthenticated Remote DNS Changer - This document describes an exploit for remotely changing DNS settings on the IntelBras WRN 340 ADSL modem

router without authentication.

4. Document 4: MITRE ATT&CK technique T1584.002 - DNS Server - This document describes how adversaries may compromise third-party DNS servers to alter DNS records and facilitate collection and credential access efforts.

MITRE ATT&CK Mapping

The threat of unauthenticated DNS change on home routers maps to the following MITRE ATT&CK techniques:

1. T1584.002 - DNS Server - Adversaries may compromise third-party DNS servers to alter DNS records and facilitate collection and credential access efforts.
2. T1584.001 - Domains - Adversaries may hijack domains and/or subdomains to use during targeting.
3. T1596.001 - DNS/Passive DNS - Adversaries may search DNS data for information about victims that can be used during targeting.

Related Vulnerabilities

The evidence suggests that the following vulnerabilities are related to the threat of unauthenticated DNS change on home routers:

1. CVE-2020-13777 - Unauthenticated remote DNS change vulnerability in D-Link DSL-2740R.
2. CVE-2020-13778 - Unauthenticated remote DNS change vulnerability in D-Link DSL-2640B.
3. CVE-2020-13779 - Unauthenticated remote DNS change vulnerability in IntelBras WRN 340.

Recommended Mitigations

To mitigate the threat of unauthenticated DNS change on home routers, the following recommendations are made:

1. Update firmware to the latest version to patch known vulnerabilities.
2. Change default administrator passwords to prevent unauthorized access.
3. Enable WPA2 encryption to prevent unauthorized access to the router.
4. Use a VPN to encrypt DNS traffic.
5. Monitor DNS traffic for suspicious activity.

References

1. Document 1: D-Link DSL-2740R Unauthenticated Remote DNS Change
2. Document 2: D-Link DSL-2640B Unauthenticated Remote DNS Changer
3. Document 3: IntelBras WRN 340 Unauthenticated Remote DNS Changer
4. Document 4: MITRE ATT&CK technique T1584.002 - DNS Server
5. Document 5: MITRE ATT&CK technique T1584.001 - Domains
6. Document 6: MITRE ATT&CK technique T1596.001 - DNS/Passive DNS

7. Document 7: IoT23 - Hide and Seek — CTU-IoT-Malware-Capture-1-1

8. Document 8: IoT23 - Kenjiro — CTU-IoT-Malware-Capture-17-1

- Faithfulness (1–5): ____

- Usefulness (1–5): ____

- Technical correctness (1–5): ____

Answer B

Executive Summary

This report analyzes the threat of unauthenticated DNS change exploits on home routers. The evidence found indicates that several router models, including D-Link DSL-2640B, D-Link DSL-2640U, D-Link DSL-2740R, IntelBras WRN 340, and D-Link DIR-867, DIR-878, and DIR-882, are vulnerable to unauthenticated remote DNS change exploits. These exploits allow attackers to modify DNS settings, potentially redirecting users to malicious sites.

Threat Analysis

The threat of unauthenticated DNS change exploits on home routers is significant. Attackers can use these exploits to compromise user security and confidentiality by redirecting them to malicious sites. This can lead to various consequences, including:

- * Malware infections
- * Data theft
- * Financial loss
- * Reputation damage

Evidence Found

The following evidence was found:

- * Document 1: DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
- * Document 2: DLink DSL-2640U - Unauthenticated DNS Change Exploit
- * Document 3: D-Link DSL-2740R Unauthenticated Remote DNS Change
- * Document 4: D-Link DSL-2640B Unauthenticated Remote DNS Changer
- * Document 5: IntelBras WRN 340 Unauthenticated Remote DNS Changer
- * Document 6: plural D-Link Authentication vulnerabilities in routers (CVE-2020-8863)

MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques and tactics are relevant to this threat:

- * T1210 - Exploitation of Remote Services
- * T1204 - User Execution
- * T1190 - Exploit Public-Facing Application

- * T1562 - Impair Defenses
- * T1071 - Application Launch

Related Vulnerabilities

The following vulnerabilities are related to this threat:

- * CVE-2020-8863: plural D-Link Authentication vulnerabilities in routers

Recommended Mitigations

To mitigate this threat, the following measures can be taken:

1. Update firmware: Ensure that all router firmware is up-to-date, as newer versions may include patches for these vulnerabilities.
2. Use strong passwords: Use strong, unique passwords for all router administrator accounts.
3. Enable WPA2 encryption: Enable WPA2 encryption on the router to prevent unauthorized access.
4. Use a VPN: Use a virtual private network (VPN) to encrypt internet traffic and protect against DNS spoofing.
5. Monitor DNS settings: Regularly monitor DNS settings to detect any unauthorized changes.
6. Use a reputable DNS service: Use a reputable DNS service that provides additional security features, such as DNS filtering and blocking.

References

- * Document 1: DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
- * Document 2: DLink DSL-2640U - Unauthenticated DNS Change Exploit
- * Document 3: D-Link DSL-2740R Unauthenticated Remote DNS Change
- * Document 4: D-Link DSL-2640B Unauthenticated Remote DNS Changer
- * Document 5: IntelBras WRN 340 Unauthenticated Remote DNS Changer
- * Document 6: plural D-Link Authentication vulnerabilities in routers (CVE-2020-8863)

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer C

Executive Summary

This report analyzes the threat of unauthenticated DNS change exploits on home routers. The provided evidence reveals multiple records of exploits targeting various D-Link and IntelBras home routers, allowing attackers to remotely change DNS settings without authentication. This vulnerability can be used to redirect users to malicious sites, perform phishing attacks, or conduct other malicious activities.

Threat Analysis

The threat analysis indicates that the exploits are designed to target the web interface of the routers, which is accessible without authentication. This allows attackers to remotely modify the DNS settings, redirecting users to malicious sites or conducting other malicious activities. The exploits are likely to be used by cybercriminals to gain unauthorized access to user data, conduct phishing attacks, or spread malware.

Evidence Found

The provided evidence consists of five documents detailing exploits for the following home routers:

1. D-Link DSL-2740R
2. D-Link DSL-2640B
3. IntelBras WRN 340
4. D-Link DSL-2640B (same as document 2)
5. D-Link DSL-2640U

All of these exploits are designed to target the web interface of the routers, allowing attackers to remotely change DNS settings without authentication.

MITRE ATT&CK Mapping

The exploits can be mapped to the following MITRE ATT&CK techniques:

1. T1210 - Exploitation of Remote Services
2. T1204 - User Execution of Keylogging Malware
3. T1208 - Document and Content Management
4. T1212 - Exploitation of Remote Services
5. T1214 - User Execution of Malicious Code

Related Vulnerabilities

The exploits are related to the following vulnerabilities:

1. CVE-2017-2847 - D-Link DSL-2740R Unauthenticated Remote DNS Change
2. CVE-2017-2848 - D-Link DSL-2640B Unauthenticated Remote DNS Change
3. CVE-2017-2849 - IntelBras WRN 340 Unauthenticated Remote DNS Change

Recommended Mitigations

To mitigate the threat of unauthenticated DNS change exploits, the following recommendations are made:

1. Update the firmware of the home router to the latest version.
2. Change the default administrator password.

3. Enable WPA2 encryption for wireless networks.
4. Use a VPN to encrypt internet traffic.
5. Regularly monitor the router's logs for suspicious activity.

References

1. Document 1: [VARIoT] D-Link DSL-2740R Unauthenticated Remote DNS Change
2. Document 2: [VARIoT] D-Link DSL-2640B Unauthenticated Remote DNS Changer
3. Document 3: [VARIoT] IntelBras WRN 340 Unauthenticated Remote DNS Changer
4. Document 4: [VARIoT] DLink DSL-2640B - Unauthenticated Remote DNS Change Exploit
5. Document 5: [VARIoT] DLink DSL-2640U - Unauthenticated DNS Change Exploit

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Answer D

Unauthenticated DNS Change on Home Routers: Threat Analysis and Mitigation Recommendations

1. Executive Summary

This report provides an analysis of the potential threat posed by unauthenticated DNS changes on home routers. The analysis suggests that advanced persistent threats (APTs) or nation-state actors may use sophisticated malware to target home routers, potentially leading to malicious redirection of internet traffic or other malicious activities. The report outlines the likely threat actors, malware, and vulnerability class involved, as well as the desired evidence types and key uncertainties and limitations.

2. Threat Analysis

The threat analysis suggests that the following threat actors may be involved in exploiting unauthenticated DNS changes on home routers:

- * Advanced Persistent Threats (APTs)
- * Nation-state actors

The malware used in such attacks may include:

- * Sophisticated malware designed to target home routers
- * Malware that uses remote code execution (RCE) or command injection vulnerabilities to gain access to the device's administrative interface

The vulnerability class involved may include:

- * Remote Code Execution (RCE) vulnerabilities in home router firmware
- * Command injection vulnerabilities in home router firmware

3. Evidence Found

No retrieved KB evidence is available to support the existence of exploit records related to unauthenticated DNS changes on home routers. However, based on the analysis, it is plausible that such exploits may exist. The following attack steps may be involved:

- * Initial Access: An attacker uses a RCE vulnerability to gain access to the home router's administrative interface.
- * Privilege Escalation: The attacker uses the administrative interface to modify the DNS settings, potentially using a command injection vulnerability to execute malicious code.
- * Command and Control: The attacker uses the modified DNS settings to redirect internet traffic to a malicious server or website, potentially for further exploitation or data exfiltration.

4. MITRE ATT&CK Mapping

The following MITRE ATT&CK techniques may be relevant to the attack scenario described above:

- * T1055: Network Service Scanning
- * T1210: Exploit Public-Facing Application
- * T1059: Command and Control

5. Related Vulnerabilities

The following types of vulnerabilities may be relevant to unauthenticated DNS changes on home routers:

- * Remote Code Execution (RCE) vulnerabilities in home router firmware
- * Command injection vulnerabilities in home router firmware

6. Recommended Mitigations

To prevent or mitigate unauthenticated DNS changes on home routers, the following practical mitigations can be implemented:

- * Regular Firmware Updates: Ensure that the home router's firmware is regularly updated to patch known vulnerabilities.
- * Strong Passwords: Use strong, unique passwords for the home router's administrative interface.
- * Two-Factor Authentication: Enable two-factor authentication for the home router's administrative interface to prevent unauthorized access.
- * Monitor Network Activity: Regularly monitor network activity for suspicious behavior, such as unusual DNS queries or traffic redirection.

7. References

This report is based on model knowledge and general references only. No specific knowledge base evidence was retrieved to support the analysis. The following general references may be useful for further research:

- * MITRE ATT&CK: A framework for understanding and classifying cyber threats
- * NIST Cybersecurity Framework: A framework for managing and reducing cybersecurity risk
- * SANS Institute: A leading provider of cybersecurity training and research

- Faithfulness (1–5): ____
- Usefulness (1–5): ____
- Technical correctness (1–5): ____

Preference rank (1=best ... 4=worst)

A: ____ B: ____ C: ____ D: ____